

الجمهورية الجزائرية الديمقراطية الشعبية
وزارة التعليم العالي والبحث العلمي

Université Badji Mokhtar -
Annaba
Badji Mokhtar – Annaba
University



جامعة باجي مختار – عنابة

Faculté : Technologie

Département : Informatique

Domaine : Mathématique-Informatique

Filière : Informatique

Spécialité : RSI

Mémoire

Présenté en vue de l'obtention du Diplôme de Master

Thème

Un schéma d'authentification sécurisé et légère dans IOHT

Présenté par : Ouafi Nour El Houda

Encadrant : Ahmim Marwa

Grade: MCA

Université: UBMA

Jury de Soutenance :

Ghoualmi Nacira	Professeur	UBMA	Président
Ahmim Marwa	MCA	UBMA	Encadrant
Naamane Sarah	MAB	UBMA	Examineur

Année Universitaire : 2023/2024

Dédicaces

*Je dédie cet effort à celui qui m'a aidé, qui a été très patient
avec moi durant toute ma vie et qui s'est battu pour le bien de ma
supériorité. Celui qui est aujourd'hui absent mais toujours présent dans
mon cœur, il n'a jamais quitté mon esprit ni ma prière, et je ne l'ai
jamais oublié*

...

A mon père

Remerciements

je remercie tout d'abord le bon dieu pour m'avoir donné le courage et la santé pour accomplir ce travail.

Je commence par exprimer ma profonde reconnaissance envers ma directrice de mémoire, Dr Marwa Ahmim, pour son encadrement précieux, ses conseils éclairés, et sa disponibilité constante. Sa patience et son soutien ont été inestimables, Elle a su me guider avec bienveillance et rigueur, Je lui suis profondément reconnaissant pour tout ce qu'elle a fait pour moi.

Je souhaite également exprimer ma reconnaissance envers mes très chers parents , dont le soutien indéfectible a été une source de force et d'encouragement tout au long de ce parcours. Mes frères, ainsi que ma sœur , méritent également mes remerciements pour leur soutien et leurs encouragements.

Je tiens également à remercier sincèrement les membres de mon jury Pr Nacira Ghoualmi-Zine et Dr Sarah Naamane, pour toute leurs aides et leur dévouement , qui ont été d'une grande valeur pour moi.

À tous ces intervenants, je présente mes remerciements, mon respect et ma gratitude.

Résumé

L'Internet des Objets de Santé (IoHT:Internet of Healthcare Things) est une révolution dans le domaine médical, promettant une surveillance continue et personnalisée de la santé grâce à des dispositifs connectés. Cependant, la sécurité des données sensibles échangées dans l'IoHT est une préoccupation majeure, avec des risques potentiels tels que la compromission des dispositifs et les cyberattaques. Précédemment, Chien-Ming Chen et al avaient proposé un schéma d'authentification dans l'Internet des objets (IoT). pour l'environnement des soins de santé. Cependant, l'analyse approfondie a démontré que le protocole était vulnérable et qu'il ne pouvait pas résister aux différentes attaques prévues, Dans ce contexte, Nous proposons un nouveau schéma d'authentification adapté à l'IoHT, nommé "LSAP-IOHT". Il utilise des techniques cryptographiques avancées telles que Zero-Trust, PUF, ECC et 3FA. LSAP-IOHT vise à garantir l'intégrité, la confidentialité et l'authenticité des données échangées dans l'IoHT. La vérification formelle et informelle de notre protocole montre qu'il résiste à différents types d'attaques, notamment les attaques de l'homme du milieu, l'usurpation d'identité et les attaques par replay. De plus, la complexité de LSAP-IOHT reste légère, ce qui le rend adapté aux dispositifs IoHT aux ressources limitées. L'outil de simulation Scyther a été utilisé comme approche formelle pour établir la validité du protocole proposé.

Mots clés : Authentification, IoHT , protocole, Attaques, scyther.

Abstract

The Internet of Healthcare Things (IoHT) represents a revolution in the medical field, promising continuous and personalized health monitoring through connected devices. However, the security of sensitive data exchanged within IoHT is a major concern, with potential risks such as device compromise and cyberattacks. Previously, Chien-Ming Chen et al. proposed an authentication scheme for the Internet of Things (IoT) in healthcare environments. However, in-depth analysis demonstrated vulnerabilities in the protocol, unable to withstand various anticipated attacks. In this context, we propose a new authentication scheme tailored for IoHT, named "LSAP-IOHT". It utilizes advanced cryptographic techniques such as Zero-Trust, PUF, ECC, and 3FA. LSAP-IOHT aims to ensure the integrity, confidentiality, and authenticity of data exchanged within IoHT. Formal and informal verification of our protocol shows resilience against different types of attacks, including man-in-the-middle attacks, identity theft, and replay attacks. Furthermore, the complexity of LSAP-IOHT remains lightweight, making it suitable for IoHT devices with limited resources. The Scyther simulation tool was employed as a formal approach to establish the validity of the proposed protocol.

Key words : Authentication, IoHT , protocol, Attacks, scyther.

الملخص

تُعد إنترنت الأشياء الصحية ثورة في المجال الطبي، حيث تَعِدُ بالمراقبة الصحية المستمرة والشخصية من خلال الأجهزة المتصلة. إلا أن أمن البيانات الحساسة التي يتم مشاركتها في إنترنت الأشياء الصحية يمثل مصدر قلق كبير، مع وجود مخاطر محتملة مثل اختراق الأجهزة والهجمات الإلكترونية، في السابق، اقترح تشين مينج تشين وآخرون مخطط مصادقة قائم على إنترنت الأشياء خاص ببيئة الرعاية الصحية. ومع ذلك، أظهر التحليل العميق أن البروتوكول كان عرضة للاختراق ولم يتمكن من الصمود أمام العديد من الهجمات المتوقعة، في نفس السياق، نقترح مخطط مصادقة جديد مصمم خصيصًا لتكنولوجيا إنترنت الأشياء، يسمى "LSAP-IOHT" وهو يستخدم تقنيات التشفير المتقدمة مثل Zero-Trust و PUF و ECC و 3FA. تهدف LSAP-IOHT إلى ضمان سلامة وسرية وموثوقية البيانات المتبادلة داخل IoHT. يُظهر الفحص الرسمي وغير الرسمي للبروتوكول الخاص بنا القدرة على الصمود ضد أنواع مختلفة من الهجمات، بما في ذلك هجمات الرجل في الوسط وسرقة الهوية وهجمات إعادة الإرسال. علاوة على ذلك، لا يزال تعقيد بروتوكول LSAP-IOHT خفيف جدًا، مما يجعله مناسبًا لأجهزة IoHT ذات الموارد المحدودة. تم استخدام أداة المحاكاة Scyther كنهج رسمي لإثبات صحة البروتوكول المقترح.

الكلمات المفتاحية : المصادقة، إنترنت الأشياء في مجال الرعاية الصحية، البروتوكول، الهجمات.Scyther،

Table des matières

Table de matières.....	I
Table des figures.....	III
Liste des tableaux.....	VI
Introduction générale.....	1

Chapitre 1: l'Internet des Objets «IoT»

1.1 Les concepts de base de l'IOT.....	5
1.2 Architecture de l'Internet des Objets.....	7
1.2.1 les Couches de l'IoT	7
1.2.2 les modèles de déploiement de l'IoT.....	9
1.3 Les technologies de l'IoT.....	11
1.4 Applications et domaines d'utilisation de IOT.....	13
1.5 Problèmes et défis liés à l'IoT.....	16
1.6 Le futures de l'IoT.....	18
1.7 La conclusion.....	19

Chapitre 2: La sécurité dans «IoT»

2.1 Définition.....	21
2.2 Dimensions de sécurité informatique.....	21
2.3 Les attaques à différents couches.....	23
2.3.1 les attaques au niveau de la couche physique.....	23
2.3.2 les attaques au niveau de la couche réseau.....	24
2.3.3 les attaques au niveau de la couche application.....	26
2.3.3 les attaques au niveau de la couche de traitement de données.....	27
2.4 Mécanismes de sécurité pour l'IoT.....	28
2.5 Normes et réglementations en matière de sécurité IoT.....	31
2.6 La conclusion.....	32

Chapitre 3: Notre contribution

3.1 Travaux connexes.....	34
3.2 Modèle du système.....	38
3.3 La revue de protocole de Chien-Ming Chen et al.....	39
3.4 La cryptanalyse du protocole de Chien-Ming Chen et al.....	41
3.5 Notre proposition de schéma LSAP-IOHT.....	42
3.6 Analyse de sécurité.....	48
3.7 La conclusion.....	52
Conclusion générale.....	53
Référence.....	54

Table des figures

Figure 1. 1 Internet des objets.....	5
Figure 1. 2 la transmission des donnée dans les réseau de capteur.....	7
Figure 1. 3 l'architecture de IoT.....	9
Figure 1. 4 Patchs de peau incorporés.....	13
Figure 1. 5 L'Internet des Objets pour une agriculture plus intelligente.....	15
Figure 1. 6 la surveillance des animaux dans l'IOT.....	16
Figure 1. 7 L'AIoT : L'avenir de la convergence de l'Intelligence Artificielle et de l'Internet des Objets.....	19
Figure 2 .1 Dimensions de sécurité informatique.....	22
Figure 2.2 Le pare-feu filtre les menaces.....	29
Figure 2.3 fonction de gestion des clés.....	30
Figure 3.1 Le modèle de système de santé proposé.....	38
Figure 3.2 le scénario d'attaque de usurpation d'identité de l'utilisateur.....	42
Figure 3.3 phase d'initiation.....	43
Figure 3.4 phased'enregistrement de l'utilisateur.....	44
Figure 3.5 phase d'enregistrement du capteur.....	45
Figure 3.6 phase d'enregistrement du capteur.....	47
Figure3.7 phase de connexion et d'authentification en SPDL.....	50
Figure 3.8 Résultat de la vérification formelle.....	51

Liste des tableaux

Tableau 3.1 Comparaison de la sécurité.....	36
Tableau 3.2 Comparaison des performances.....	37
Tableau 3.3 Définitions des notations.....	43

Introduction générale

1. Le cadre scientifique

L'Internet des Objets de Santé (IoHT, Internet of Health Things) constitue une innovation majeure en fusionnant les technologies de l'information avec les soins médicaux, créant ainsi un réseau intelligent de dispositifs connectés dédiés à la surveillance et à la gestion de la santé. Ce cadre scientifique englobe une multitude de technologies et d'appareils, notamment des capteurs biométriques, des dispositifs portables, des équipements médicaux connectés et des plateformes de télé-santé. Ces composants interagissent via des réseaux sans fil comme le Wi-Fi, le Bluetooth et les réseaux cellulaires pour collecter, transmettre et analyser des données de santé en temps réel.

L'architecture de l'IoHT repose sur trois niveaux principaux : le niveau des dispositifs, où les capteurs collectent des données ; le niveau de la communication, qui assure la transmission sécurisée de ces données ; et le niveau de traitement et d'analyse, où les informations sont stockées et analysées pour fournir des insights exploitables par les professionnels de la santé.

Les avantages de l'IoHT sont nombreux : il permet une surveillance continue et à distance des patients, facilitant la gestion des maladies chroniques et réduisant la fréquence des visites médicales ; il améliore la précision des diagnostics et la personnalisation des traitements ; et il contribue à la réduction des coûts de santé en optimisant l'utilisation des ressources et en permettant une détection précoce des anomalies. En résumé, l'IoHT représente un cadre scientifique révolutionnaire qui promet de transformer les soins de santé grâce à l'interconnectivité et à l'analyse avancée des données.

Par exemple, une attaque sur un dispositif de surveillance cardiaque connecté pourrait entraîner la transmission de données falsifiées, induisant en erreur les professionnels de santé et mettant la vie du patient en péril.

Par conséquent, il est impératif de développer et de mettre en œuvre des protocoles de sécurité avancés et adaptés aux spécificités des dispositifs IoHT pour garantir la protection des données de santé et la fiabilité des systèmes médicaux connectés.

2. La problématique

Aujourd'hui, des médias américains de premier plan tels que "CBS Evening News" et "The Wall Street Journal", ainsi que de nombreuses publications à travers le monde, ont mis en lumière le problème émergent des dispositifs médicaux piratés et des cyberattaques provoquant des pannes dans les services d'urgence des hôpitaux, soulignant que ces attaques sur IOHT pourraient devenir le prochain cauchemar en matière de sécurité

la nature sensible des données de santé et la diversité des dispositifs impliqués posent des défis significatifs en matière de sécurité et de confidentialité, Les dispositifs IoHT

Introduction générale

collectent et transmettent des informations extrêmement sensibles, telles que les données biométriques, les historiques médicaux et les états de santé en temps réel. La diversité et l'hétérogénéité des dispositifs impliqués - allant des capteurs portables aux implants médicaux connectés - augmentent la complexité de la sécurisation de ces systèmes. Cette variété de dispositifs, souvent dotés de capacités de traitement et de stockage limitées, crée une surface d'attaque étendue et vulnérable à une multitude de menaces.

Les cyberattaques, telles que les interceptions de données, les accès non autorisés, et les altérations de dispositifs, peuvent avoir des conséquences graves. Sans mesures de sécurité robustes, les données de santé peuvent être exposées à des violations de confidentialité, compromettant la vie privée des patients. De plus, l'intégrité des dispositifs médicaux peut être menacée, ce qui pourrait mener à des diagnostics erronés, des traitements inadéquats, voire à des situations mettant en danger la vie des patients.

3. Le but du travail et le travail réalisé

Notre projet consiste à proposer un nouveau schéma d'authentification léger et sécurisé adapté aux dispositifs de l'Internet des Objets de Santé (IoHT). L'objectif principal est de répondre au besoin urgent de sécuriser les données sensibles échangées au sein de l'IoHT, en utilisant des techniques cryptographiques avancées. Nous avons intégré plusieurs approches modernes de sécurité telles que l'approche Zero-Trust, les Physical Unclonable Functions (PUF), l'Elliptic Curve Cryptography (ECC), et l'authentification à trois facteurs (Three-Factor Authentication).

L'approche Zero-Trust assure que chaque accès est strictement vérifié et authentifié, minimisant ainsi les risques liés aux comportements non sécurisés ou aux attaques internes. Les PUF exploitent les caractéristiques physiques uniques des composants électroniques pour créer des identifiants sécurisés et non reproductibles, ce qui renforce la sécurité contre les tentatives de clonage. L'ECC fournit un niveau élevé de sécurité avec des clés de taille réduite, idéale pour les dispositifs IoHT souvent contraints par des capacités de calcul et de stockage limitées. Enfin, l'authentification à trois facteurs combine des éléments de connaissance tel que ID de possession, un mot de passe, CRP.

Dans notre analyse informelle, nous avons démontré que notre protocole est résistant à diverses attaques connues telles que les attaques de l'intérieur (privileged insider attacks), l'usurpation d'identité, les attaques de l'homme du milieu (MITM, Man-In-The-Middle), et les attaques par relecture (replay attacks). Pour valider formellement la sécurité de notre protocole, nous avons utilisé l'outil de vérification Scyther. Les résultats obtenus confirment que notre protocole offre une résistance efficace contre ces menaces, assurant ainsi une protection robuste pour les données sensibles échangées dans l'IoHT.

Introduction générale

4. La structure du mémoire

Notre mémoire est organisée comme suit :

Chapitre 1 l'Internet des Objets «IoT» : ce chapitre, définit les bases de l'Internet des Objets (IoT), notamment son architecture et ses modèles de déploiement , ses technologies clés, ses applications , ses défis .

Chapitre 2 La sécurité dans IOT :ce chapitre , définit en profondeur les différentes facettes de la sécurité informatique, allant de sa définition , dimensions , en passant par les attaques qui peuvent survenir à différentes couches du réseau, de la physique à l'application et les mécanismes de sécurité spécifiques à l'IoT.

Chapitre 3 Notre contribution : Dans ce chapitre, nous avons discuté des travaux connexes dans le domaine de l'IoHT et réalisé une analyse approfondie du protocole proposé par Chien-Ming Chen et al. Par la suite, nous avons proposé un nouveau schéma d'authentification. L'analyse formelle et informelle via l'outil Scyther montre que le protocole proposé est sécurisé.

Chapitre 1

l'Internet des Objets

«IoT»

Au cours des cinq dernières décennies , le monde a connu une ère dominée par la technologie , L'internet des Objets représente une révolution technologique majeure, où des objets physiques ordinaires deviennent des entités intelligentes connectées à Internet. Ces objets, qu'ils soient des appareils domestiques, des capteurs industriels ou des dispositifs médicaux, sont dotés de capteurs, de logiciels et de connectivité réseau leur permettant de collecter, de partager et d'analyser des données .

Toutefois, cette ubiquité croissante de l'IoT l'a également exposé à diverses menaces en matière de cybersécurité. depuis que l'IoT a évolué d'un simple privilège à une nécessité incontournable.

Dans ce chapitre, nous aborderons les bases de l'IoT, en définissant ses concepts fondamentaux, en explorant son architecture, ses caractéristiques et les technologies.

1.1 Les concepts de base de l'IOT

IoT (Internet of things) est un concept technique mondial émergent basé sur l'Internet qui facilite l'échange dans les réseaux de la chaîne d'approvisionnement mondiale de biens et de services entre tous les éléments, équipements et objets connectés au réseau. L'IOT désigne l'interconnexion en réseau de ces objets du quotidien, qui sont souvent dotés d'une certaine forme d'intelligence. Dans ce contexte, l'internet peut également être une plateforme permettant aux appareils de communiquer électroniquement et de partager des informations et des données spécifiques avec le monde qui les entoure. L'IOT peut donc être considéré comme une véritable évolution de ce que nous connaissons sous le nom d'internet, en y ajoutant une interconnectivité plus étendue, une meilleure perception de l'information et des services intelligents plus complets[1].



Figure 1.1 Internet des objets[2]

L'IOT a été créé entre 2008 et 2009, l'expression "Internet des objets" a été utilisée pour la première fois en 1999 par Kevin Ashton qui dans le domaine de l'identification par radiofréquence (RFID) en réseau et des technologies de détection émergentes. En 2010, le nombre d'objets et de dispositifs physiques quotidiens connectés à l'internet était d'environ 12,5 milliards. Aujourd'hui, il y a environ 50 milliards d'appareils connectés à l'IdO. Plus ou moins un appareil intelligent par personne[1].

Au cœur de cette révolution de l'IOT, Les réseaux de capteurs se révèlent être les artisans de l'innovation dans la convergence de la connectivité et de la technologie. Les capteurs sont les yeux et les oreilles de l'Internet des Objets, percevant le monde physique et transformant ces perceptions en données exploitables[5].

Selon Robert Sheldon

Un capteur est un dispositif qui détecte et répond à un certain type d'entrée provenant de l'environnement physique. Il peut s'agir de lumière, de chaleur, de mouvement, d'humidité, de pression ou de tout autre phénomène environnemental. La sortie est généralement un signal qui est converti en un affichage lisible par un être humain à l'emplacement du capteur ou transmis électroniquement sur un réseau pour lecture ou traitement ultérieur[4].

Selon Mustafa Kocakulak and Ismail Butun

Dans un WSN, le nœud de capteur est l'un des principaux composants. Un nœud de capteur est un petit appareil de faible puissance. Bien qu'il dispose de ressources énergétiques limitées, les étapes de collecte et de transfert des données sont accomplies par des unités spécifiques d'un nœud de capteur[3].

Un réseau de capteurs sans fil (Wireless Sensor Network - WSN) est un ensemble interconnecté de capteurs autonomes déployés sur un territoire donné, souvent pour surveiller, collecter et transmettre des données relatives à l'environnement physique. Ces capteurs sont équipés de capacités de communication sans fil qui leur permettent de coopérer pour transmettre des informations vers des points de collecte de données ou des nœuds centraux.

Les caractéristiques principales des réseaux de capteurs sans fil incluent la capacité à fonctionner dans des environnements distribués, la faible consommation d'énergie pour prolonger la durée de vie des capteurs, et la capacité à traiter les données localement avant de les transmettre. Ces réseaux sont utilisés dans divers domaines, tels que la surveillance environnementale, la santé, les infrastructures intelligentes et d'autres applications nécessitant une collecte de données à partir de multiples points dans une zone étendue[5].

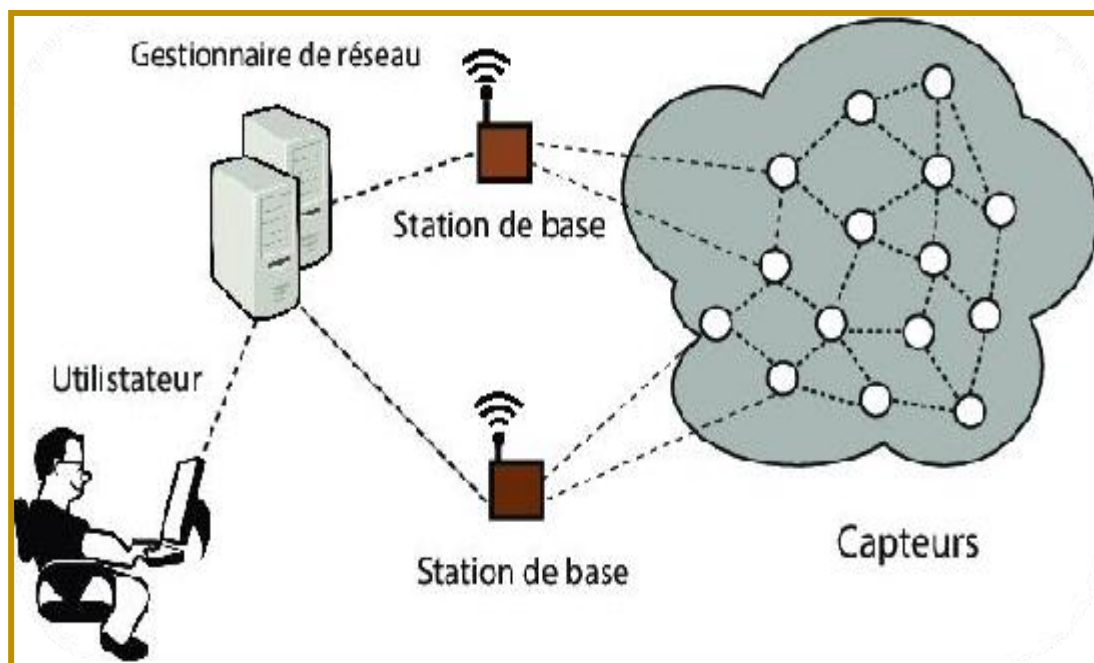


Figure 1.2 la transmission des données dans le réseau de capteurs [6]

La transmission de données est un processus par lequel les données et les requêtes de données sont routées dans le réseau de capteurs. Nous pouvons simplement dire que dans les WSN, les données environnementales sont collectées par des capteurs et ensuite, plusieurs capteurs sans fil transmettent les données en les relayant, et finalement les délivrent à la station de base [6].

1.2 Architecture de l'Internet des Objets

L'architecture de l'IoT comprend des couches interconnectées qui facilitent la communication et le traitement des données entre les objets connectés. Elle repose sur un agencement stratégique des couches de communication, de traitement et d'application, permettant une interconnexion fluide entre les dispositifs connectés et les plateformes de gestion.

1.2.1 les Couches de l'IoT

L'Internet des objets (IoT) est un réseau complexe composé de différentes couches qui interagissent pour permettre la communication et le fonctionnement des dispositifs connectés. Chaque couche remplit un rôle spécifique dans le processus global de l'IoT. Dans une architecture proposée en premier lieu, les auteurs ont proposé un modèle de structure hiérarchique : couche de perception, couche de réseau et couche d'application. Ce schéma offre une organisation stratégique pour comprendre et gérer les interactions complexes au sein des systèmes IoT, permettant ainsi une meilleure compréhension [8].

❖ La couche de perception

La couche de perception est la couche physique, qui comporte des capteurs permettant de détecter et de collecter des informations sur l'environnement. Elle détecte certains paramètres physiques ou identifie d'autres objets intelligents dans l'environnement[7].

Elle se trouve tout en bas et se présente comme étant l'organe sensoriel de l'IOT. Son but est de reconnaître les objets et de collecter des informations. Cette couche comprend les étiquettes RFID, les lecteurs de codes-barres 2D, les terminaux, les unités GPS, les caméras, les capteurs et les réseaux de capteurs. les objets IoT peuvent être divisés en groupes [8]:

- Capteurs
- Actionneurs
- Machines et dispositifs

❖ La couche réseau

La couche réseau «The network layer» est responsable de la connexion à d'autres objets intelligents, à des dispositifs réseau et à des serveurs. Ses fonctionnalités sont également utilisées pour la transmission et le traitement des données[7].

Cette couche représente le cœur de l'IOT. Elle traite et transmet les informations reçues de la couche de perception à la couche d'application. La couche réseau se compose des entités pour lesquelles le centre d'information, le centre de traitement intelligent, les systèmes de réseau Internet et le centre de gestion du réseau sont nécessaires[8].

Les communications entre les appareils et les services cloud ou les passerelles impliquent différentes technologies tell que :

- Ethernet
- Réseaux cellulaires
- LPWAN (Low-power Wide-area Network)
- WiFi

❖ La couche application

La couche application est responsable de la prestation de services spécifiques à l'application à l'utilisateur. Elle définit diverses applications dans lesquelles l'internet des objets peut être déployé, par exemple les maisons intelligentes, les villes intelligentes et la santé intelligente[7].

la couche d'application, qui est un mélange des exigences socio-commerciales de l'IOT, définissant la tâche approfondie associée au nœud. Elle est à son tour à la fusion de l'IOT et de la technologie industrielle, avec un ensemble d'exigences industrielles et de processus de système[8].

❖ La couche de traitement de données

Elle stocke et traite les données venant de la couche réseau , toutes ces taches sont généralement gérées par des plate fromes IOT [9].

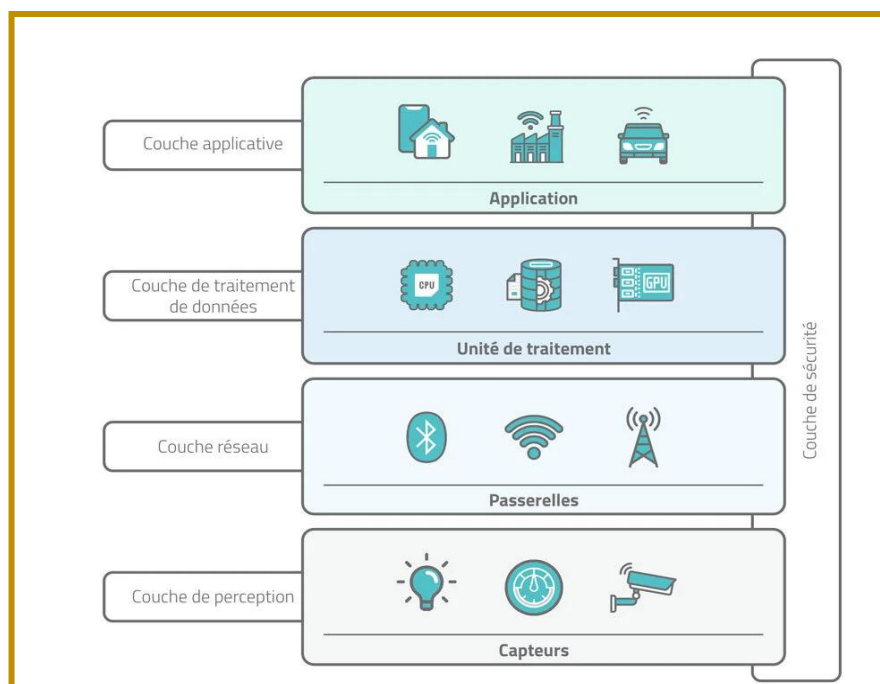


Figure 1.3 l'architecture de IoT[9]

1.2.2 les modèles de déploiement de l'IoT

Les modèles de déploiement de l'IoT, comprenant le cloud et le edge, proposent des approches centralisées et décentralisées, influençant la gestion des données et la performance des solutions IoT. chacune offrant des avantages et des défis uniques en termes de gestion des données, de latence et de scalabilité. Ces modèles façonnent la manière dont les appareils interagissent et communiquent au sein de l'écosystème de l'IoT, influençant ainsi les performances et la flexibilité des solutions IoT déployées[10][11].

❖ IoT centralisé vs IoT décentralisé

Au cours du processus de développement de la structure sociale future, la question de savoir si une structure décentralisée ou centralisée est plus appropriée pour le développement de la structure sociale future sera examinée

Au départ, le modèle des algorithmes gossip-orienté a été adopté comme moyen de propager les données dans des cadres disséminés à grande échelle. Cependant, lorsque leur force, leur efficacité et leur simplicité ont commencé à susciter une immense reconnaissance, les algorithmes gossip-orientés sont devenus de plus en plus populaires. Et avec le développement avancé de la technologie des réseaux, la transmission par réseau a pris une double direction de recherche, bien qu'entièrement variée, y compris un modèle client-serveur hautement centralisé et le cadre P2P fortement basé sur l'algorithme de gossip-

orienté . Dans l'espace réseau, les architectures décentralisées et centralisées font partie intégrante de l'infrastructure du réseau P2P[10].

L'IoT centralisé et décentralisé représentent deux approches fondamentalement différentes dans la manière dont les infrastructures IoT sont conçues et déployées. Dans un système centralisé, tous les dispositifs IoT communiquent directement avec un point central, souvent un serveur ou une passerelle, où les données sont collectées, analysées et stockées. Ce modèle offre un contrôle et une gestion centralisés, mais peut rencontrer des problèmes de latence et de dépendance à une infrastructure robuste. En revanche, dans un système décentralisé, les dispositifs IoT communiquent directement entre eux ou avec des nœuds intermédiaires, minimisant la dépendance à un point central. Cela peut améliorer la résilience du système et réduire les besoins en bande passante, mais peut être plus complexe à gérer. Le choix entre ces deux approches dépend des exigences spécifiques en termes de sécurité, de latence, de scalabilité et de ressources disponibles[10].

❖ IoT basé sur le cloud vs IoT Edge Computing

La relation entre l'informatique en nuage et l'informatique en périphérie 'edge' a une importance cruciale dans le paysage de l'Internet des objets (IoT). Ces deux paradigmes informatiques, chacun avec ses attributs uniques, contribuent de manière synergique à répondre aux exigences multiples des environnements de IoT[11].

L'informatique périphérique est au cœur de l'actualité. Elle révolutionne le traitement des données en rapprochant les capacités de calcul de la source de données, généralement au niveau ou à proximité des appareils IoT eux-mêmes. Cette proximité réduit la latence et l'utilisation de la bande passante, favorisant l'analyse et la prise de décision en temps réel. L'informatique en périphérie joue un rôle essentiel dans les scénarios où les réponses immédiates sont cruciales, permettant aux applications de fonctionner avec une vitesse et une efficacité supérieures[11].

En revanche, l'informatique en nuage fournit une infrastructure centralisée et évolutive, qui sert de base au stockage, au traitement des données et à l'analyse complexe. Le cloud agit comme un réservoir pour de grandes quantités de données générées par les appareils IoT, offrant la puissance de calcul requise pour les tâches intensives. Il facilite le stockage à long terme et la gestion des données et permet la collaboration entre divers appareils, formant ainsi un réseau cohérent dans le vaste domaine de l'IdO[11].

Donc , L'IoT basé sur le cloud centralise le traitement et le stockage des données IoT dans des serveurs distants, tandis que l'IoT Edge Computing effectue le traitement des données localement, plus près des appareils, minimisant ainsi la latence et réduisant la dépendance au réseau[11].

1.3 Les technologies de l'IoT

Les technologies de l'IoT englobent un large éventail de composants et de protocoles conçus pour permettre la connectivité et la communication entre les objets physiques et les systèmes informatiques. Ils jouent un rôle crucial dans la mise en œuvre efficace des solutions IoT, offrant des moyens robustes et flexibles pour interconnecter et gérer un large éventail d'applications et de dispositifs.

❖ Réseaux de capteurs sans fil (WSN)

Les réseaux de capteurs sans fil sont des réseaux sans fil qui se composent généralement d'un grand nombre de dispositifs distribués à distance et équipés de capteurs (instruments qui mesurent des quantités dans notre environnement) pour surveiller des phénomènes physiques ou environnementaux. Ces appareils fonctionnent de manière autonome et sont reliés logiquement par des moyens d'auto-organisation. Voici quelques défis à relever pour ce type de systèmes[12] :

- La fiabilité
- Consommation d'énergie
- Taille du nœud
- La mobilité
- Confidentialité et sécurité

❖ Radio-Frequency Identification (RFID)

La RFID est une combinaison d'une puce informatique et d'une petite antenne radio qui permet à pratiquement n'importe quel objet de s'auto-identifier. Elle a été développée à la base pour être utilisée pendant la Seconde Guerre mondiale, les Britanniques l'ayant utilisée pour identifier leurs avions[13].

La RFID est une technologie utilisée pour identifier des objets. La technologie RFID permet d'étiqueter explicitement les objets afin de faciliter leur identification à l'aide d'appareils. Les données contenues dans une étiquette RFID se composent généralement de son identification unique (ID)[14].

Un système RFID standard se compose de quatre éléments principaux :

- **RFID Tags «Étiquettes RFID»**

Étiquettes RFID - Appliquées directement sur les objets. Chaque étiquette RFID contient une toute petite puce d'une capacité d'au moins 96 bits, qui est programmée électroniquement avec des informations uniques[13][14].

- **Antenne**

également appelée capteur, interrogateur ou lecteur. Un conduit entre les étiquettes RFID et le coupleur. Les antennes RFID connectées au lecteur émettent de l'énergie et des données depuis et vers les étiquettes RFIS. et vers les étiquettes RFIS[13].

- **Reader/ Coupler**

il assure la liaison entre les étiquettes RFID et le serveur/ordinateur. Le coupleur peut envoyer des informations dans deux directions : Il peut lire les informations d'une étiquette et les envoyer au serveur ou au PC (mode lecture)[13].

- **Serveur/PC**

la liaison entre le coupleur et le système d'automatisation de la bibliothèque. Le PC est le cœur d'un système RFID complet. Il est la passerelle de communication entre les différents composants[13].

❖ **Wi-fi**

La technologie Wi-Fi est apparue à la fin du dernier siècle et s'est développée pendant plus de dix ans. Elle a été utilisée pour la première fois pour le positionnement en intérieur par Bahl en 2000. Avec la popularisation des appareils mobiles équipés de Wi-Fi, sa technologie de localisation s'étend progressivement de l'intérieur à l'extérieur. Le Wi-Fi offre une connexion sans fil à Internet et aux réseaux locaux (LAN). De très nombreux appareils disponibles à ce jour sur le marché font appel à la technologie Wi-Fi : smartphones, consoles de jeux vidéo, PC...

En fonction de sa vitesse et du temps de transmission, la technologie Wi-Fi peut être divisée en IEEE 802.11b, IEEE 802.11a, IEEE 802.11g et IEEE 802.11n[17].

❖ **Bluetooth**

Le standard Bluetooth pour la couche physique a été créé par Ericsson en 1994 et visait à remplacer le câble de données RS-232. Il est essentiellement utilisé dans les WPAN et les réseaux de zone corporelle (BAN) qui sont des réseaux de communication à courte distance, nécessitant une faible consommation d'énergie et un faible coût[18].

Bluetooth fonctionne soit à un débit de base "Basic Rate" (BR), soit à une faible énergie "Low Energy" (LE), mais un système peut passer de l'un à l'autre pour plus de robustesse. Le débit de base dispose de l'option Enhanced Data Rate (EDR) ainsi que de nombreuses autres options qui permettent des taux de transfert de données plus élevés ainsi qu'une plus grande complexité, mais à un coût plus élevé[19].

❖ **Bluetooth Low Energy (BLE)**

Le Bluetooth Low Energy (BLE) a été initialement nommé Wibree par Nokia en 2006, mais a été fusionné et renommé sous la norme Bluetooth version 4.0 en 2010. [18]En comparaison avec le Bluetooth classique, le BLE a une portée de transmission similaire (environ 50 mètres), un taux de transfert de données plus lent (environ 200 kbit/s), mais il offre une consommation d'énergie réduite et un temps d'installation beaucoup plus rapide (temps nécessaire à la découverte d'un

appareil Bluetooth et à la connexion). Grâce à ces caractéristiques, le BLE est devenu une alternative à la norme NFC[18] [19].

❖ **Middleware**

le middleware ou intergiciel est considéré comme une technologie qui facilite le développement d'applications distribuées. En ce sens, le middleware a évolué, passant de la dissimulation des détails du réseau aux applications, à des systèmes plus sophistiqués permettant de répondre à de nombreuses exigences importantes en matière de distribution, d'hétérogénéité, de mobilité, d'interopérabilité et de gestion des données[20].

L'intergiciel est une couche de logiciel située au-dessus du système d'exploitation, mais en dessous du programme d'application, qui fournit une abstraction de programmation commune à travers un système distribué[20].

1.4 Applications et domaines d'utilisation de IOT

Les applications et domaines d'utilisation de l'IoT sont divers et touchent de nombreux secteurs de la vie quotidienne et de l'industrie, de la santé à l'agriculture, en passant par l'industrie et la logistique. Il permet la création de systèmes intelligents capables de surveiller, de contrôler et d'optimiser divers processus et environnements. Grâce à la connectivité des objets, l'IoT facilite la collecte et l'analyse de données en temps réel, ouvrant la voie à des innovations majeures dans la manière dont nous interagissons avec notre environnement et gérons nos activités quotidiennes[7][22].

❖ **La santé «Internet of Healthcare Things (IoHT)»**

Dans le secteur des santé, les avantages d'un monde connecté, surveillé en permanence, automatisé et doté d'un système d'apprentissage automatique sont évidents et considérables.

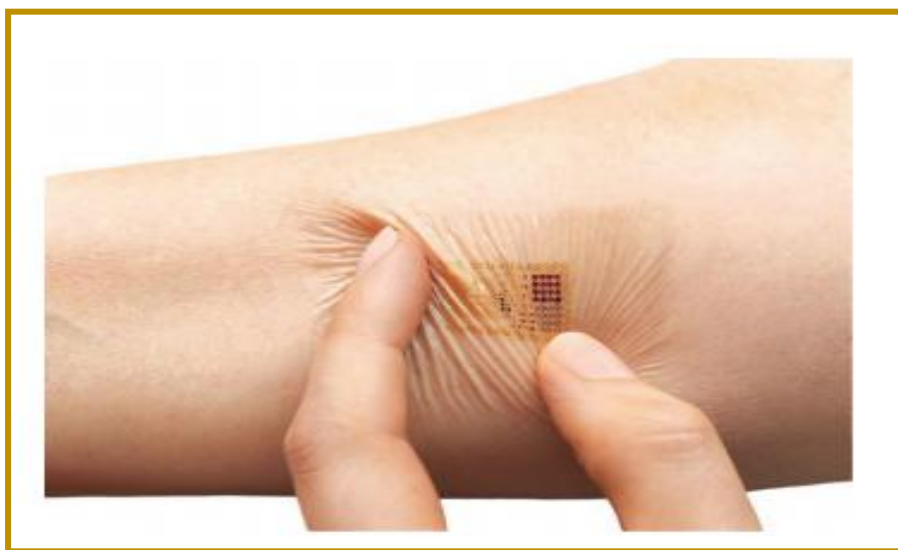


Figure 1.4 Patches de peau incorporés[7]

Nous pourrions voir des objets portables qui appellent une ambulance si les signes vitaux d'un patient chutent, des renouvellements d'ordonnance automatisés pour minimiser l'inobservation des médicaments, et une chaîne d'approvisionnement sans friction, peu coûteuse et sans erreur du vendeur au patient, même une chambre d'hôpital qui s'adapte à l'évolution de l'état d'un patient[21].

L'internet des objets peut être très utile pour les applications de la santé. Il est possible d'utiliser des capteurs capables de mesurer et de surveiller divers paramètres médicaux dans le corps humain. Ces applications peuvent viser à surveiller la santé d'un patient lorsqu'il n'est pas à l'hôpital ou lorsqu'il est seul. Elles peuvent ensuite fournir un retour d'information en temps réel au médecin, aux proches ou au patient[7] , Dans ce travail, nous avons choisi ce domaine.

❖ Domotique et habitat intelligent

La technologie de la maison intelligente, également appelée domotique, du mot latin domus, qui signifie maison, Une maison intelligente est une résidence qui utilise des appareils connectés à Internet pour permettre la surveillance et la gestion à distance des appareils et des systèmes, tels que l'éclairage et le système de chauffage.[22].

Il assure aux propriétaires la sécurité, le confort, la commodité et l'efficacité énergétique en leur permettant de contrôler des appareils intelligents, souvent à l'aide d'une application pour la maison intelligente sur leur smartphone ou un autre appareil en réseau[22].

❖ Villes intelligentes

Les villes intelligentes utilisent des dispositifs IOT tels que des capteurs, des éclairages et des compteurs connectés pour collecter et analyser des données. Les villes utilisent ensuite ces données pour améliorer les infrastructures, les équipements et les services publics, et bien plus encore.

Les dispositifs urbains intelligents facilitent les tâches quotidiennes et les rendent plus efficaces, tout en réduisant les problèmes liés à la sécurité publique, à la circulation et à l'environnement[23][24]. , Voici quelques technologies de ville intelligente parmi les plus populaires :

• Compteurs d'électricité intelligents

Ces dispositifs se placent dans les bâtiments et se connectent à un réseau énergétique intelligent, ce qui permet aux entreprises de services publics de gérer plus efficacement les flux d'énergie[23][24].

• Les réseaux intelligents «Smart grids»

Les réseaux intelligents, qui contribuent grandement à la conservation des ressources, constituent sans doute la meilleure application de l'architecture et de l'infrastructure intelligentes. Amsterdam, par exemple, a expérimenté l'offre d'unités de stockage d'énergie et de panneaux solaires pour les ménages connectés au réseau intelligent de la ville[23].

• Moniteurs intelligents de la qualité de l'air

Des poussières, des saletés, des produits chimiques de nettoyage flottent en permanence dans l'air d'un immeuble de bureaux ou d'une maison. Les contrôleurs intelligents de la qualité de l'air peuvent détecter ces particules et informer les utilisateurs de la présence de polluants[24].

❖ Agriculture intelligente

La combinaison des concepts de smart farming et de big data ainsi que IOT permet aux exploitations agricoles d'utiliser cette innovation numérique pour améliorer leur productivité. L'analyse prédictive des données permet d'anticiper le rendement d'une année et de se positionner en fonction du volume qui sera disponible au moment de la récolte. Cette transformation numérique est un nouvel acquis pour la réussite d'une exploitation agricole, d'autant bien nécessaire que l'agriculture devra répondre à l'alimentation d'une population mondiale qui atteindra 8,5 milliards d'individus en 2030[25].

L'écosystème IoT dans les smart farms se compose de nombreux appareils et logiciels qui travaillent ensemble pour capturer le signal et le transmettre pour traitement[26].

D'une manière générale, dans les articles publiés, les domaines suivants se sont révélés être les domaines communs dans lesquels des solutions IOT sont mises en œuvre[26] :

- Surveillance des plantes
- Surveillance des sols
- Gestion de l'irrigation
- Contrôle des maladies
- Gestion des engrais et des pesticides



Figure 1.5 L'Internet des Objets pour une agriculture plus intelligente[27]

❖ La surveillance de l'habitat écologique

Les algorithmes d'apprentissage automatique qui surveillent la population de diverses espèces, les caméras intelligentes qui peuvent détecter les braconniers dans la brousse, les animaux marqués par des capteurs qui révèlent les détails de leur histoire, et les smartphones qui peuvent écouter les tronçonneuses dans la forêt, ne sont que quelques exemples des avantages à tirer de la mise en œuvre de systèmes de surveillance bienveillants dans l'ensemble du monde naturel[28].

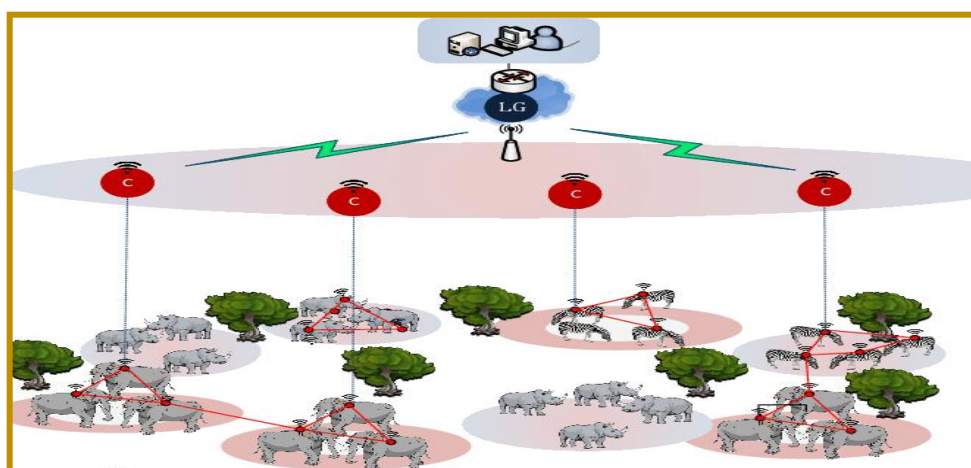


Figure 1.6 la surveillance des animaux dans l'IOT[29]

En juin 2022, plus de 3 000 entreprises ont pris des mesures climatiques fondées sur la science et près de 1 500 ont approuvé des objectifs fondés sur la science, sans compter les directives déjà mises en œuvre par les gouvernements[28].

1.5 Problèmes et défis liés à l'IoT

Les problèmes et défis liés à l'IoT concernent la sécurité des données, la gestion des dispositifs connectés, l'interopérabilité des systèmes et la protection de la vie privée. Ces enjeux nécessitent une attention particulière pour garantir le bon fonctionnement, la fiabilité et la confidentialité des infrastructures IoT dans un monde de plus en plus interconnecté[18].

❖ Sécurité

La force d'attraction de l'IOT vient du fait qu'un grand nombre de dispositifs IOT sont intégrés dans le monde réel et communiquent en permanence des informations sur ce monde. Malheureusement, cette omniprésence pose également de problèmes sérieux en matière de sécurité et de protection de la vie privée, qui doivent être résolus pour que l'IOT soit largement accepté par le public.[18]

les appareils IOT passent la plupart du temps sans surveillance et peuvent donc être facilement attaqués physiquement. la communication sans fil entre ces objets et ceux qui les relient à l'internet est vulnérable aux écoutes abusives. Les

mécanismes de sécurité complexes et exigeants en termes de ressources ne peuvent pas être mis en œuvre sur des dispositifs IOT à ressources limitées (par exemple, des étiquettes RFID passives ou des nœuds de capteurs de faible puissance).

des informations sur l'environnement sont collectées de manière autonome et constante par des dispositifs IOT sans que l'homme en soit conscient (par exemple, des applications domestiques intelligentes enregistrant les habitudes de vie des habitants).

Enfin, la manière dont la quantité extrêmement massive de données hétérogènes générées par l'IOT est exploitée, c'est-à-dire qui a le droit d'accéder à quel type de données et à quel moment, reste incertaine. Des exemples de problèmes sont le remplacement d'appareils IoT par des appareils nuisibles (en raison de l'absence de surveillance des appareils), les attaques de l'homme du milieu (en raison de la communication sans fil) et l'utilisation abusive de données sensibles[18].

❖ Scalability (extensibilité)

La technologie IOT est d'une ampleur sans précédent, tant en ce qui concerne Le nombre d'appareils IOT connectés (qui devrait atteindre plusieurs milliards) que la zone géographique qu'elle couvre (qui devrait être la terre entière). L'évolutivité est donc d'une importance capitale lors de la création d'applications basées sur l'IOT. Les entreprises de l'IOT ont souvent des centaines ou des milliers d'appareils sur le terrain. Les plus grands fabricants d'appareils IoT ont des millions d'appareils déployés dans le monde entier. Au fur et à mesure que les entreprises se développent, elles assemblent souvent leur pile IoT au coup par coup, en adoptant différentes solutions de connectivité pour les déploiements dans de nouvelles régions. Chacune de ces solutions s'accompagne de plateformes de gestion, de systèmes de support et de technologies de base différents. Et supposons que vous deviez modifier fondamentalement le produit pour prendre en charge une nouvelle solution de connectivité. Dans ce cas, il est nécessaire de disposer de plusieurs UGS pour un seul produit. Plus l'échelle de vos opérations est grande, plus la gestion des appareils et la logistique deviennent lourdes[18] [30].

❖ Interopérabilité

L'un des aspects incroyables de l'IOT est la possibilité apparemment infinie de configurer la pile technologique pour l'adapter à des conditions uniques. Mais cela crée aussi un défi : tous les appareils et solutions IoT ne sont pas compatibles entre eux ou avec les applications de gestion de l'entreprise. L'ajout de nouveaux matériels et logiciels peut exiger une réaction en chaîne de changements pour conserver les fonctionnalités dont tout utilisateur a besoin tout en adaptant la nouvelle technologie.

L'interopérabilité pose un autre problème aux fabricants de solutions IOT.

Certaines des technologies sur lesquelles repose la solution IoT peuvent être des logiciels open source. Ce n'est pas un problème en lui-même, mais si cette technologie open source ne dispose pas d'un mécanisme de régulation pour créer une norme universelle claire, il se peut que différentes entreprises et/ou différents pays utilisent des variantes différentes de la technologie open source. Il est alors difficile d'ajouter la technologie d'un autre fournisseur ou de déployer votre solution IoT dans un nouveau pays. Ce n'est certainement pas un problème pour toutes les applications IOT, mais certains secteurs doivent accélérer l'adoption de normes universelles pour améliorer l'interopérabilité[30].

❖ **durée de vie limitée de la batterie**

La vision de l'IOT prédit un futur dans lequel les personnes seront entourées d'environnements intelligents qui les aideront en permanence et de manière discrète dans tous les aspects de leur vie. Par exemple, dans les applications de santé, les capteurs portés sur le corps doivent être aussi petits que possible afin de ne pas gêner les activités quotidiennes des patients[18].

La plupart des appareils IOT sont équipés de petites batteries. Cela s'explique principalement par le fait que les appareils sont souvent incroyablement petits et que les nouvelles générations de technologies IoT tendent vers des appareils et des composants plus petits et plus efficaces. Des batteries plus grandes peuvent restreindre les cas d'utilisation d'un appareil ou limiter l'endroit et la manière dont l'appareil peut être installé[30].

1.6 Le futures de l'IoT

L'avenir de l'IoT est prometteur, avec des avancées telles que l'intelligence artificielle, le edge computing et la 5G/6G qui promettent de révolutionner davantage la connectivité et les capacités des appareils IoT. Ces progrès ouvrent la voie à des applications plus sophistiquées et à des systèmes autonomes qui transformeront les secteurs de la santé, de l'industrie, de la ville intelligente et de bien d'autres domaines. La collaboration entre les secteurs de la technologie et de l'industrie devrait façonner un avenir où l'IoT devient encore plus intégré dans notre vie quotidienne, facilitant la prise de décision, l'efficacité opérationnelle et la qualité de vie[31].

❖ **L'IOT renforcé par l'IA (AIOT) et la convergence**

Les appareils connectés à l'IOT sont dits "intelligents", mais en général, il s'agit d'appareils "connectés". Cependant, la technologie de l'IOT converge de plus en plus avec des systèmes et des appareils capables de prendre des décisions et de répondre à des questions à l'aide de l'IA et de l'apprentissage automatique. Tout comme pour les personnes, le fait d'avoir des milliers d'appareils intelligents tous connectés et tentant d'effectuer leurs tâches les uns à côté des autres est susceptible de conduire à des disputes. Le développement des protocoles

permettant aux appareils intelligents de se comporter de manière harmonieuse (et de partager des données en toute sécurité) sera une priorité pour l'industrie en 2024[31].



Figure 1.7 L'AIoT : L'avenir de la convergence de l'Intelligence Artificielle et de l'Internet des Objets[32]

❖ Le Edge Computing à la rencontre de l'IA et de la 5G

L'informatique en périphérie désigne les dispositifs qui analysent les données à proximité de la source où elles sont capturées, au lieu de les envoyer à un serveur centralisé, tel qu'un service en nuage, pour y être stockées et analysées. Les volumes de données augmentant, il est nécessaire d'extraire des informations le plus rapidement possible afin de pouvoir agir plus vite et de réduire le coût de transmission des données brutes bruyantes vers le nuage.

Les véhicules autonomes sont un excellent exemple de dispositifs Edge, car ils ont besoin d'interpréter les données des caméras pour repérer les dangers sur la route sans avoir à les envoyer au cloud et à attendre qu'on leur renvoie des informations. En 2024, le déploiement en cours des réseaux 5G rendra l'Edge computing viable pour de nombreuses nouvelles applications, tandis que l'intégration de l'IA rendra les dispositifs de périphérie plus intelligents et plus autonomes. Cela devrait conduire à un accroissement de l'adoption et à de nouveaux cas d'utilisation innovants[31].

1.7 La conclusion

Au cours de ce chapitre, nous avons exploré les bases de l'Internet des Objets (IoT), notamment son architecture et ses modèles de déploiement, , plongeant dans sa complexité à travers ses technologies clés, ses applications , En scrutant ses défis nous avons mis en lumière les enjeux cruciaux de sécurité, de scalabilité et de contraintes matérielles. Le chapitre suivant se focalisera sur la sécurité dans IOT.

Chapitre 2

La sécurité dans «IoT»

Au cœur de la révolution technologique actuelle se trouve l'Internet des Objets (IoT), une toile d'appareils interconnectés qui promet de transformer radicalement notre manière de vivre et de travailler. Cependant, cette interconnexion généralisée soulève des questions cruciales de sécurité, menaçant la confidentialité des données et la fiabilité des systèmes.

Dans ce chapitre, nous plongerons dans l'univers complexe de la sécurité de l'IoT, explorant les Exigence, les menaces et les différentes approches qui façonnent l'avenir de cette technologie novatrice.

2.1 Définition

La sécurité informatique est un concept multifacette qui peut être défini de différentes manières selon le contexte et les préoccupations spécifiques. Parmi les diverses perspectives des chercheurs, on peut mentionner quelques-unes :

Selon Raphael Yende

La sécurité informatique cherche à minimiser la vulnérabilité d'un système contre les menaces et les intrusions numériques. Elle vise à garantir que toutes les ressources d'un système informatique ne sont utilisées qu'aux fins prévues et par des utilisateurs autorisés[33].

Selon G. Florin, S. Natkin

La sécurité informatique représente au sens large l'ensemble des méthodes et des outils utilisés pour réduire la vulnérabilité d'un système. Elle consiste notamment à assurer la protection des informations et des ressources confidentielles face à toutes formes d'attaques[34].

Selon Solange Ghernaoui

La notion de sécurité informatique correspond aux caractéristiques d'un système informatique, définies en matière de disponibilité, d'intégrité et de confidentialité. Ces critères fondamentaux sont atteints par la mise en œuvre de fonctions et de services de sécurité, tels que le contrôle d'accès et la détection d'intrusions[35].

2.2 Dimensions de sécurité informatique

La sécurité de l'information a souvent été abordée comme un concept "unidimensionnel" basé sur la "technologie". Selon ce concept, la sécurité de l'information est souvent définie comme "la préservation de la confidentialité, de l'intégrité et de la disponibilité" de l'information. C'est ce que l'on appelle souvent le "principe CIA"[36].

Puis, la communauté de la sécurité de l'information a étendu cette approche technologique basée sur trois composantes à la quatrième " l'authentification ". Ensuite, de l'approche unidimensionnelle "Uni-Dimensional Approach" à l'approche bidimensionnelle "Dual Dimensional Approach" , L'approche à deux dimensions étend donc son champ d'application vers la protection de l'information et du propriétaire de l'information.

de l'approche bidimensionnelle à la troisième dimension "The Third Dimension" , puis à la dimension plus une "The Plus One Dimension" , mais l'objectif est toujours le même : assurer la sécurité des personnes et des systèmes informatique.[36] les exigences fondamentales de la sécurité informatique sont les suivantes :

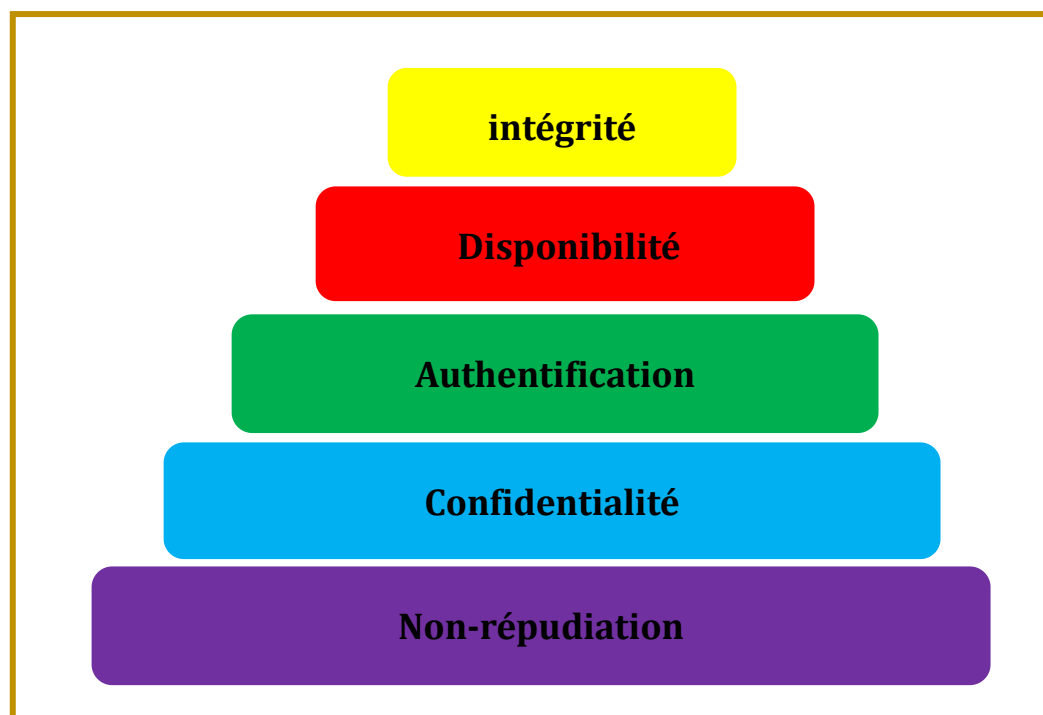


Figure 2.1 Dimensions de sécurité informatique

❖ **intégrité**

L'intégrité est le fait de garantir l'exactitude et la fiabilité des données et de nous assurer que les informations diffusées correspondent bien à ce qui est supposé être et ne sont pas modifiées au cours de la transmission. [33]

❖ **Disponibilité**

la Disponibilité cette notion signifie une bonne performance du système, et la possibilité de consulter les services et les ressources à n'importe quel moment. Pour une ressource donnée, la disponibilité correspond au taux de fonctionnement du service fourni par cette ressource. Les charges de travail

possibles pendant le temps de disponibilité d'un service sont le facteur déterminant de la capacité à utiliser une ressource[34][35].

❖ **Authentification**

L'authentification permet de garantir la validité des identités revendiquées par les entités participant à la communication (par exemple, une personne, un dispositif, un service ou une application) et de s'assurer qu'une entité ne tente pas de se faire passer pour une autre ou de rejouer sans autorisation une communication passée. Par conséquent, l'entité devra prouver son identité, généralement par des informations uniques dont elle est censée être la seule détentrice, telles qu'un mot de passe ou une empreinte biométrique[35].

❖ **Confidentialité**

La confidentialité elle permet de faire en sorte que l'information soit incompréhensibles pour d'autres personnes que celles qui sont concernées , Cette notion vise à protéger les informations contre toute manipulation ou divulgation non autorisée. pour assurer la confidentialité des données et garantir que seules les personnes autorisées ont accès aux données soit de restreindre et de contrôler l'accès ou de crypter ces données [35].

❖ **Non-répudiation**

La non-répudiation garantit qu'une transaction ne pourra pas être niée. Elle permet également d'empêcher une personne ou une entité de nier avoir effectué une action liée à des informations particulières et de fournir des preuves de différentes actions sur le réseau[33].

2.3 Les attaques à différents couches

Les attaques à différentes couches sont une réalité omniprésente dans le paysage de la sécurité informatique, chaque couche offrant son propre ensemble de vulnérabilités et de défis uniques. Des attaques ciblées peuvent se produire à différentes strates.

2.3.1 les attaques au niveau de la couche physique

❖ **Attaque par brouillage «Jamming Attack»**

Les attaquants émettent des signaux très puissants pour perturber ou bloquer les communications sans fil, L'attaque peut être lancée à la fois de l'extérieur et de l'intérieur . L'attaquant utilise un émetteur de grande puissance pour perturber les communications sans fil légitimes.ce qui empêche les appareils légitimes de communiquer entre eux. et Il empêche la source de transmettre les paquets ou refuse la transmission de paquets légitimes[37].

❖ **Consommation d'énergie «Energy Drain»**

Un attaquant générer de grandes quantités de trafic dans le réseau. Ces faux

messages provoquent de fausses alarmes qui gaspillent les efforts de réponse et épuisent la quantité limitée d'énergie d'un réseau alimenté par batterie[38].

❖ **Dommages physiques**

Par exemple dans Le réseau de capteurs sans fil fonctionne dans des environnements éloignés et peu sensibles. Les nœuds distribués et non surveillés dans la nature du WSN les rendent vulnérables aux attaques physiques. Les nœuds sont détruits éternellement dans l'environnement physique, il y a donc une perte permanente des nœuds [37].

❖ **Interception des signaux**

Les attaquants peuvent intercepter les signaux transmis par les réseaux sans fil pour écouter des données sensibles ou injecter des données malveillantes[39].

❖ **Vol de dispositifs IoT**

Les dispositifs IoT physiques peuvent être volés, ce qui compromet leur sécurité et peut permettre aux attaquants d'accéder aux données sensibles ou de perturber les opérations du système[39].

❖ **Attaques par interférence électromagnétique**

Les attaquants peuvent utiliser des signaux électromagnétiques pour interférer avec les communications sans fil, perturbant ainsi le fonctionnement normal du réseau ou injectant des données malveillantes[39].

❖ **Attaque par altération «Tampering Attack»**

L'intrus modifie les dispositifs IoT tel que les nœuds de capteur ou détériore leurs services et prend le contrôle total du nœud capturé. Les dispositifs physiques sont endommagés lors de cette attaque, de sorte que les ressources sont insuffisantes[37].

❖ **Attaque de privation de sommeil «Sleep Deprivation Attack»**

Cette attaque vise à épuiser rapidement la batterie des appareils IoT en les forçant à rester actifs en permanence, ce qui peut entraîner une surconsommation d'énergie et une dégradation rapide des performances. Elle exploite ainsi une vulnérabilité au niveau de l'alimentation des dispositifs physiques, perturbant leur fonctionnement normal et compromettant leur disponibilité et leur intégrité[39].

2.3.2 les attaques au niveau de la couche réseau

❖ **Attaques par déni de service (DoS)**

Les attaques DoS sont des attaques par lesquelles les attaquants réduisent les services du réseau en fournissant un nœud malveillant pour les détourner. La menace principale consiste à s'attaquer à la disponibilité des ressources et des services nécessaires à la transmission des données. Les attaquants détruisent ou détournent la configuration de l'infrastructure du réseau de capteurs. L'attaque DoS peut se produire dans n'importe quelle couche du modèle OSI du WSN en

affectant les protocoles du moyen de transmission, en consommant les ressources, en détruisant les composants physiques[37].

❖ **Attaque par capture de nœud**

L'attaque par capture de nœud est un problème majeur dans les WSN. L'intrus effectue diverses opérations et compromet l'ensemble du réseau. L'attaque par capture de nœud supprime certains nœuds de capteurs et les redéploie pour effectuer de multiples attaques. Un nœud malveillant redéployé est utilisé pour modifier les informations dans le canal de communication du WSN[37].

❖ **Attaques par rejeu**

Dans le WSN, l'attaquant reproduit le nœud malveillant à plusieurs reprises pour consommer de l'énergie et dominer les canaux de communication. Dans cette attaque, la topologie du réseau change constamment en raison de la mobilité des nœuds de capteurs. Le moyen efficace de surmonter cette attaque est de dépenser des tokens de session et d'inclure des timestamps dans les messages[37].

❖ **L'attaque Hello Flood**

L'attaquant tente généralement de puiser l'énergie d'un nœud ou d'épuiser ses ressources. Un attaquant doté d'une grande puissance de transmission pourrait diffuser des paquets "HELLO" (utilisés dans de nombreux protocoles de découverte de nœuds) pour convaincre chaque nœud du réseau que l'adversaire se trouve à portée de communication d'un saut, ce qui amènerait un grand nombre de nœuds à gaspiller de l'énergie en envoyant des paquets à ce voisin imaginaire et donc à s'éteindre[38].

❖ **L'attaque de détournement (Misdirection Attack)**

L'attaquant redirige le paquet depuis les nœuds enfants vers d'autres nœuds distants, mais pas nécessairement vers le nœud parent légitime. L'objectif principal de l'intrus est de détourner les messages entrants afin d'augmenter le temps de latence, ce qui empêche quelques paquets d'atteindre la station de base[38].

❖ **Une attaque par inondation (Flooding Attack)**

Un attaquant peut répéter de nouvelles demandes de connexion jusqu'à ce que les ressources requises par chaque connexion soient épuisées ou qu'une certaine capacité maximale soit atteinte. Il en résulte de graves contraintes en termes de ressources pour les nœuds légitimes[38].

❖ **L'attaque par collision**

Dans une attaque par collision, un nœud attaquant ne respecte pas le protocole de contrôle d'accès au support et produit des collisions avec les transmissions des nœuds voisins en envoyant un court paquet bruyant. paquet court et bruyant. Les paquets entrent en collision lorsque deux nœuds tentent d'émettre simultanément sur la même fréquence, ce qui entraîne une altération des paquets. Cette attaque peut perturber considérablement le fonctionnement du

réseau[38].

❖ **L'attaque du trou noir (Black Hole Attack)**

Une attaque par trou noir consiste essentiellement à modifier le routage du réseau dans le but d'attirer tous les paquets vers la destination du nœud attaqué et de les rejeter ou de les abandonner silencieusement[38].

❖ **L'attaque Homing (ou Homing attack)**

l'attaquant analyse le trafic du réseau pour déduire l'emplacement géographique des nœuds critiques, tels que les chefs de grappe ou les voisins de la station de base. Il peut ensuite désactiver physiquement ces nœuds. Cela conduit à un autre type d'attaque par trou noir[38].

❖ **Une attaque de spoofing**

Cette attaque consiste à cibler les informations de routage pendant qu'elles sont échangées : créer des boucles de routage, attirer ou repousser le trafic réseau à partir de nœuds sélectionnés, étendre et raccourcir les routes sources, générer de faux messages d'erreur, partitionner le réseau, etc[38].

❖ **Attaque de Sybille**

Cette attaque consiste à modifier le routage du réseau pour attirer le trafic des nœuds attaquants, dans le but d'isoler ces nœuds. Lorsque ces nœuds ne peuvent plus communiquer, l'attaquant envoie un faux trafic supplantant les nœuds[38].

2.3.3 les attaques au niveau de la couche application

❖ **Attaque de phishing**

Le "phishing" désigne une tentative de vol d'informations sensibles, généralement sous la forme de noms d'utilisateur, de mots de passe, de numéros de carte de crédit, d'informations bancaires ou d'autres données importantes, dans le but d'utiliser ou de vendre les informations volées. En se faisant passer pour une source fiable et en présentant une demande alléchante, un pirate attire la victime afin de la piéger, un peu comme un pêcheur utilise un appât pour attraper un poisson[40].

❖ **Cross-site scripting (XSS)**

Le cross-site scripting (XSS) est un exploit par lequel l'attaquant insère un code sur un site web légitime qui sera exécuté lorsque la victime charge le site web. Ce code malveillant peut être inséré de différentes manières. Le plus souvent, il est ajouté à la fin d'une adresse URL ou placé directement sur une page qui affiche un contenu généré par l'utilisateur. En termes plus techniques, le cross-site scripting est une attaque par injection de code côté client[40].

❖ **Cheval de Troie**

Il s'agit de logiciels malveillants dissimulés dans d'autres logiciels utiles afin de pousser l'utilisateur à les installer. Les copies pirates de logiciels populaires sont souvent infectées par des chevaux de Troie[40].

❖ **Ransomware**

Ce programme peut crypter des fichiers ou même un système d'exploitation

entier sur un ordinateur ou un réseau et les maintenir cryptés jusqu'à ce qu'une rançon soit versée à l'attaquant. L'émergence du bitcoin et d'autres crypto-monnaies a entraîné une augmentation de la popularité des attaques par ransomware, car les attaquants peuvent accepter de l'argent de manière anonyme et minimiser le risque de se faire attraper[40].

❖ Les virus

Un virus est un programme malveillant qui peut être intégré dans un système d'exploitation ou un logiciel ; la victime doit exécuter le système d'exploitation ou ouvrir le fichier infecté pour être affectée[40].

❖ Injection de code SQL

L'injection SQL est une technique d'injection de code utilisée pour modifier ou récupérer des données dans des bases de données SQL. En insérant des instructions SQL spécialisées dans un champ d'entrée, un attaquant est en mesure d'exécuter des commandes qui permettent de récupérer des données dans la base de données, de détruire des données sensibles ou d'effectuer d'autres manipulations[40].

❖ Attaque par inondation de HTTP

Une attaque par inondation HTTP est un type d'attaque volumétrique par déni de service distribué (DDoS) conçue pour submerger un serveur ciblé de requêtes HTTP. Une fois que la cible a été saturée de requêtes et qu'elle est incapable de répondre au trafic normal, le déni de service se produit pour les requêtes supplémentaires provenant d'utilisateurs réels[40].

❖ Attaques par ingénierie sociale

D'une manière générale, l'ingénierie sociale consiste à manipuler les gens pour qu'ils donnent des informations sensibles. Par exemple, un pirate envoie à une victime un courriel qui semble provenir d'une personne figurant dans la liste de contacts de la victime. Ce courriel peut contenir un lien suspect qui exécutera une attaque malveillante de type cross-site scripting ou dirigera la victime vers un site malveillant[40].

❖ Slowloris

Slowloris est une attaque par déni de service qui permet à un attaquant de submerger un serveur ciblé par l'ouverture et le maintien de nombreuses connexions HTTP simultanées entre l'attaquant et la cible[40].

2.3.4 les attaques au niveau de la couche de traitement de données

❖ ARP spoofing

L'usurpation d'adresse ARP, également connue sous le nom de "ARP poisoning", est une attaque de type homme du milieu (MitM) qui permet aux attaquants d'intercepter les communications entre les appareils du réseau. Quand un client ou un switch reçoit un message ARP, il met à jour sa table ARP avec la nouvelle liaison physique-logique. La prochaine fois qu'il a du trafic à envoyer, il l'envoie sur la base de la nouvelle adresse physique figurant dans sa table. Un adversaire

peut tirer pleinement parti de cette situation en diffusant un message ARP pour n'importe quelle adresse IP de son voisin avec sa propre adresse MAC physique. Tous les voisins de l'environnement commuté commenceront à acheminer le trafic vers l'adversaire au lieu du destinataire prévu. Par conséquent, l'adversaire réussit une attaque de type "man-in-the-middle" [41].

❖ **Attaques VLAN**

un attaquant génère du trafic avec un ID VLAN d'un système terminal qu'il ne peut pas atteindre normalement et envoie le trafic. Par ailleurs, l'attaquant peut essayer d'imiter un switch afin de négocier un trunking et d'envoyer et de recevoir du trafic entre les VLAN[41].

❖ **Attaques par faux point d'accès «Fake access point attacks»**

Les attaques par faux AP sont fréquemment utilisées pour accéder aux données des utilisateurs. Dans ce type d'attaque, l'attaquant émet une diffusion similaire au SSID dans l'environnement et permet à l'utilisateur de se connecter à ce SSID[41].

❖ **Attaque par désauthentification**

Les attaques par désauthentification sont un type d'attaques par déni de service qui déconnectent les appareils d'un réseau. L'objectif est de capturer les handshakes de reconnexion ou de diminuer la qualité de service du réseau. Ces attaques utilisent des trames de désauthentification pour s'exécuter[41].

2.4 Mécanismes de sécurité pour l'IoT

Les mécanismes de sécurité pour l'IdO désignent les techniques et les protocoles mis en œuvre pour protéger les appareils, les réseaux et les données de l'IdO contre les cybermenaces. Ces mécanismes comprennent la cryptographie, l'authentification, le contrôle d'accès et la détection des intrusions, entre autres, afin de garantir l'intégrité, la confidentialité et la disponibilité des systèmes de l'IdO. Comme l'IdO étend sa portée à divers domaines, il devient indispensable de mettre en place des mesures de sécurité solides pour atténuer les risques et protéger les informations sensibles contre les accès ou manipulations non autorisés.

❖ **La cryptographie**

Le mot « cryptographie » est dérivé de « kryptos » qui signifie « caché » ou « secret » en grec ancien et de « graphein » qui signifie « écrire ». C'est l'étude qui traite la transmission confidentielle de données par le biais de méthode de chiffrement , La cryptographie est la science qui utilise les mathématiques pour crypter et décrypter les données. La cryptographie permet de stocker des informations sensibles ou de les transmettre sur des réseaux non sécurisés (comme l'internet) de manière que personne ne puisse les lire, à l'exception du destinataire prévu[45].

Il y a essentiellement deux types de cryptographie:

• Chiffrement symétrique

Dans le cryptage à clé symétrique, tout utilisateur du système de cryptage dispose d'une copie de la clé secrète unique, cette clé secrète est utilisée pour le chiffrement et le déchiffrement, elle est plus rapide que le cryptage asymétrique, dans le cryptage symétrique, l'expéditeur partage la même clé secrète avec le destinataire pour l'utiliser dans le processus de déchiffrement. Comme la clé secrète est partagée entre l'expéditeur et le destinataire, il devient risqué de l'utiliser. Dans le cas du chiffrement par clé symétrique, il est recommandé d'utiliser une longueur de clé de 128 bits afin d'éviter ou de rendre plus difficile toute tentative de piratage. Les algorithmes de cryptage les plus courants sont AES, RC4, DES, 3DES, RC5 et RC6[46].

• Chiffrement asymétrique

Elle est également connue sous le nom de cryptographie à clé publique. Elle implique différentes clés pour le cryptage et le décryptage. Elle utilise deux clés de cryptage distinctes liées l'une à l'autre, la première clé étant appelée clé publique et l'autre clé étant appelée clé privée. La clé publique est disponible pour toute personne souhaitant envoyer un message à l'expéditeur. La seconde clé privée reste secrète, seul l'expéditeur la connaît. Un message crypté par une clé publique peut être décrypté à l'aide d'une clé privée. Un message crypté par une clé privée peut être décrypté à l'aide d'une clé publique. La sécurité de la clé publique n'est pas nécessaire car elle est disponible et peut passer par l'internet[46].

❖ Pare-feu «firewall»

Un pare-feu est souvent défini comme un dispositif (ou un logiciel) utilisé pour filtrer ou contrôler le flux de trafic[47].



Figure 2.2 Le pare-feu filtre les menaces [48]

Les pare-feu sont généralement mis en œuvre sur le périmètre du réseau et fonctionnent en définissant des zones de fiabilité et de non fiabilité .

Un pare-feu est un élément indispensable de toute architecture de sécurité. Il élimine les incertitudes liées aux protections au niveau de l'hôte et les confie au dispositif de sécurité du réseau. Les pare-feu, et en particulier les pare-feu de nouvelle génération, se concentrent sur le blocage des logiciels malveillants et des attaques de la couche application, avec un système intégré de prévention des intrusions (IPS), ces pare-feu de nouvelle génération peuvent réagir rapidement et de manière transparente pour détecter et réagir aux attaques extérieures sur l'ensemble du réseau. Ils peuvent définir des politiques pour mieux défendre le réseau et effectuer des évaluations rapides pour détecter les activités invasives ou suspectes, comme les logiciels malveillants, et les arrêter[47].

❖ Les protocoles de gestion des clés

La gestion des clés est le domaine qui a reçu le plus d'attention de la part des chercheurs en matière de sécurité des WSN. La gestion des clés est un mécanisme essentiel pour garantir la sécurité des services et des applications de réseau dans les WSN. L'objectif de la gestion des clés est d'établir les clés entre les nœuds de manière sûre et fiable[43].

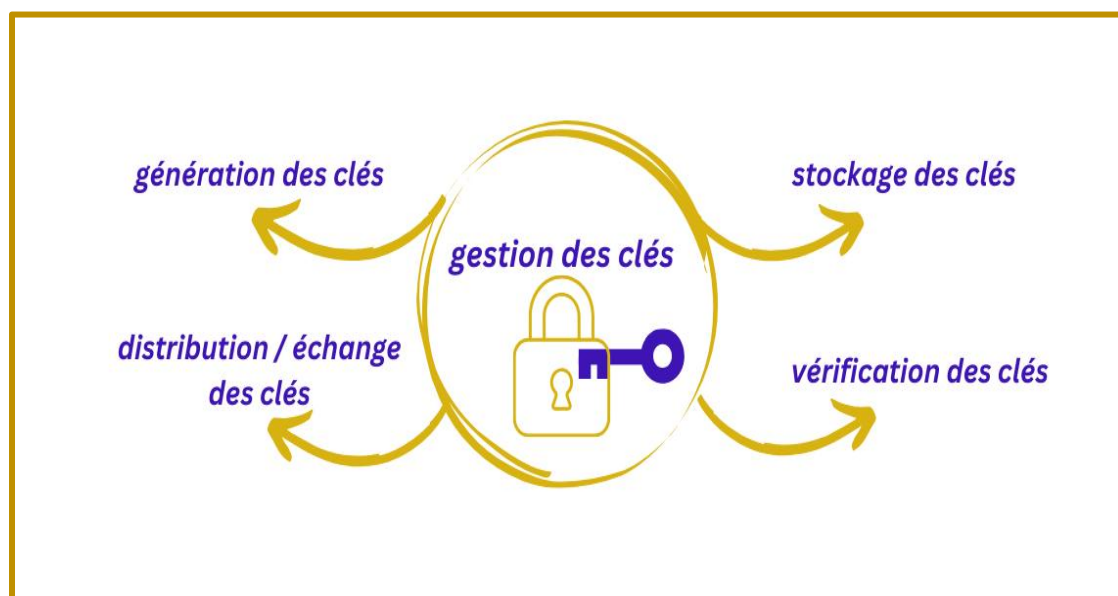


Figure 2.3 fonction de gestion des clés

Par ailleurs, le système de gestion des clés doit prendre en charge l'ajout et la révocation de nœuds dans le réseau. Étant donné que les nœuds des WSN sont soumis à des contraintes de calcul et d'énergie, les protocoles de gestion des clés pour ces réseaux doivent être extrêmement légers. La plupart des protocoles de gestion de clés existants pour les WSN sont basés sur la cryptographie à clé symétrique. car les techniques de cryptographie à clé publique sont en général intensives en termes de calcul[43].

❖ **L'authentification**

L'authentification est un processus par lequel l'identité d'un nœud / personne dans un réseau est vérifiée et garantit que les données ou les messages de contrôle proviennent d'une source authentifiée. Les différentes procédures d'authentification sont les suivantes [42] :

- **Authentification unidirectionnelle**

Un seul message est transmis du nœud émetteur au nœud récepteur. Ce message pourra créer : l'identité de l'expéditeur, le message généré par l'expéditeur, le message destiné au destinataire, le message qui n'est pas altéré pendant le transit[42].

- **Authentification bidirectionnelle ou mutuelle**

Les deux entités peuvent s'authentifier mutuellement dans un lien de communication. Dans les environnements WSN, ce système ne signifie pas seulement l'authentification entre les nœuds normaux et la station de base, mais mentionne également les deux contreparties qui sont sûres de l'identité de l'autre[42].

- **Authentification à trois sens**

Un troisième message de l'émetteur au récepteur est envoyé lorsque les horloges des nœuds ne peuvent pas être synchronisées[42].

- **Authentification implicite**

L'authentification implicite est non seulement réalisée en tant que processus indépendant, mais elle est également le sous-produit d'autres processus tels que l'établissement de clés. Dans les WSN, ce type d'authentification peut minimiser la fois la complexité opérationnelle et la consommation d'énergie[42].

Les problèmes d'authentification basés sur le déploiement des nœuds sont :

- **le déploiement statique**

les nœuds sont statiques et vulnérables aux attaques par rejeu. Les protocoles d'authentification doivent contrer ces problèmes puisque les nœuds sont facilement traçables[42].

- **le déploiement dynamique**

les problèmes sont notamment : la réauthentification du nœud mobile, le mouvement du nœud qui doit être intraversable, l'intégrité du message, la confidentialité, et la capture et la compromission du nœud[42].

2.5 Normes et réglementations en matière de sécurité IoT

Les normes et réglementations en matière de sécurité IoT sont des directives établies par des organisations et des autorités gouvernementales pour garantir la protection des dispositifs, réseaux et données dans l'écosystème de l'Internet des objets. Ces normes définissent des exigences de sécurité, des bonnes pratiques et des protocoles de conformité pour les fabricants, les développeurs et les utilisateurs d'appareils IoT.

Voici quelques-unes des normes de sécurité de l'IdO les plus reconnues :

- **ISO/IEC 27001**

ISO/IEC 27001 est la norme internationale en matière de sécurité de l'information. Elle définit les spécifications d'un SGSI (système de gestion de la sécurité de l'information) efficace. L'approche des meilleures pratiques de l'ISO 27001 aide les organisations à gérer leur sécurité informatique en s'intéressant aux personnes, aux processus et à la technologie. Un SMSI adopte une approche systématique pour garantir la confidentialité, l'intégrité et la disponibilité (CIA) des ressources d'information de l'entreprise.

Un SMSI ISO 27001 se compose de politiques, de procédures et d'autres contrôles impliquant des personnes, des processus et des technologies.

Un SMSI est un moyen efficace de sécuriser les ressources informatiques, sur la base d'évaluations régulières des risques et d'approches neutres en termes de technologie et de fournisseur[49].

- **NIST SP 800-53**

Norme établie par le National Institute of Standards and Technology (NIST) des États-Unis, fournissant des recommandations détaillées pour la sécurité des systèmes d'information et des réseaux[50].

- **NIST SP 800-53**

Recommandations de sécurité de base pour l'IoT émises par l'Agence européenne de cybersécurité (ENISA), fournissant des conseils pratiques pour sécuriser les appareils IoT[51].

2.6 La conclusion

Au terme de ce chapitre, nous avons exploré en profondeur les différentes facettes de la sécurité informatique, allant de sa définition selon divers chercheurs aux dimensions qui la composent, en passant par les attaques qui peuvent survenir à différentes couches du réseau, de la physique à l'application. Nous avons également examiné les mécanismes de sécurité spécifiques à l'IoT, ainsi que les normes et réglementations essentielles pour garantir un environnement sécurisé dans le domaine en constante évolution de l'Internet des objets. , Dans le chapitre suivant, nous présentons l'état de l'art relatif aux systèmes d'authentification dans le domaine des santé, puis nous présentons notre contribution.

Chapitre 3

Notre contribution

Dans ce chapitre, nous avons exploré les travaux connexes menés par des chercheurs dans le domaine de la santé. Nous avons minutieusement examiné le protocole proposé par Chien-Ming Chen et al., effectuant une cryptanalyse approfondie pour évaluer sa sécurité. Ensuite, nous avons apporté des améliorations à ce protocole et présenté notre proposition. Par la suite, nous avons effectué une analyse théorique et formelle en utilisant l'outil Scyther, afin de valider la robustesse de notre proposition et d'assurer sa fiabilité dans des environnements réels dans IOHT.

3.1 Travaux connexes

Chen et al. ont développé le protocole LAP-IoHT pour sécuriser les données de santé dans l'IoHT. En utilisant l'authentification à trois facteurs, le chiffrement asymétrique et la biométrie, le protocole garantit la confidentialité des données. Dans le LAP-IoHT, tous les participants, y compris les utilisateurs et les capteurs portables, sont authentifiés par la passerelle. Ensuite, une clé de session partagée est établie pour chaque session de communication. LAP-IoHT crypte les caractéristiques biométriques des utilisateurs pour garantir l'anonymat. Une analyse de LAP-IoHT a été réalisée à l'aide du modèle Real-or-Random (ROR)[52].

Kumar et al. ont utilisé des signatures numériques pour crypter le processus de communication du protocole IoHT et une authentification et un système de clés sont mis en place entre le patient, le serveur en nuage et le médecin. Pour améliorer la sécurité, les auteurs ont introduit un nouveau protocole, appelé RAPCHI (Robust Authentication Protocol for IoMT-based CHI), qui aborde les problèmes fondamentaux de sécurité et de confidentialité dans les infrastructures de santé connectées (CHI) basées sur l'informatique en nuage. L'article montre que RAPCHI est sécurisé contre les attaques de type "homme du milieu" et "reply" à l'aide du programme de simulation AVISPA[53].

Aghili et al. ont proposé un protocole de contrôle d'accès et de transfert de la propriété pour les systèmes IoHT à travers l'analyse de la sécurité du protocole ZZTL et l'amélioration apportée après avoir trouvé une certaine vulnérabilité dans le protocole ZZTL contre les attaques suivantes : attaque de traçabilité de l'utilisateur, attaque DoS, attaque d'initié, attaque de désynchronisation. L'architecture proposée comprend trois entités principales : le groupe d'utilisateurs, le serveur médical et le groupe de patients, qui assurent l'authentification, l'accord de clé, la confidentialité et le contrôle d'accès. Le protocole comprend notamment un mécanisme de transfert de propriété entre médecins, assurant une transition transparente des privilèges[54].

Preeti et al. ont conçu un protocole qui applique sur l'Internet des objets de santé

(IoHT) un réseau de capteurs sans fil (WSN) et intègre l'utilisation d'une carte à puce à des fins d'authentification. Ce protocole vise à renforcer la sécurité et la confidentialité des systèmes de santé à distance en garantissant une communication sécurisée entre les parties concernées par la cryptanalyse et l'étude du protocole de Challa et al, dans lequel ils ont trouvé certaines vulnérabilités , Les auteurs de cet article ont proposé un schéma d'authentification à trois facteurs amélioré par rapport au schéma de Challa et al. pour la surveillance des patients dans un système de santé à distance[55].

Ullah et al , propose un schéma d'authentification dans des environnements hétérogènes (sans certificat ou IBC). Pour élaborer le système proposé, la cryptographie à courbe hyperelliptique (HECC) est utilisée avec des clés de 80 bits seulement pour offrir le même niveau de sécurité dans la prévention des cyberattaques. Par conséquent, pour les dispositifs WBAN disposant de ressources limitées, Ullah et al utilisent une HECC comme meilleure option[56].

J. Rabie et al. présente un protocole de signature agrégée distribuée préservant la confidentialité dans un réseau de capteurs médicaux sans certificat. Le système proposé comprend plusieurs entités clés telles que les nœuds capteurs médicaux portables, le nœud zonal, le serveur médical central et l'expert médical certifié. Les nœuds capteurs collectent des données médicales et les transmettent au serveur central après vérification par le serveur local. Le protocole utilise des opérations XOR pour agréger les signatures des nœuds capteurs et éliminer la centralisation du serveur médical. La confidentialité des données médicales est soulignée en raison des risques de sécurité liés à la transmission d'informations sensibles. En outre, le rôle des différentes entités est défini, mettant en avant leurs capacités de stockage, de traitement et de confiance dans le système[57].

Xie et al. ont proposé un schéma d'authentification sans certificat amélioré et efficace avec préservation conditionnelle de la vie privée. les auteurs étudient et analysent le système de Ji et al. ils ont trouvé certaines vulnérabilités , après un schéma d'authentification sans certificat amélioré et sécurisé pour les WBAN avec préservation conditionnelle de la vie privée (appelé CasCP) est proposé[58].

THAKUR et al, après avoir analysé les faiblesses de sécurité du protocole de Servati et Safkhani, ont affirmé que la plupart des attaques cryptographiques, telles que l'usurpation d'identité, la fuite de secret éphémère, la recherche de mot de passe hors ligne et l'intrusion privilégiée, peuvent être combattues par leur système , THAKUR et al proposent une approche d'authentification fiable et efficace pour les systèmes médicaux basés sur le WMSN. Similaire au schéma en cinq phases de Servati et Safkhani, le système amélioré incorpore également ces

phases[59].

Li et al. ont proposé une technique d'authentification qui utilise un mécanisme à trois facteurs pour assurer une parfaite confidentialité. Li et al après la cryptanalyse du protocole d'authentification d'AMIN et al. ils ont trouvé qu'il était vulnérable. Pour améliorer la sécurité en s'appuyant sur le travail précédent d'AMIN et al, un protocole d'authentification à trois facteurs sécurisé basé sur l'ECC avec secret de transmission pour les WMSN est proposé[60].

Sureshkumar et al. ont conçu un schéma d'authentification utilisant l'ECC léger pour les WMSN Le protocole d'authentification proposé résout les problèmes de sécurité rencontrés dans les protocoles existants. La méthode formelle de la logique Burrows-Abadi-Needham (BAN) est appliquée pour prouver l'exactitude du protocole[61].

❖ Comparaisons de la sécurité

	R1	R2	R3	R4	R5	R6	R7	R8	R9	R10	R11	R12	outil de vérification
[1]	Y	Y	Y	X	Y	Y	Y	Y	Y	Y	X	X	ROR
[2]	Y	Y	X	Y	X	X	X	X	X	X	X	X	-AVISPA -ROM
[3]	Y	Y	Y	X	X	Y	Y	X	Y	Y	Y	X	-ProVerif
[4]	Y	Y	Y	Y	Y	Y	Y	Y	X	Y	Y	Y	-BAN -AVISPA
[5]	X	Y	Y	X	X	X	X	X	X	Y	X	Y	-ROR
[6]	Y	Y	Y	Y	X	X	X	X	X	Y	X	Y	-ROM -BAN
[7]	Y	Y	X	X	X	X	X	X	X	Y	X	Y	-ROM
[8]	Y	Y	Y	X	Y	Y	Y	X	X	Y	X	X	-BAN -ROR -Scyther
[9]	Y	Y	X	X	X	Y	Y	X	Y	X	Y	X	-ProVerif
[10]	Y	Y	Y	X	Y	Y	Y	X	X	X	Y	X	-BAN

Tableau 3.1 Comparaison de la sécurité

"Y" signifie que le protocole n'est pas vulnérable à cette attaque. Et "X" signifie que le protocole est vulnérable à cette attaque. R1 : attaque par rejeu ; R2 : attaque par usurpation d'identité ; R3 : attaque d'initié ; R4 : attaque de l'homme du milieu ; R5 : attaque par informations temporaires spécifiques à une session connue ; R6 : attaque par carte à puce volée ; R7 : attaque par devinette de mot de passe hors ligne ; R8 : attaque par capture de nœud de capteur ; R9 : attaque par désynchronisation ; R10 : attaque par divulgation de clé de session ; R11 : attaque par DOS , R12 : attaque par modification de message ;

❖ Comparaison des performances

	nombre de HF/FE/PM/e/⊕	nombre de messages U / G/ S	Total Calcul (ms)	Coût total de communication (bits)	nombre de Phases
[1]	31/1/-/-/36	4/4/3	24.77 (ms)	2496 (Bits)	3
[2]	21/-/3/-/8	2/2/2	370.19074 (ms)	6720 (Bits)	5
[3]	32/1/-/-/31	7/5/1	21.09864 (ms)	2016 (Bits)	5
[4]	31/1/6/-/18	4/3/1	69.171(ms)	2272 (Bits)	8
[5]	4/-/-/-/2	2/2/3	2.88(ms)	1440 (Bits)	5
[6]	4/-/-/-/14	-	7.013 (ms)	520(Bits)	6
[7]	4/-/6/-/4	1/2/4	5.82(ms)	1732 (Bits)	5
[8]	18/1/11/-/5	6/2/1	14.304 (ms)	1920 (Bits)	5
[9]	22/-/-/-/21	7/6/2	53.06 (ms)	2560 (Bits)	6
[10]	18/-/17/-/13	6/4/2	16.514 (ms)	2912 (Bits)	7

Tableau 3.2 Comparaison des performances

HF : opération de fonction de hachage, FE : opération d'extraction floue
 PM : opération de multiplication de points de la courbe elliptique,
 e : exponentielles simples,
 ⊕ : opération XOR,
 U:utilisateur, G : gateway, S : capteur

3.2 Modèle du système

Le modèle de système de santé proposé est illustré dans la Figure 3.1 Dans ce paradigme, le flux de travail du protocole proposé est composé de trois entités principales : les capteurs ; les utilisateurs, passerelle.

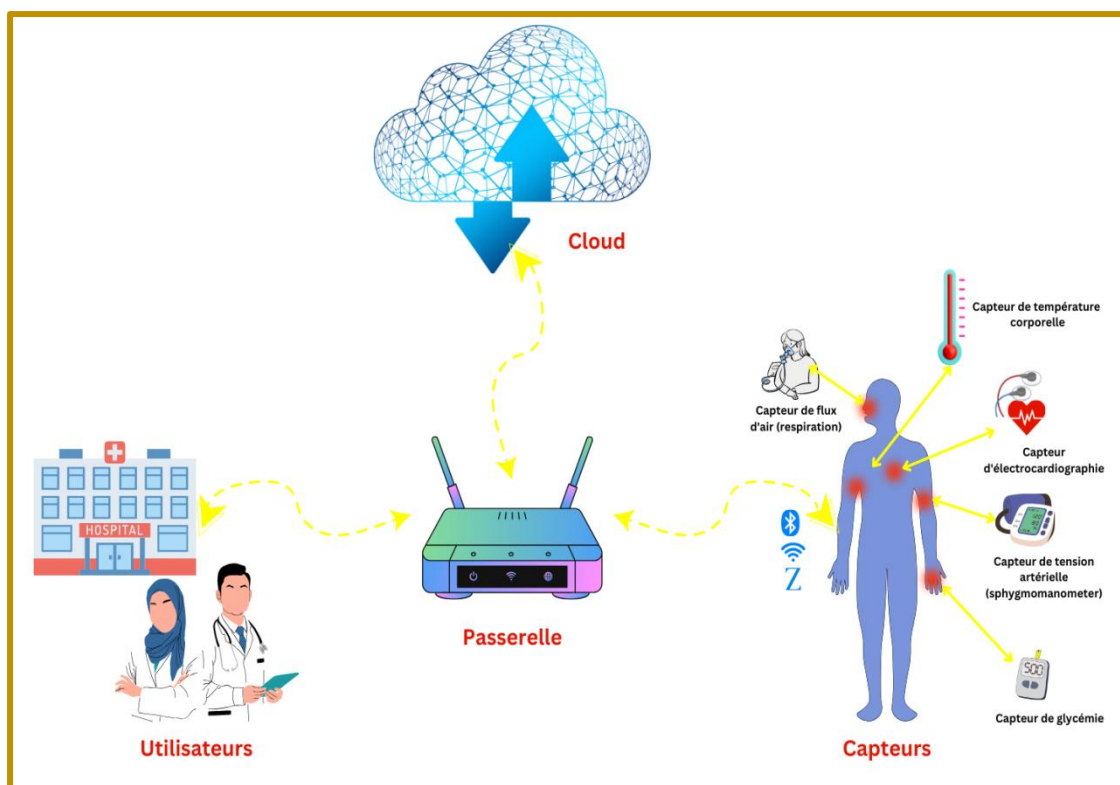


Figure 3.1 Le modèle de système de santé proposé

❖ les capteurs

Ces capteurs sont placés ou implantés dans le corps humain et leur rôle principal est de collecter les différentes données relatives à la santé, telles que l'ECG, la pression artérielle, la glycémie, la fréquence respiratoire et la température corporelle.

❖ les utilisateurs

Dans le modèle du système proposé, les utilisateurs sont représentés principalement en tant que médecins, qui possèdent un accès autorisé aux données médicales des patients. Ces médecins utilisent le système pour surveiller et analyser l'état des patients, prescrire des traitements et prendre des décisions thérapeutiques éclairées sur les données fournies par les capteurs.

❖ passerelle «gateway»

la passerelle joue le rôle de pivot pour orchestrer la communication entre les utilisateurs et les capteurs, agit comme un intermédiaire de confiance facilitant la

transparence de la communication ; elle constitue une unité principale où les informations sont authentifiées et reliées de manière sécurisée entre les différents composants du système.

Au cœur de ce cadre, on trouve le corps du patient équipé de capteurs médicaux sans fil intelligents et à faible consommation d'énergie, tels que des stimulateurs cardiaques, tension artérielle, des capteurs de glycémie, etc. Ces capteurs utilisent souvent des technologies telles que Zigbee ou Bluetooth pour enregistrer et mettre à jour les données et les transmettre ensuite. Par ailleurs, les professionnels de santé, notamment les médecins, peuvent accéder à distance à l'interface de la passerelle pour surveiller l'état des patients et récupérer les informations nécessaires, que le patient se trouve à l'hôpital ou à chez lui. Cela permet un suivi en temps réel de l'état des patients et facilite l'accès rapide aux informations critiques. Les données des patients sont stockées en toute sécurité sur un serveur cloud, ce qui garantit une gestion, une accessibilité et une confidentialité robustes des données au sein de l'écosystème de l'IOHT.

3.3 La revue de protocole de Chien-Ming Chen et al

Le protocole LAP-IoHT de Chen et al. est un protocole d'authentification léger conçu pour l'Internet des objets de santé . Il utilise l'authentification à trois facteurs, le chiffrement asymétrique et la biométrie pour sécuriser la transmission de données de santé sensibles. Le protocole se compose de trois phases : l'enregistrement de l'utilisateur, l'enregistrement du capteur, la connexion et l'authentification.

❖ phase d'enregistrement de l'utilisateur

si l'utilisateur U_a souhaite être un utilisateur légitime. Cet utilisateur doit être enregistré auprès du GW_b , Les messages sont transmis via un canal sécurisé.

• Message 1

l'utilisateur U_a possède ID_a , PW_a et la biométrie Bio et choisit un nombre aléatoire r_i , U_a calcule $HID_a = h(ID_a // r_i)$, $Gen(Bio) = (\sigma_a, \tau_a)$, $HPW_a = h(PW_a // \sigma_a)$, $N = PW_a \oplus h(ID_a // \sigma_a)$.

U_a envoie à GW_b { HID_a , HPW_a , N }

• Message 2

GW_b vérifie si HID_i a déjà été enregistré, puis il calcule , $D1 = h(HID_a // N)$, $D2 = (D1 // G_j) \oplus HPW_a$, $D3 = (D2 \oplus N)$, $D4 = h(HID_a // G_j) \oplus D1$.

GW_b envoie à U_a { $D1$, $D3$, $D4$ }

GW_b stocke (HID_a , $D1$) dans sa base de données.

• Message 3

U_a calcule $\Omega_a = N \oplus r_i$ et $M = h(N // r_i) \oplus HID_a$

U_a stocke { $D1$, $D3$, $D4$, Ω_i , M } dans sa carte à puce.

❖ phase d'enregistrement du capteur

Un capteur portable doit également être enregistré avant de pouvoir rejoindre le réseau avec GWb , Les messages sont transmis via un canal sécurisé.

• Message 1

SNc envoie son identité IDc à GWb

• Message 2

GWc génère un nombre aléatoire b et calcule la pseudo-identité de SNc, $PIDc = h(IDc // b)$ et $HSIDc = h(IDc // G_j)$, $SG = h(HSIDc // G_j) \oplus PIDc$, $L = ENC_{pbs}(PIDc)$

GWb envoie à SNc {SG, L}

GWb stocke (SIDc, PIDc) dans sa base de données.

• Message 3

SNc stocke {SG, L} dans sa propre mémoire

❖ phase de connexion et d'authentification

Si l'Ua exige une connexion à un capteur portable spécifique SNc, GWb doit vérifier la légitimité de l'utilisateur.

• Message 1

Ua insère sa carte à puce dans un ordinateur ou un lecteur de carte à puce, et lui fournit son IDa , PWa , Bio , cet ordinateur calcule $\sigma_a = Rep(Bio, \tau_a)$, $N = PWa \oplus h(IDa // \sigma_a)$, $M' = h(N // r_i) \oplus HIDa$ ou $r_i = N \oplus \Omega_a$, ensuite, il détermine si M' est égal à M stocké dans la carte à puce , si c'est le cas , il génère un nombre aléatoire ra et un horodateur T1 et calcule $HPWa = h(PWa // \sigma_a)$, $K1 = D3 \oplus N \oplus HPWa$, $K2 = K1 \oplus ra$, $Xug = h(T1 // ra // HIDa // K2)$.

Ua envoie à GWb { HIDa , K2, Xug , T1 }

• Message 2

GWb vérifie la fraîcheur de T1 , Ensuite, il calcule $K1 = h(D1 // G_j)$, $ra = K1 \oplus K2$, $Xug' = h(T1 // ra // HIDa // K2)$, Si Xug reçu est égal à Xug' calculé, GWc calcule un nombre aléatoire rc et un horodateur T2 , $HSIDc = h(IDc // G_j)$, $K3 = ra \oplus h(HSIDc // G_j)$, $K4 = D1 \oplus h(K3 // IDc // ra)$, $K5 = rc \oplus h(D1 // ra)$, $K6 = K3 \oplus PIDc$, $Xgs = h(T2 // ra // rc // IDc // K5)$.

GWb envoie à SNc {K4, K5, K6, Xgs, T2}

• Message 3

SNb vérifie la fraîcheur de T2 , Ensuite, SNc obtient PIDc par déchiffrement de L à l'aide de la clé privée pus, et calcule $K3 = K6 \oplus PIDc$, $ra = K3 \oplus SG \oplus PIDc$, $D1 = K4 \oplus h(K3 // IDc // ra)$, $rc = K5 \oplus h(D1 // ra)$, $Xgs' = h(T2 // ra // rc // IDc // K5)$, Si Xgs reçu est égal à Xgs' calculé , SNb calcule un nombre aléatoire rb et un horodateur T3 , $K7 = rb \oplus h(SG // D1 // rc)$, $K8 = PIDc \oplus K7$, $Xsg = h(T3 // rc // rb // K7 // SG)$, $Xsu = h(ra // rb // IDc // D1)$, Enfin, SNc calcule la clé de session $SK = h(ra // rb // rc)$.

SNc envoie à GWb { K8, Xsg,Xsu,T3}

• **Message 4**

GWb vérifie la fraîcheur de T3, Ensuite, il calcule $k7 = PIDc \oplus K8$, $SG = h(HSIDc//Gj) \oplus PIDc$, $rb = K7 \oplus h(SG//D1//rc)$, $Xsg' = h(T3//rc//rb//K7//SG)$, Si Xsg reçu est égal à Xsg' calculé, GWb calcule un horodateur T4, $K9 = D1 \oplus K1$, $K10 = K9 \oplus h(HIDa//Gj) \oplus rb$, $K11 = IDc \oplus h(K1//rb)$, et il calcule $Xgu = h(T4//ra//rc//K10)$ pour une authentification mutuelle ,Enfin, GWb calcule la clé de session $SK = h(ra//rb//rc)$.

GWb envoie à Ua {K5, K10,K11 ,Xgu , Xsu ,T4}

• **Message 5**

Ua vérifie la fraîcheur de T4, Ensuite, il calcule $rb = K1 \oplus K10 \oplus D4$, $rc = K5 \oplus h(D1//ra)$, et il calcule $Xgu = h(T4//ra//rc//K10)$, Si Xgu reçu est égal à Xgu' calculé , Ua calcule la clé de session $SK = h(ra//rb//rc)$.

3.4 La cryptanalyse du protocole de Chien-Ming Chen et al

❖ **Attaque par vol de carte à puce**

l'attaquant A obtient {D1, D3, D4, Ω_a , M} stockés dans la carte à puce qui a été volée.

❖ **Attaque d'initiés privilégiés**

Supposons que l'attaquant A soit un initié privilégié du système, l'attaquant prendra HPWa et N, sachant que $K1 = h(D1//Gj)$, l'attaquant peut trouver K1 à partir de D2 "de l'attaque précédente l'attaquant a déjà D3 donc il a aussi D2 vu que $D3 = D2 \oplus N$ ", En sachant que $D2 = h(D1//Gj) \oplus HPWa$, en appliquant un autre $\oplus HPWa$, l'attaquant obtient $h(D1//Gj)$ qui est K1, maintenant $K2 = K1 \oplus ra$, l'attaquant pourrait trouver K1, donc à partir de K2 on peut dire que l'attaquant possède ra.

❖ **Attaque par l'usurpation d'identité de l'utilisateur**

Dans cette attaque, l'attaquant A cherche à générer un Message1 valide contenant "HIDa, K2, Xug, T1" dans la phase de connexion et d'authentification, tout en sachant que l'attaquant possède déjà "ru, K1, K2, D1, D3, D4, Ω_a , M, HPWa", et comme HIDa a été envoyé via un canal public, il peut également le prendre, $Xug = h(T1//ra//HIDa//K2)$ et l'attaquant les a tous obtenus, vu que le Message1 généré par l'attaquant contient les informations d'identification originales de l'utilisateur Ua, donc le message généré va passer la phase de vérification, et l'attaquant A a réussi à usurper l'identité de l'utilisateur.

dans le message5 $K5 = rc \oplus h(D1//ra)$, l'attaquant possède D1 et ra donc il peut obtenir rc, $rb = K1 \oplus K10 \oplus D4 = K1 \oplus K9 \oplus h(HIDa//Gj) \oplus D4 = K1 \oplus D1 \oplus K1 \oplus h(HIDa//Gj) \oplus h(HIDa//Gj) \oplus D1 \oplus rb$ donc l'attaquant peut aussi obtenir rb, comme l'attaquant possède ra, rb, rc, il a maintenant la clé secrète SK qui est $sk = h(ra//rc//rb)$.

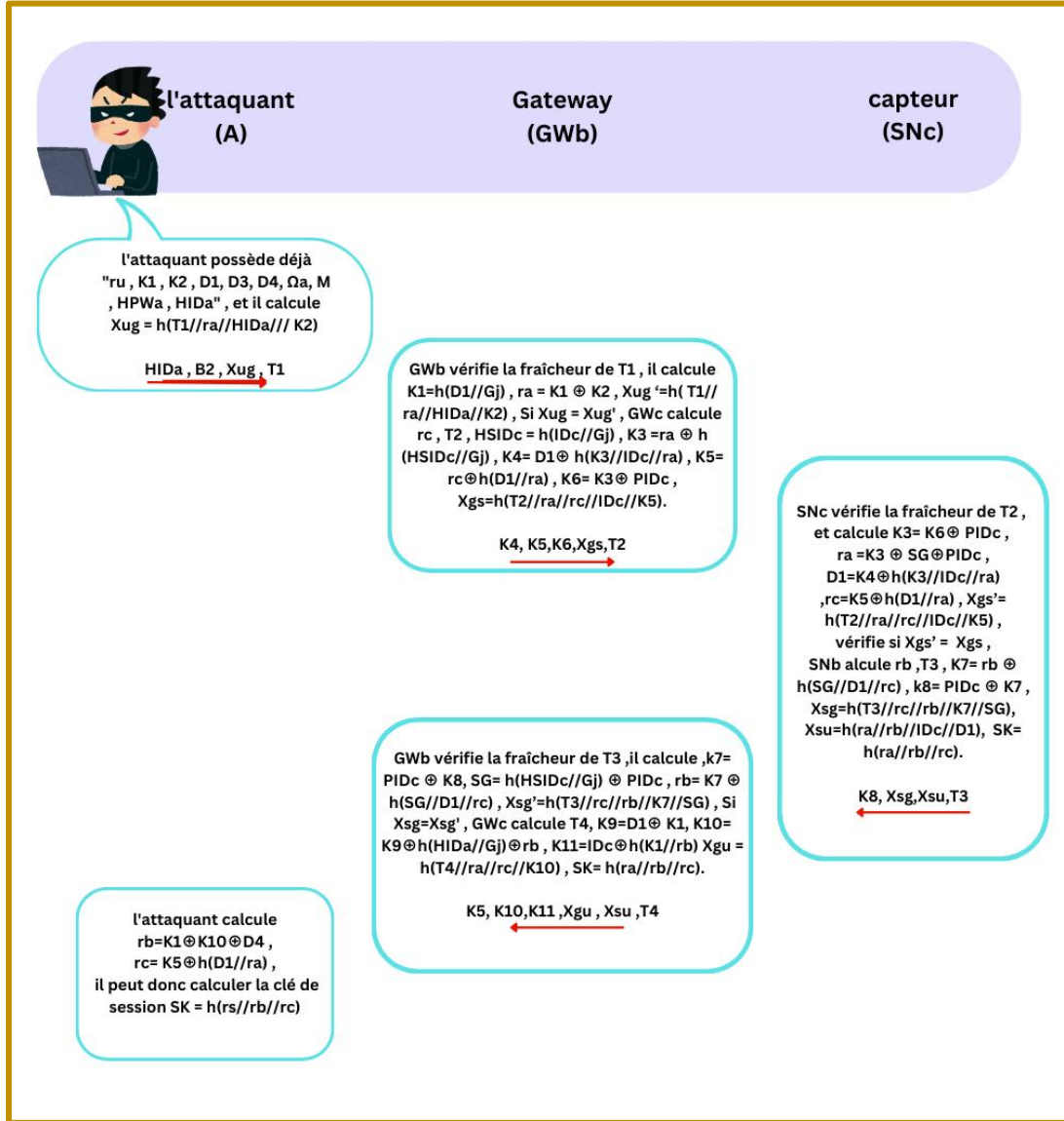


Figure 3.2 le scénario d'attaque de usurpation d'identité de l'utilisateur

3.5 Notre proposition de schéma LSAP-IOHT

Pour répondre aux problèmes de sécurité posés par l'approche de Chien-Ming Chen et al, nous proposons un nouveau schéma d'authentification fiable et efficace pour les systèmes médicaux. En utilisant des techniques cryptographiques avancées et des mécanismes d'authentification robustes. Avec un schéma composé de quatre phases, le système amélioré incorpore les phases suivantes :

- phase d'initiation
- phase d'enregistrement de l'utilisateur
- phase d'enregistrement du capteur
- phase de connexion et d'authentification

Notations	Descriptions
Ua , GWb , SNc	utilisateur, nœud gateway, nœud capteur
PWa	Mot de passe de Ua
IDa	identité de Ua
IDc	identité de SNc
PWc	Mot de passe de SNc
IDg	identité de gateway
SKsg , SKug , SKsu	Session key
Ts	Time stamp, avec s = 1, 2, 3, 4
NA , NB , NS , NB1, NB2 , ru , rs , rg	nombres aléatoires
$\oplus$,	XOR , opération de concaténation
H(.)	fonction de hachage
ENC/DEC	chiffrement / déchiffrement
PUF	Physical unclonable function
ECC	Elliptic-curve cryptography

Tableau 3.3 Définitions des notations

❖ phase d'initiation

On considère que cette phase est appliquée avant le commencement du protocole dans un environnement sécurisé, chaque entité « gateway , capteurs , utilisateurs » est équipée de la technologie PUF , et a un Challenge-Response basé sur PUF " CRP " , le gateway a les deux CRP des capteurs et des utilisateurs " CRPs , CRPa " , tandis que les deux capteurs et utilisateurs possèdent le CRP de la gateway "CRPb » , Ce protocole utilise un système ECC léger pour les appareils intelligents.

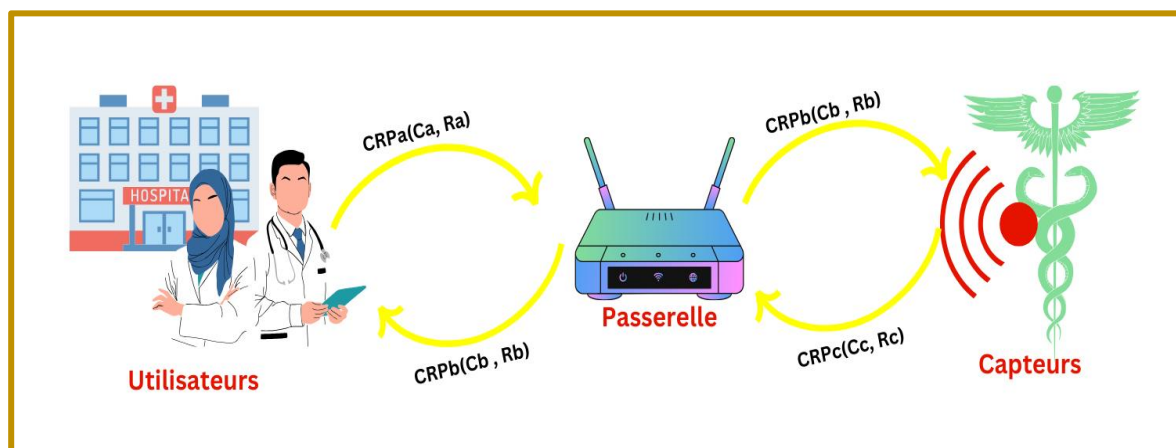


Figure 3.3 phase d'initiation

❖ phase d'enregistrement de l'utilisateur

Pour que l'utilisateur U_a souhaite être reconnu comme un utilisateur légitime, il doit obligatoirement être enregistré auprès du GWb. Une fois cet enregistrement effectué, tous les messages échangés seront transmis via un canal sécurisé afin de garantir la confidentialité et l'intégrité des communications.

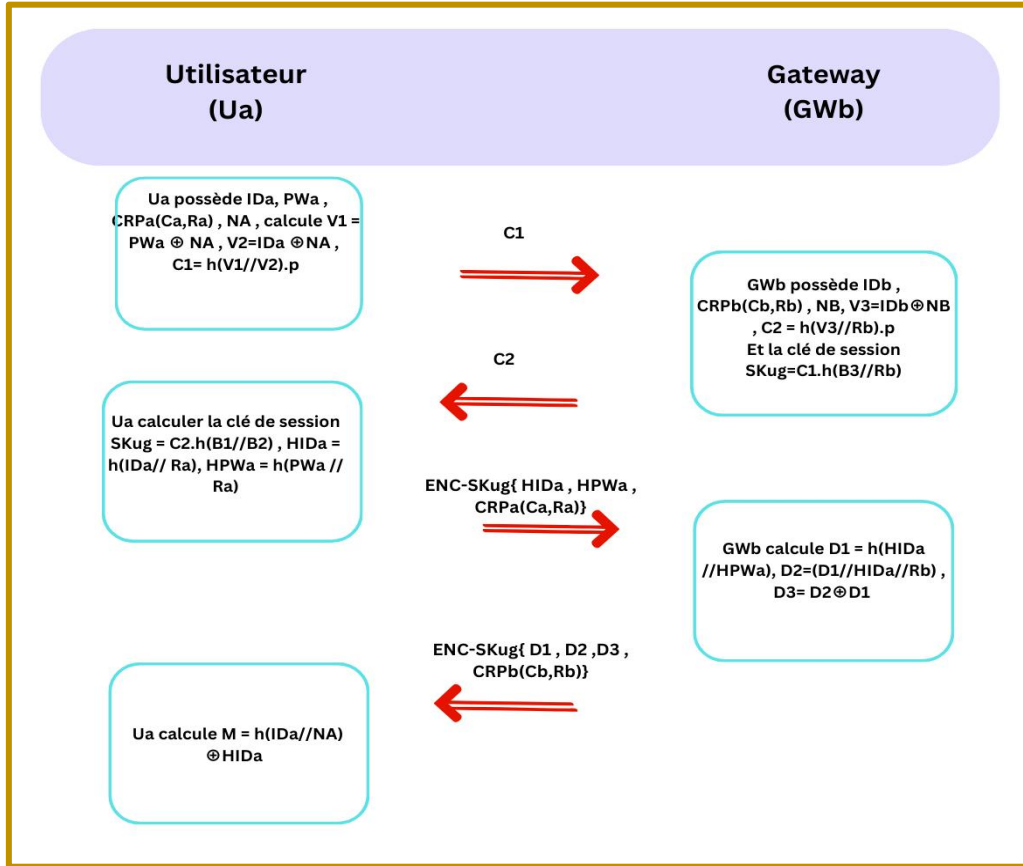


Figure 3.4 phased'enregistrement de l'utilisateur

• Message 1

l'utilisateur U_a possède ID_a , PW_a et PUF a généré l'unique challenge-réponse $CRPa(Ca, Ra)$ et choisit un nombre aléatoire NA , U_a calcule $V1 = PW_a \oplus NA$, $V2 = ID_a \oplus NA$, $C1 = h(V1 // V2).p$

U_a envoie à GW_b :{ $C1$ }

• Message 2

GW_b possède ID_b et PUF a généré l'unique challenge-réponse $CRPb(Cb, Rb)$ et choisit un nombre aléatoire NB , puis il calcule, $V3 = ID_b \oplus NB$, $C2 = h(V3 // Rb).p$ Et la clé de session $SKug = C1.h(B3 // Rb)$

GW_b envoie à U_a :{ $C2$ }

• Message 3

Ua peut maintenant calculer la clé de session $SK_{ug} = C2.h(B1//B2)$, Ua calcule $HIDa = h(IDa//Ra)$, $HPWa = h(PWa//Ra)$

Ua envoie à GWb: $ENC-SK_{ug}\{HIDa, HPWa, CRPa(Ca,Ra)\}$

• Message 4

GWb vérifie à l'aide de PUF l'identité de Ua, puis il calcule, $D1 = h(HIDa//HPWa)$, $D2 = (D1//HIDa//Rb)$, $D3 = D2 \oplus D1$,

GWb envoie à Ua : $ENC-SK_{ug}\{D1, D2, D3, CRPb(Cb,Rb)\}$

• Message 5

Ua vérifie à l'aide de PUF l'identité de GWb, puis Ua calcule $M = h(IDa//NA) \oplus HIDa$

❖ phase d'enregistrement du capteur

Un capteur portable doit également être enregistré auprès du GWb avant de pouvoir se connecter au réseau. Une fois enregistré, les messages sont transmis via un canal sécurisé, assurant ainsi la sécurité des communications.

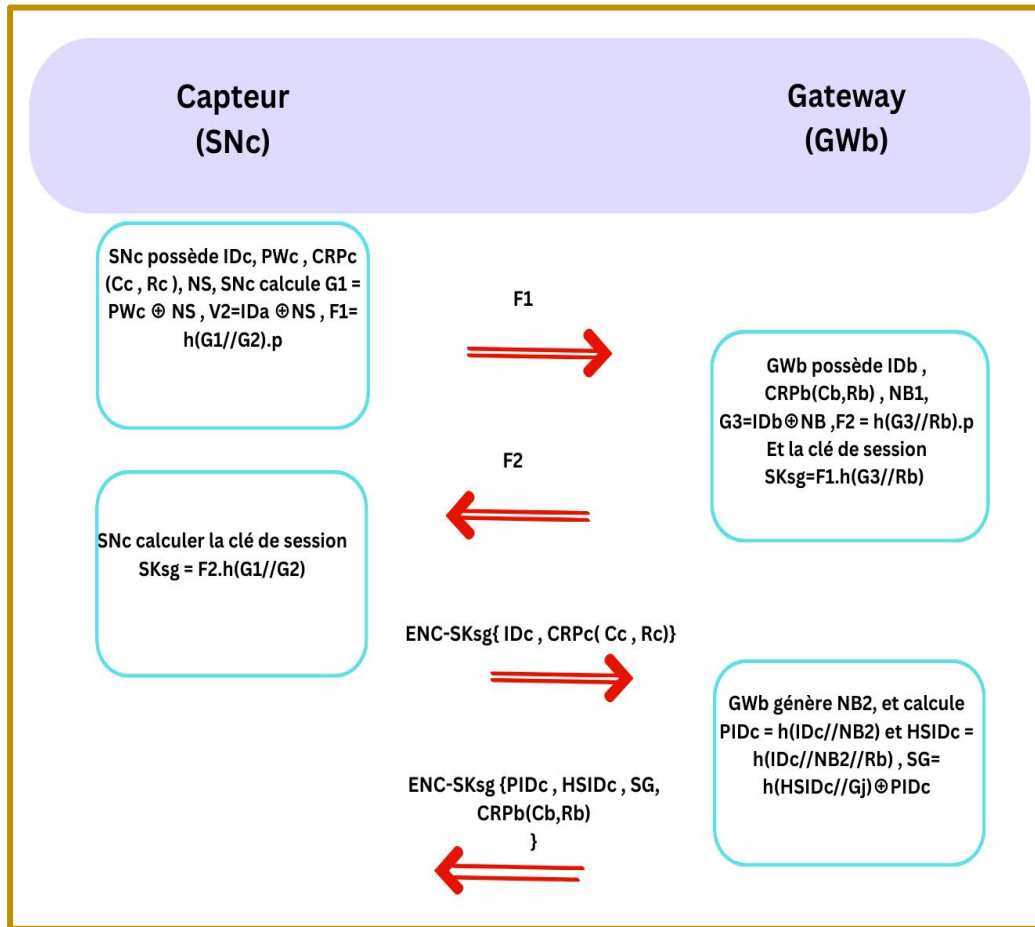


Figure 3.5 phase d'enregistrement du capteur

• **Message 1**

Le capteur SNc possède IDc, PWc et PUF a généré l'unique challenge-réponse CRPc (Cc , Rc) et choisit un nombre aléatoire Ns , SNc calcule $G1 = PWc \oplus NS$, $V2=IDa \oplus NS$, $F1= h(G1//G2).p$

SNc envoie à GWb :{ F1}

• **Message 2**

GWb possède IDb et PUF a généré l'unique challenge-réponse CRPb (Cb , Rb) et choisit un nombre aléatoire NB1, puis il calcule , $G3=IDb \oplus NB$, $F2 = h(G3//Rb).p$
Et la clé de session $SKsg=F1.h(G3//Rb)$

GWb envoie à SNc {F2}

• **Message 3**

SNc peut maintenant calculer la clé de session $SKsg = F2.h(G1//G2)$

SNc envoie à GWb / ENC-SKsg{ IDc , CRPc(Cc , Rc)}

• **Message 4**

GWc génère un nombre aléatoire NB2 et calcule la pseudo-identité de SNc, $PIDc = h(IDc//NB2)$ et $HSIDc = h(IDc//NB2//Rb)$, $SG= h(HSIDc//Gj) \oplus PIDc$

GWb envoie à SNc : ENC-SKsg {PIDc , HSIDc , SG, CRPb(Cb,Rb)}

❖ **phase de connexion et d'authentification**

Si Ua demande une connexion à un capteur portable spécifique SNc, GWb doit confirmer que l'utilisateur est légitime.

• **Message 1**

Ua insère sa carte à puce dans un ordinateur ou un lecteur de carte à puce, et lui fournit son IDa ,PWa , CRPa(Ca,Ra) , cet ordinateur calcule $M' = h(IDa// NA) \oplus HIDa$, ensuite, il détermine si M' est égal à M stocké dans la carte à puce , si c'est le cas, il génère un nombre aléatoire ra et un horodateur T1et calcule $K1=h(D1//Ra)$, $K2 =K1 \oplus ra$, $Z1=h(IDa //PWa//Ra).p$, $Xug =h(T1// ra//Z1).$

Ua envoie à GWb { K2, Xug , Z1, T1}

• **Message 2**

GWb vérifie la fraîcheur de T1 , Ensuite, il calcule $K1'=h(D1//Ra)$, $ra = K1' \oplus K2$, $Xug '=h(T1// ra//Z1)$, Si Xug reçu est égal à Xug' calculé, GWc calcule un nombre aléatoire rb et un horodateur T2, $K3 =ra \oplus h(HSIDc//Rb)$, $K4= K3 \oplus PIDc$, $K5= rb \oplus HSIDc \oplus ra$, $Xgs=h(T2//ra//rb//Z1//IDc).$

GWb envoie à SNc {K4, K5,Xgs,Z1, T2}

• **Message 3**

SNb vérifie la fraîcheur de T2 , Ensuite, SNc calcule $K3'= K4 \oplus PIDc$, $ra =K3' \oplus SG \oplus PIDc$, $rb=K5 \oplus HSIDc \oplus ra$, $Xgs'= h(T2//ra//rb//Z1//IDc)$, Si Xgs reçu est égal à Xgs' calculé , SNb calcule un nombre aléatoire rc et un horodateur T3 , $K6= rc \oplus h(SG//Rc//rb)$, $k7=PIDc \oplus K6$, $Z2=h(PWc//IDc//Rc).p$

$Xsg=h(T3//rc//rb//Z2//SG)$, Enfin, SNc calcule la clé de session $SKsu=ra.rc.Z1.h(PWc//IDc//Rc)$

SNc envoie à GWb { K7, Xsg,Z2,T3}

• Message 4

GWb vérifie la fraîcheur de T3, Ensuite, il calcule $k6'=PIDc \oplus K7$, $rc=K6' \oplus h(SG//Rc//rb)$, $Xsg'=h(T3//rc//rb//Z2//SG)$, Si Xsg reçu est égal à Xsg' calculé, GWb calcule un horodateur T4, $K8=rc \oplus h(D1//K1)$, $K9=K8 \oplus h(HIDa//Rb)$, et il calcule $Xgu=h(T4//rc//Z2//Rb//ra)$ pour une autre authentification mutuelle.

GWb envoie à Ua {K9,Xgu,Z2,T4}

• Message 5

Ua vérifie la fraîcheur de T4, Ensuite, il calcule $K8'=K9 \oplus h(HIDa//Rb)$, $rc=K8' \oplus h(D1//B1)$, et il calcule $Xgu=h(T4//rc//Z2//Rb//ra)$, Si Xgu reçu est égal à Xgu' calculé, Ua calcule la clé de session $SKsu=ra.rc.Z2.h(PWa//IDa//Ra)$

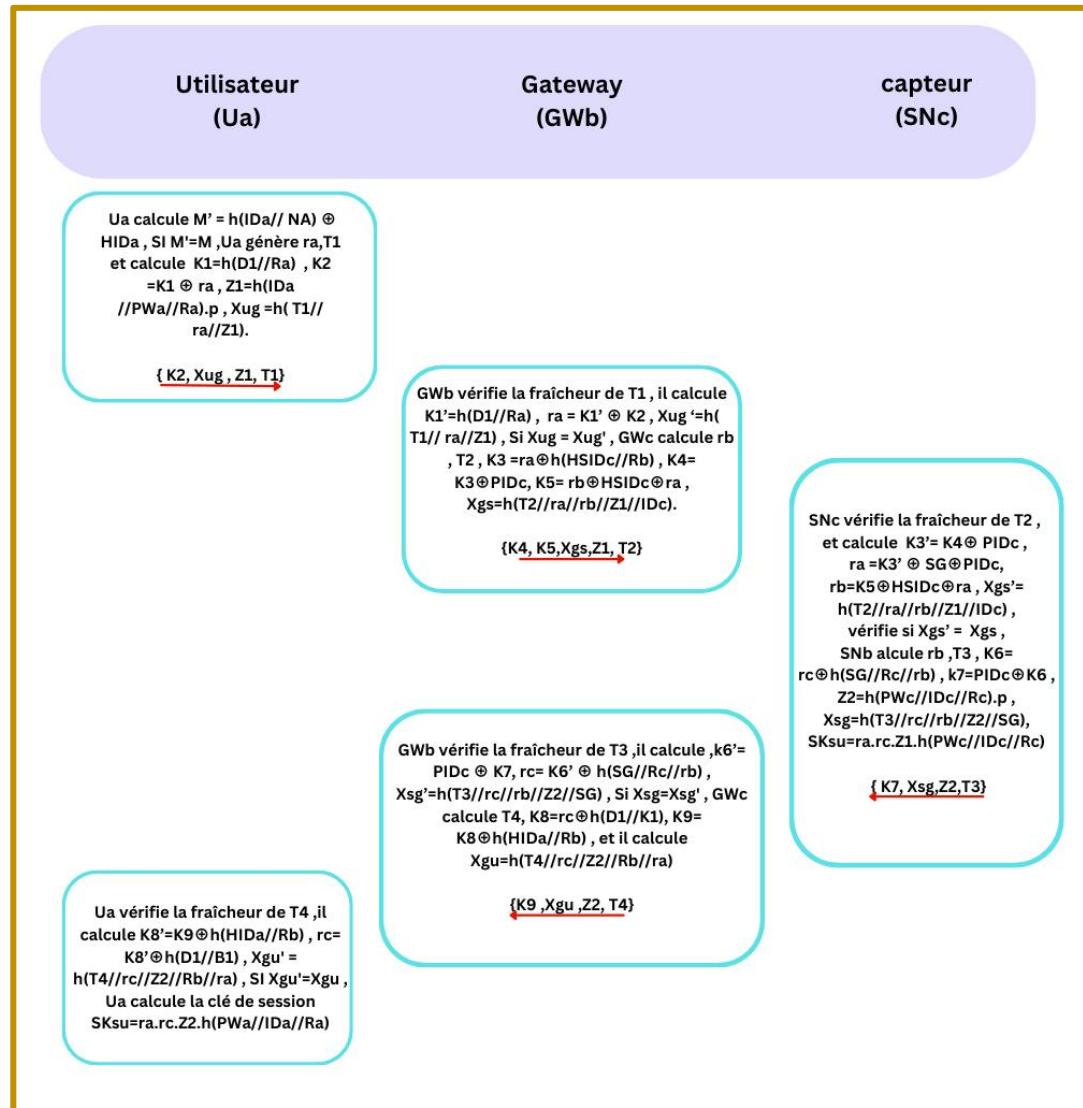


Figure 3.6 phase d'enregistrement du capteur

3.6 Analyse de sécurité

Cette analyse formelle vise à examiner la robustesse et l'efficacité de notre protocole de sécurité dans le contexte du IoHT. Nous allons évaluer les mécanismes de cryptographie et d'authentification utilisés, leur intégration harmonieuse dans l'architecture globale du système, et leur capacité à répondre aux menaces potentielles. En fournissant une évaluation détaillée et rigoureuse, nous espérons démontrer que notre protocole peut offrir une sécurité fiable et adaptable dans un environnement de santé hautement connecté et nous prouvons également que notre approche est résistante à différents types d'attaques.

Enfin, nous avons utilisé scyther pour montrer que le protocole que nous avons proposé est sécurisé.

❖ Analyse informelle

Dans cette analyse, nous prouvons la capacité de résistance aux attaques connues, et nous définissons quelques techniques cryptographiques utilisées.

• Attaque par Rejeu

Dans notre protocole proposé, les messages transmis comprennent des timestamps et des nombres aléatoires, tels que T1, T2, NA et NB. Les timestamps et les nombres aléatoires sont deux moyens efficaces de prévenir les attaques par rejeu. En intégrant ces mécanismes, notre protocole garantit la résistance aux attaques par rejeu, préservant ainsi la sécurité et l'intégrité des communications.

• Attaque par usurpation d'identité

Pour chaque entité du système - nœud gateway, nœud capteur et utilisateur - nous avons utilisé une double vérification d'authentification pour chaque message transmis. En outre, nous avons adopté une authentification à trois facteurs. Chaque entité est équipée d'une identité, d'un mot de passe et d'une paire Challenge-Réponse (CRP) unique du PUF. Cette approche de sécurité à plusieurs niveaux garantit que même si un attaquant tente de pénétrer dans le système, il ne réussit pas à passer la double vérification d'authentification.

• Attaque d'initiés privilégiés

Le protocole que nous avons proposé est sécurisé contre les attaques d'initiés privilégiés grâce à la mise en œuvre de PUF (Physically Unclonable Functions). Chaque entité du système est authentifiée à l'aide d'une paire Challenge-Réponse (CRP) PUF unique, qui ne peut être ni dupliquée ni prédite. Cela garantit que même les initiés privilégiés, qui pourraient avoir accès à d'autres détails d'authentification, ne peuvent pas reproduire les réponses PUF uniques d'autres entités. et même si l'attaquant pouvait obtenir certaines données, il ne pourrait pas trouver les clés, certaines des données qui entrent dans la génération des clés n'ayant même pas été envoyées. Par conséquent, le protocole atténue

efficacement le risque de menaces d'initiés, en maintenant l'intégrité et la sécurité du système.

- **Attaque physique**

La nature simple des appareils IOHT permet aux adversaires d'y accéder facilement. Dans une attaque physique, l'attaquant peut accéder physiquement à l'appareil IoT pour extraire les clés secrètes et, par conséquent, cloner l'appareil. Le protocole que nous avons proposé est considéré comme étant sécurisé contre ce type d'attaque en raison du fait que les microcontrôleurs et les PUF des appareils sont intégrés sur la même puce et communiquent de manière sécurisée. Par conséquent, même si un attaquant a un accès physique à l'appareil IoT, il ne peut en extraire aucune des clés secrètes.

- **Attaque de l'homme du milieu**

notre protocole proposé est considéré être résistant à ce type d'attaque du fait que l'attaquant MITM a besoin de connaître des informations spécifiques pour construire des données valides afin de commencer l'attaque. Connaître toutes ces informations n'est pas possible pour un adversaire actif qui se place sur la ligne de communication entre les trois parties qui communiquent, dans la phase d'enregistrement de l'utilisateur et dans l'enregistrement du capteur, nous avons envoyé les données cryptées à l'aide d'une clé symétrique, et pour la phase de connexion, nous avons utilisé deux vérifications d'authentification.

❖ **Analyse formelle**

Dans cette section, nous entreprenons une analyse approfondie du protocole proposé, mettant en œuvre une vérification formelle à l'aide de l'outil SCYTHER. Cette démarche vise à évaluer la robustesse et la fiabilité du protocole dans divers scénarios et à identifier d'éventuelles vulnérabilités.

L'utilisation de l'outil SCYTHER nous permet de modéliser le protocole dans un environnement simulé, où nous pouvons explorer différents paramètres et configurations pour évaluer sa performance et sa sécurité. Cette approche méthodique nous offre des insights précieux sur la solidité du protocole, nous permettant ainsi de prendre des mesures correctives si nécessaire et de garantir un niveau de sécurité optimal pour notre système.

- **Présentation de l'outil sycther**

Scyther représente un outil de vérification avancé spécialement conçu pour les protocoles de sécurité, opérant dans l'hypothèse que toutes les fonctions cryptographiques sont parfaites. Il se distingue par son interface utilisateur graphique intuitive, facilitant ainsi la vérification et la compréhension des protocoles. Chaque fois qu'une attaque est détectée en lien avec une revendication spécifique, Scyther génère des graphes d'attaque correspondants, fournissant ainsi une visualisation claire des vulnérabilités potentielles. De plus,

Scyther peut examiner toutes les revendications envisageables concernant un protocole donné. Cet outil est également précieux pour identifier les problèmes résultant de la conception du protocole. En outre, Scyther est capable de générer tous les modèles de traces possibles, ce qui permet une analyse exhaustive des scénarios possibles. La vérification peut être réalisée avec un nombre limité ou illimité de sessions, offrant ainsi une flexibilité optimale dans l'évaluation de la sécurité. Le langage utilisé pour écrire des protocoles dans Scyther est le SPDL (Security Protocol Description Language), garantissant une syntaxe claire et une représentation précise des protocoles[62].

La figure ci-dessus illustre un exemple du langage SPDL, représentant une section de la phase de connexion et d'authentification de notre protocole proposé. Dans cet extrait, les trois rôles principaux du système sont déclarées : le "gateway", le "capteur" et l'"utilisateur". Les messages transmis entre ces entités sont également spécifiés, décrivant ainsi le flux d'informations lors de la phase de login et de la connexion.

```

protocol protocoleIOHT(S , G , U)
{
  role U
  {
    const ra: Nonce;
    var rb , rc: Nonce;
    fresh T1, T2 , T3 , T4 : Timestamp;
  |
    send_1(U,G, K2, Xug, Z1, T1 );
    rcv_4(G,U, K9 , Xgu , Z2 , T4 );
    macro SKsu = Multiplication(ra , rc , Z2 ,h(PWa , IDa , Ra) );
  }

  role G
  {
    var ra , rc: Nonce;
    const rb: Nonce;
    fresh T1, T2 , T3 , T4 : Timestamp;

    rcv_1(U,G, K2, Xug, Z1, T1 );
    send_2(G,S, K4,K5, Xgs, Z1 , T2 );
    rcv_3(S,G, K7 , Xsg , Z2 , T3 );
    send_4(G,U, K9 , Xgu , Z2 , T4 );
  }

  role S
  {
    var ra , rb: Nonce;
    const rc: Nonce;
    fresh T1, T2 , T3 , T4 : Timestamp;

    rcv_2(G,S, K4,K5, Xgs, Z1 , T2 );
    send_3(S,G, K7 , Xsg , Z2 , T3 );
    macro SKus = Multiplication(ra , rc , Z1 ,h(PWc , IDc , Rc));
  }
}

```

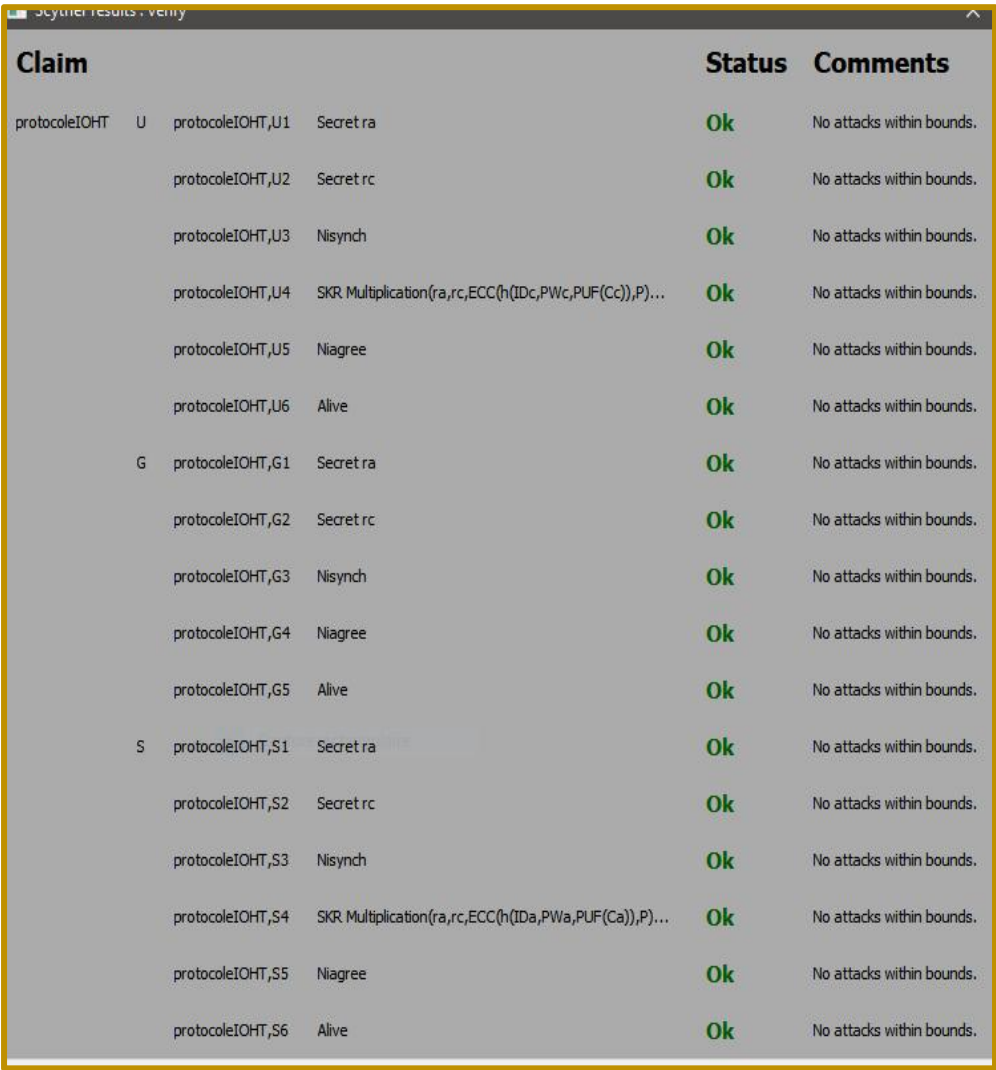
Figure 3.7 phase de connexion et d'authentification en SPDL

• Analyse formelle du protocole proposé

Après avoir soumis notre protocole à une analyse formelle approfondie à l'aide de l'outil Scyther qui il est utilisé de nombreux chercheurs évaluer divers systèmes de sécurité dans des travaux connexes précédents.

nous sommes ravis de confirmer que notre système répond aux normes de sécurité les plus strictes. Les résultats de l'analyse ont démontré de manière concluante que notre protocole est robuste et résilient face à diverses attaques

potentielles. Grâce à l'utilisation de Scyther, nous avons pu modéliser et simuler différentes situations et interactions, vérifiant ainsi chaque aspect du protocole et identifiant toute faiblesse éventuelle.



The screenshot shows a window titled "Scyther results - verify" containing a table with the following data:

Claim	Status	Comments
protocoleIOHT, U		
protocoleIOHT,U1 Secret ra	Ok	No attacks within bounds.
protocoleIOHT,U2 Secret rc	Ok	No attacks within bounds.
protocoleIOHT,U3 Nisynch	Ok	No attacks within bounds.
protocoleIOHT,U4 SKR Multiplication(ra,rc,ECC(h(IDc,PWc,PUF(Cc)),P)...	Ok	No attacks within bounds.
protocoleIOHT,U5 Niagree	Ok	No attacks within bounds.
protocoleIOHT,U6 Alive	Ok	No attacks within bounds.
G		
protocoleIOHT,G1 Secret ra	Ok	No attacks within bounds.
protocoleIOHT,G2 Secret rc	Ok	No attacks within bounds.
protocoleIOHT,G3 Nisynch	Ok	No attacks within bounds.
protocoleIOHT,G4 Niagree	Ok	No attacks within bounds.
protocoleIOHT,G5 Alive	Ok	No attacks within bounds.
S		
protocoleIOHT,S1 Secret ra	Ok	No attacks within bounds.
protocoleIOHT,S2 Secret rc	Ok	No attacks within bounds.
protocoleIOHT,S3 Nisynch	Ok	No attacks within bounds.
protocoleIOHT,S4 SKR Multiplication(ra,rc,ECC(h(IDa,PWa,PUF(Ca)),P)...	Ok	No attacks within bounds.
protocoleIOHT,S5 Niagree	Ok	No attacks within bounds.
protocoleIOHT,S6 Alive	Ok	No attacks within bounds.

Figure 3.8 Résultat de la vérification formelle

En résumé, l'analyse formelle effectuée via l'outil Scyther confirme la sécurité et la fiabilité de notre protocole, renforçant ainsi notre confiance dans sa capacité à protéger les données et à garantir l'intégrité de la communications.

3.7 La conclusion

Dans ce chapitre, nous avons entrepris une exploration des travaux connexes dans le domaine IOHT, en nous concentrant notamment sur le protocole proposé par Chien-Ming Chen et al. Notre analyse approfondie de ce protocole a révélé des vulnérabilités et des failles significatives. Forts de ces constats, nous avons conçu et proposé un protocole alternatif, mettant en œuvre des techniques cryptographiques avancées et des mécanismes d'authentification robustes. Notre approche vise à renforcer la sécurité et l'intégrité des communications dans les environnements IOHT, offrant ainsi une solution plus fiable et sécurisée. Enfin, nous avons soumis notre protocole à une vérification formelle rigoureuse à l'aide de l'outil Scyther, confirmant ainsi sa résilience face aux attaques potentielles.

Conclusion générale

L'Internet des Objets de Santé (IoHT) représente une avancée prometteuse dans le domaine médical, offrant la possibilité de surveiller et de gérer la santé des individus de manière plus efficace et personnalisée. Cependant, cette convergence des technologies médicales et des systèmes d'information pose des défis majeurs en matière de sécurité. Les données sensibles échangées au sein de l'IoHT sont exposées à diverses menaces, telles que la compromission des dispositifs et les cyberattaques, mettant en danger la vie privée et la sécurité des patients.

Dans ce contexte, notre projet a entrepris une analyse approfondie de la sécurité dans l'IoHT, en mettant en lumière les défis spécifiques et les risques potentiels associés à cette technologie émergente. Nous avons réalisé une cryptanalyse du protocole proposé par Chien-Ming Chen et al., mettant en évidence ses vulnérabilités et ses limitations en termes de sécurité.

Fort de cette analyse, nous avons proposé un nouveau schéma d'authentification adapté aux besoins uniques de l'IoHT. En utilisant des techniques cryptographiques avancées telles que l'approche Zero-Trust, les Physical Unclonable Functions (PUF), l'Elliptic Curve Cryptography (ECC) et l'authentification à trois facteurs (3FA), notre protocole offre une protection robuste contre les menaces potentielles. L'analyse formelle et informelle que nous avons menée a confirmé la solidité de notre protocole en termes de sécurité. En utilisant l'outil de vérification formelle Scyther, nous avons pu valider la résistance de notre protocole face à diverses attaques, assurant ainsi sa fiabilité et son efficacité dans un environnement IoHT.

En conclusion, notre travail contribue à renforcer la sécurité et la confiance dans l'IoHT en fournissant un protocole d'authentification avancé et robuste. En poursuivant nos efforts dans ce domaine, nous pouvons favoriser une adoption plus large et plus sûre de l'IoHT, ouvrant la voie à des avancées significatives dans les soins de santé connectés et personnalisés.

Références

- [1] A. Al-Fuqaha, M. Guizani, M. Mohammadi, M. Aledhari, et M. Ayyash, « Internet of Things: A Survey on Enabling Technologies, Protocols, and Applications », *IEEE Commun. Surv. Tutorials*, vol. 17, no. 4, pp. 2347-2376, 2015, doi: 10.1109/COMST.2015.2444095.
- [2] Dynamique Entrepreneuriale, « Quand réserver un billet d'avion pour payer moins cher », *Dynamique Entrepreneuriale*, 2009. [En ligne]. Disponible : <https://www.dynamique-mag.com/article/quand-reserver-billet-avion-payer-moins-cher.9144>. [Accès le : 03-févr.-2024].
- [3] M. Kocakulak et I. Butun, « An overview of Wireless Sensor Networks towards internet of things », in *2017 IEEE 7th Annual Computing and Communication Workshop and Conference (CCWC)*, Las Vegas, NV, USA: IEEE, janv. 2017, pp. 1-6. doi: 10.1109/CCWC.2017.7868374.
- [4] R. Sheldon, « Sensor », *TechTarget*. [En ligne]. Disponible : <https://www.techtarget.com/whatis/definition/sensor>.
- [5] Z. Sheng, C. Zhu, et T. Gu, *Book of Wireless Sensor Networks: Principles, Design, and Applications*, ISBN-13: 978-1447155041.
- [6] A. Belfkih, B. Sadeg, C. Duvallet, et L. Amanton, « Les bases de données dans les réseaux de capteurs sans fil », *Techniques et sciences informatiques*, vol. 33, pp. 739-776, déc. 2014, doi: 10.3166/tsi.33.739-776.
- [7] P. Sethi et S. R. Sarangi, « Internet of Things: Architectures, Protocols, and Applications », *Journal of Electrical and Computer Engineering*, vol. 2017, pp. 1-25, 2017, doi: 10.1155/2017/9324035.
- [8] J. Holler, V. Tsiatsis, et C. Mulligan, *From Machine-to-Machine to the Internet of Things: Introduction to a New Age of Intelligence*, Amsterdam: Academic Press, 2015.
- [9] Ozone Connect, « IoT industriel », *Ozone Connect*. [En ligne]. Disponible : <https://iotindustriel.com/iot-iiot/architecture-iot-lessentiel-a-savoir/>. [Accès le : 11-févr.-2024].
- [10] Z. Xi, « The comparison of decentralized and centralized structure of network communication in different application fields », in *Proceedings of the 2019 International Conference on Management Science and Industrial Economy (MSIE 2019)*, Guangzhou, China: Atlantis Press, 2020, doi: 10.2991/msie-

19.2020.10.

[11] IntelliSoft, « What Describes the Relationship Between Edge Computing and Cloud Computing », IntelliSoft. [En ligne]. Disponible : <https://intellisoft.io/what-describes-the-relationship-between-edge-computing-and-cloud-computing>. [Accès le : 11-févr.-2024].

[12] F. Nack, Institute of Computer Science (ICS), Freie Universität Berlin, « An Overview on Wireless Sensor Networks ».

[13] M. Rafiq, « Radio Frequency Identification (RFID): Its Usage and Libraries », National Textile University, Faisalabad, Pakistan.

[14] A. Hussain et T. Zehra, « RADIO FREQUENCY IDENTIFICATION (RFID) AND LIBRARIES IN THE ERA OF TECHNOLOGY », ResearchGate, mai 2023.

[15] IPv6 Introduction and Configuration, Published May 2012, ISBN-10: 0738450553.

[16] TechTarget, « IPv6 Address », TechTarget. [En ligne]. Disponible : <https://www.techtarget.com/iotagenda/definition/IPv6-address>. [Accès le : 11-févr.-2024].

[17] Y. Guo, S. Zhang, et D. Xiao, « Overview of Wi-Fi Technology », in Proceedings of the 2nd International Conference on Computer Application and System Modeling, China: Atlantis Press, 2012. doi: 10.2991/iccasm.2012.330.

[18] C. D. Truong, « Routing and Sensor Search in the Internet of Things », PhD thesis, Lübeck, Institute of Computer Engineering of the University of Lübeck, 2014, 197 p.

[19] J. Wu, « How Bluetooth Works », ECE Senior Capstone Project, Tech Notes, 2017.

[20] L. A. Amaral, E. de Matos, R. T. Tiburski, F. Hessel, W. T. Lunardi, et S. Marczak, « Middleware Technology for IoT Systems: Challenges and Perspectives Toward 5G », in Internet of Things (IoT) in 5G Mobile Technologies, vol. 8, C. X. Mavromoustakis, G. Mastorakis, et J. M. Batalla, Éd., in Modeling and Optimization in Science and Technologies, vol. 8. Cham: Springer International Publishing, 2016, pp. 333-367. doi: 10.1007/978-3-319-30913-2_15.

[21] S. LoSardo, « The Internet of Healthy Things: Considerations for Healthcare Professionals », VP, Healthcare Solution Delivery, 2011.

[22] TechTarget, « Smart Home or Building », TechTarget. [En ligne]. Disponible :

<https://www.techtarget.com/iotagenda/definition/smart-home-or-building>.
[Accès le : 11-févr.-2024].

[23] D. O. Airehrour, « A Trust-Based Routing Framework for the Internet of Things », PhD thesis, Auckland, Auckland University of Technology, 2017, 284 p.

[24] Insider Intelligence, « IoT Smart City Technology », Insider Intelligence. [En ligne]. Disponible : <https://www.insiderintelligence.com/insights/iot-smart-city-technology>.

[25] Synox, « Smart Farming: IoT for a Smarter Agriculture », Synox. [En ligne]. Disponible : <https://www.synox.io/en/smart-agriculture/smart-farming-iot-for-a-smarter-agriculture/>. [Accès le : 12-févr.-2024].

[26] S. Omar, « Internet of Things (IoT) for Smart Farming: A Systematic Review », IJCA, vol. 174, no. 27, pp. 47-54, mars 2021, doi: 10.5120/ijca2021921182.

[27] Mutualia, « Internet des Objets (IoT) pour une Agriculture Plus Intelligente », Mutualia. [En ligne]. Disponible : <https://www.mutualia.fr/agriculteur/infos/economie-et-societe/news/internet-des-objets-iot-pour-une-agriculture-plus-intelligente>. [Accès le : 12-févr.-2024].

[28] Saft, « How Can IoT Help Us Solve Our Ecological Issues? Episode 2: Biodiversity », Saft. [En ligne]. Disponible : <https://saft.com/energizing-iot/how-can-iot-help-us-solve-our-ecological-issues-episode-2-biodiversity>. [Accès le : 12-févr.-2024].

[29] E. D. Ayele, K. Das, N. Meratnia, et P. J. M. Havinga, « Leveraging BLE and LoRa in IoT Network for Wildlife Monitoring System (WMS) », in 2018 IEEE 4th World Forum on Internet of Things (WF-IoT), Singapore: IEEE, févr. 2018, pp. 342-348. doi: 10.1109/WF-IoT.2018.8355223.

[30] Emnify, « IoT Challenges 2023 », Emnify. [En ligne]. Disponible : <https://www.emnify.com/blog/iot-challenges-2023>. [Accès le : 12-févr.-2024].

[31] B. Marr, « 2024 IoT and Smart Device Trends: What You Need to Know for the Future », Forbes. [En ligne]. Disponible : <https://www.forbes.com/sites/bernardmarr/2023/10/19/2024-iot-and-smart-device-trends-what-you-need-to-know-for-the-future>. [Accès le : 12-févr.-2024].

[32] Freepik, Freepik. [En ligne]. Disponible : <https://www.freepik.com/>. [Accès le : 12-févr.-2024].

[33] R. Yende, Support de Cours de Sécurité Informatique et Crypto, 2018,

Université Chrétienne de Kinshasa.

[34] G. Florin et S. Natkin, La Sécurité, CEPADUES Editions, 1995.

[35] S. Ghernaouti, Cybersécurité: Analyser les Risques, Mettre en Œuvre les Solutions, 2019, Université Paris VI.

[36] V. Na, « The Three Plus One Dimensions of Information Security », Naavi.org. [En ligne]. Disponible : <https://www.naavi.org/wp/the-three-plus-one-dimensions-of-information-security/>. [Accès le : 08-avr.-2024].

[37] M. Keerthika et D. Shanmugapriya, « Wireless Sensor Networks: Active and Passive Attacks - Vulnerabilities and Countermeasures », Global Transitions Proceedings, vol. 2, no. 2, pp. 362-367, nov. 2021, doi: 10.1016/j.gltp.2021.08.045.

[38] A. Diaz et P. Sanchez, « Simulation of Attacks for Security in Wireless Sensor Network », Sensors, vol. 16, no. 11, p. 1932, nov. 2016, doi: 10.3390/s16111932.

[39] A. Mukherjee, « Physical-Layer Security in the Internet of Things: Sensing and Communication Confidentiality Under Resource Constraints », Proc. IEEE, vol. 103, no. 10, pp. 1747-1761, oct. 2015, doi: 10.1109/JPROC.2015.2466548

[40] Cloudflare, « Cloudflare », Cloudflare. [En ligne]. Disponible : <https://www.cloudflare.com/>. [Accès le : 09-avr.-2024].

[41] T. O'Connor, « Detecting and Responding to Data Link Layer Attacks », publié par SANS Institute, 2021.

[42] S. R. Rajeswari et V. Seenivasagam, « Comparative Study on Various Authentication Protocols in Wireless Sensor Networks », The Scientific World Journal, vol. 2016, pp. 1-16, 2016, doi: 10.1155/2016/6854303.

[43] J. Sen, « Security in Wireless Sensor Networks », Department of Computer Science & Engineering, National Institute of Science & Technology, India, doi: 10.1201/b13092-21.

[44] Moodle, « Support de Cours ». [En ligne]. Disponible : https://moodle.utc.fr/file.php/498/SupportWeb/co/Module_RCSF_63.html. [Accès le : 16-avr.-2024].

[45] PGP Corporation, « An Introduction to Cryptography », version 8.0, oct. 2002.

[46] A. Humadi, « Symmetric and Asymmetric Encryption », déc. 2020, doi: 10.13140/RG.2.2.21500.56962.

[47] Check Point Software Technologies, « What is Firewall? », Check Point. [En ligne]. Disponible : <https://www.checkpoint.com/cyber-hub/network-security/what-is-firewall/>. [Accès le : 16-avr.-2024].

[48] Alfabet Group, « Firewall: Filtrer les Menaces Malveillantes », Alfabet Group. [En ligne]. Disponible : <https://alfabet-group.com/firewall-sert-a-filtrer-les-menaces-malveillantes-alfabet-group/>. [Accès le : 16-avr.-2024].

[49] IT Governance, « ISO 27001 », IT Governance. [En ligne]. Disponible : <https://www.itgovernance.co.uk/iso27001>. [Accès le : 16-avr.-2024].

[50] National Institute of Standards and Technology, « Security and Privacy Controls for Information Systems and Organizations », NIST Special Publication 800-53 Revision 5, 2020, doi: 10.6028/NIST.SP.800-53r5.

[51] European Union Agency for Network and Information Security, Baseline Security Recommendations for IoT in the Context of Critical Information Infrastructures. Luxembourg: Publications Office of the European Union, 2017. [En ligne]. Disponible : <https://data.europa.eu/doi/10.2824/03228>. [Consulté le : 17-avr.-2024].

[52] C.-M. Chen, Z. Chen, S. Kumari, et M.-C. Lin, « LAP-IoHT: A Lightweight Authentication Protocol for the Internet of Health Things », *Sensors*, vol. 22, no. 14, p. 5401, juill. 2022, doi: 10.3390/s22145401.

[53] V. Kumar, M. S. Mahmoud, A. Alkhayyat, J. Srinivas, M. Ahmad, et A. Kumari, « RAPCHI: Robust Authentication Protocol for IoMT-Based Cloud-Healthcare Infrastructure », *Journal of Supercomputing*, vol. 78, no. 14, pp. 16167-16196, sept. 2022, doi: 10.1007/s11227-022-04513-4.

[54] S. F. Aghili, H. Mala, M. Shojafar, et P. Peris-Lopez, « LACO: Lightweight Three-Factor Authentication, Access Control and Ownership Transfer Scheme for E-Health Systems in IoT », *Future Generation Computer Systems*, vol. 96, pp. 410-424, juill. 2019, doi: 10.1016/j.future.2019.02.020.

[55] P. Soni, A. K. Pal, et S. H. Islam, « An Improved Three-Factor Authentication Scheme for Patient Monitoring Using WSN in Remote Health-Care System », *Computer Methods and Programs in Biomedicine*, vol. 182, p. 105054, déc. 2019, doi: 10.1016/j.cmpb.2019.105054.

[56] I. Ullah, M. A. Khan, A. M. Abdullah, F. Noor, N. Innab, et C.-M. Chen, « Enabling Secure Communication in Wireless Body Area Networks with Heterogeneous Authentication Scheme », *Sensors*, vol. 23, no. 3, p. 1121, janv.

2023, doi: 10.3390/s23031121.

[57] O. B. J. Rabie, S. Selvarajan, T. Hasanin, G. B. Mohammed, A. M. Alshareef, et M. Uddin, « A Full Privacy-Preserving Distributed Batch-Based Certificate-Less Aggregate Signature Authentication Scheme for Healthcare Wearable Wireless Medical Sensor Networks (HWMSNs) », *International Journal of Information Security*, vol. 23, no. 1, pp. 51-80, févr. 2024, doi: 10.1007/s10207-023-00748-1.

[58] Y. Xie, S. Zhang, X. Li, Y. Li, et Y. Chai, « CasCP: Efficient and Secure Certificateless Authentication Scheme for Wireless Body Area Networks with Conditional Privacy-Preserving », *Security and Communication Networks*, vol. 2019, pp. 1-13, juin 2019, doi: 10.1155/2019/5860286.

[59] G. Thakur, S. Prajapat, P. Kumar, A. K. Das, et S. Shetty, « An Efficient Lightweight Provably Secure Authentication Protocol for Patient Monitoring Using Wireless Medical Sensor Networks », *IEEE Access*, vol. 11, pp. 114662-114679, 2023, doi: 10.1109/ACCESS.2023.3325130.

[60] X. Li, J. Peng, M. S. Obaidat, F. Wu, M. K. Khan, et C. Chen, « A Secure Three-Factor User Authentication Protocol With Forward Secrecy for Wireless Medical Sensor Network Systems », *IEEE Systems Journal*, vol. 14, no. 1, pp. 39-50, mars 2020, doi: 10.1109/JSYST.2019.2899580.

[61] V. Sureshkumar, R. Amin, V. R. Vijaykumar, et S. R. Sekar, « Robust Secure Communication Protocol for Smart Healthcare System with FPGA Implementation », *Future Generation Computer Systems*, vol. 100, pp. 938-951, nov. 2019, doi: 10.1016/j.future.2019.05.058.

[62] N. Dalal, J. Shah, K. Hisaria, et D. Jinwala, « A Comparative Analysis of Tools for Verification of Security Protocols », *Department of Computer Engineering, S.V. National Institute of Technology, Ichchhanath, Surat, India*



الجمهورية الجزائرية الديمقراطية الشعبية
وزارة التعليم العالي والبحث العلمي

Université Badji Mokhtar -Annaba



Un schéma d'authentification sécurisé et légère dans IoHT



LSAP-IoHT

lightweight security
authentication protocol in
the internet of healthcare
thing

Carte d'information

À propos de l'équipe d'encadrement du groupe de travail

1- Équipe d'encadrement :

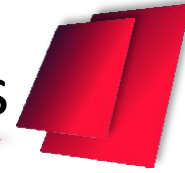
Encadrant principal :	Spécialité :	
Ahmim Marwa	Informatique	

2- Équipe de projet :

Équipe de projet (à titre indicatif)	Faculté	Spécialité	
Étudiant 01 : Ouafi Nour El Houda	technologie	informatique	



Table des matières



<u>Premier axe : Présentation du projet</u>	<u>2</u>
1. L'idée de projet (la solution proposée)	3
2. Les Valeurs suggérées.....	4
3. L'équipe.....	4
4. Les Objectifs du projet.....	4
5. Le planning de réalisation du projet.....	5
<u>Deuxième axe : Aspects innovants</u>	<u>6</u>
1. La nature des innovations.....	7
2. Les domaines d'innovation.....	7
<u>Troisième axe : Analyse stratégique du marché</u>	<u>8</u>
1. Le segment du marché.....	9
2. La mesure de l'intensité de la concurrence.....	9
3. La stratégie marketing	9
<u>Quatrième axe : Plan de production et organisation.....</u>	<u>10</u>
1. Le processus de production.....	11
2. L'approvisionnement.....	11
3. La main d'œuvre.....	12
4. Les principaux partenaires.....	12
<u>Cinquième axe : Plan financier.....</u>	<u>13</u>
1. Les coûts et les charges.....	14
2. Le chiffre d'affaires.....	14
3. Les comptes de résultats escomptés.....	17
4. Le plan de trésorerie.....	18
<u>Sixième axe : Prototype expérimental.....</u>	<u>19</u>





Introduction



L'Internet des Objets de Santé (IoHT, Internet of Health Things) constitue une innovation majeure en fusionnant les technologies de l'information avec les soins médicaux, créant ainsi un réseau intelligent de dispositifs connectés dédiés à la surveillance et à la gestion de la santé. Ce cadre scientifique englobe une multitude de technologies et d'appareils, notamment des capteurs biométriques, des dispositifs portables, des équipements médicaux connectés et des plateformes de télé-santé. Ces composants interagissent via des réseaux sans fil comme le Wi-Fi, le Bluetooth et les réseaux cellulaires pour collecter, transmettre et analyser des données de santé en temps réel.

la nature sensible des données de santé et la diversité des dispositifs impliqués posent des défis significatifs en matière de sécurité et de confidentialité. Les cyberattaques, telles que les interceptions de données, les accès non autorisés, et les altérations de dispositifs, peuvent avoir des conséquences graves. Sans mesures de sécurité robustes, les données de santé peuvent être exposées à des violations de confidentialité, compromettant la vie privée des patients.

Par exemple, une attaque sur un dispositif de surveillance cardiaque connecté pourrait entraîner la transmission de données falsifiées, induisant en erreur les professionnels de santé et mettant la vie du patient en péril.

Notre projet consiste à proposer un nouveau schéma d'authentification léger et sécurisé adapté aux dispositifs de l'Internet des Objets de Santé (IoHT). L'objectif principal est de sécuriser les données sensibles échangées au sein de l'IoHT, en utilisant des techniques cryptographiques avancées. Nous avons intégré plusieurs techniques modernes de sécurité telles que l'approche Zero-Trust, les Physical Unclonable Functions (PUF), l'Elliptic Curve Cryptography (ECC).





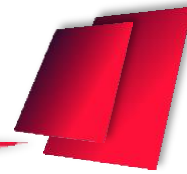
Le premier axe Présentation du projet





Premier axe

Présentation du projet



1. L'idée de projet (solution proposée)

Ce projet vise à concevoir un nouveau schéma d'authentification sécurisé spécifiquement adapté aux dispositifs de l'Internet des Objets de Santé (IoHT). Dans un domaine aussi critique que la santé, où des données sensibles sont échangées en permanence, il est impératif de garantir la sécurité et la confidentialité de ces informations.

Nous avons intégré plusieurs techniques modernes de sécurité telles que l'approche Zero-Trust, les Physical Unclonable Functions (PUF), l'Elliptic Curve Cryptography (ECC).

L'approche Zero-Trust assure que chaque accès est strictement vérifié et authentifié, minimisant ainsi les risques liés aux comportements non sécurisés ou aux attaques internes. Les PUF exploitent les caractéristiques physiques uniques des composants électroniques pour créer des identifiants sécurisés et non reproductibles, ce qui renforce la sécurité contre les tentatives de clonage. L'ECC fournit un niveau élevé de sécurité avec des clés de taille réduite, idéale pour les dispositifs IoHT souvent contraints par des capacités de calcul et de stockage limitées. Enfin, l'authentification à trois facteurs combine des éléments de connaissance tel que ID de possession, un mot de passe, CRP.

Dans notre analyse informelle, nous avons montré que notre protocole est résistant à diverses attaques connues telles que les attaques de l'intérieur (privileged insider attacks), l'usurpation d'identité, les attaques de l'homme du milieu (MITM, Man-In-The-Middle), et les attaques par relecture (replay attacks). Pour valider formellement la sécurité de notre protocole, nous avons utilisé l'outil de vérification Scyther. Les résultats obtenus confirment que notre protocole offre une résistance efficace contre ces menaces, assurant ainsi une protection robuste pour les données sensibles échangées dans l'IoHT.

- ✓ **Domaine d'activité :** Santé, spécifiquement l'Internet des Objets de Santé (IoHT). L'idée est née de la nécessité urgente de sécuriser les données sensibles échangées dans l'IoHT et s'est développée en intégrant des techniques cryptographiques avancées. Ainsi, des médias américains de premier plan tels que "CBS Evening News" et "The Wall Street Journal", ainsi que de nombreuses publications à travers le monde, ont mis en lumière le problème émergent des dispositifs médicaux piratés et des cyberattaques provoquant des pannes dans les services d'urgence des hôpitaux, soulignant que ces attaques sur IOHT pourraient devenir le prochain cauchemar en matière de sécurité
- ✓ **Conception, développement et test d'un nouveau schéma d'authentification adapté aux dispositifs IoHT.**
- ✓ **Le processus impliquera la conception et la mise en œuvre du protocoles, suivis de tests et d'évaluations approfondies.**
- ✓ **Le projet se déroulera principalement dans un environnement de laboratoire dédié à la recherche en sécurité informatique et en technologie de la santé, et dans la future avec des tests potentiels sur des dispositifs IoHT réels**





2. Les valeurs proposées :

Les valeurs proposées :

- ✓ La modernité : Répondre à des besoins entièrement nouveaux , en proposant un schéma d'authentification innovant et adapté aux dispositifs de l'Internet des Objets de Santé (IoHT) qui intègre des techniques cryptographiques avancées telles que PUF, Zero-Trust, ECC et 3FA.
- ✓ La performance : en garantissant un haut niveau de sécurité et de fiabilité pour protéger les données sensibles échangées au sein de l'IoHT.
- ✓ La flexibilité : Permettre des modifications pour adapter le schéma d'authentification aux attentes des clients et aux évolutions technologiques.
- ✓ Accomplissement de tâches : il permet une surveillance continue et à distance des patients, facilitant la gestion des maladies chroniques et réduisant la fréquence des visites médicales ; il améliore la précision des diagnostics et la personnalisation des traitements
- ✓ Réduire les coûts : il contribue à la réduction des coûts de santé en optimisant l'utilisation des ressources et en permettant une détection précoce des anomalies. ce qui peut entraîner une diminution de la fréquence des visites médicales et une meilleure gestion des maladies chroniques.
- ✓ Réduction des risques : Réduire l'exposition aux risques liés à la sécurité des données sensibles dans l'IoHT.
- ✓ Facilité d'utilisation : en garantissant une surveillance continue et à distance des patients, une amélioration de la précision des diagnostics et une personnalisation des traitements, tout en assurant une gestion efficace et sécurisée des données de santé.

3. Équipe de travail :

L'encadrement : Ce présent projet est encadré par Dr Ahmim Marwa

Ahmime Marwa :

Marwa Ahmim est une enseignante-chercheuse à l'Université Badji Mokhtar Annaba, où elle se consacre à la recherche et à l'enseignement dans les domaines de la cybersécurité et de la cryptographie. Forte de son expertise professionnelle , Ses travaux portent sur la protection des systèmes d'information, le développement du protocole de d'authentification avancées et la sécurité des réseaux informatiques.

Ouafi nour el houda

Étudiante en fin de cycle, Master 2 , réseaux et sécurité informatique , à la faculté de technologie de l'université Badji mokhtar-Annaba. Détenant un solide bagage académique en cybersécurité, avec une excellente maîtrise des concepts et des techniques de sécurité informatique. Possédant une compréhension approfondie des principes fondamentaux de la cybersécurité, ainsi que des compétences pratiques en matière de cryptographie, de protection des données et de prévention des cyberattaques

4. Objectifs du projet :

Objectifs à court terme :

- ✓ Développer et valider le schéma d'authentification léger et sécurisé adapté à l'IoHT en utilisant des techniques cryptographiques avancées telles que Zero-Trust, PUF, ECC.
- ✓ Réaliser des tests approfondis en laboratoire pour valider l'efficacité et la fiabilité du schéma d'authentification dans différentes conditions et configurations.
- ✓ Effectuer des tests pilotes sur des dispositifs IoHT pour évaluer l'efficacité et la performance du schéma d'authentification dans un environnement réel



- ✓ Élaborer une stratégie de marketing et de communication pour sensibiliser les acteurs de l'IoHT à notre solution et commencer à établir des partenariats avec des clients potentiels.
- ✓ Objectifs à moyen terme :
- ✓ Déployer notre schéma d'authentification sur une échelle plus large, en ciblant les marchés nationaux et régionaux dans le domaine de la santé et des dispositifs médicaux.
- ✓ Consolider notre réputation en tant qu'acteur majeur de la cybersécurité dans le domaine de la santé en participant à des conférences et des événements de l'industrie, et en publiant des recherches et des études de cas.
- ✓ Objectifs à long terme :
- ✓ Devenir le principal fournisseur du protocole d'authentification pour les dispositifs connectés dans divers domaines, en élargissant notre offre au-delà de l'IoHT en Algérie.
- ✓ Établir des partenariats internationaux avec des entreprises et des organisations de renommée mondiale pour étendre notre présence sur les marchés mondiaux de la cybersécurité et de la santé.
- ✓ Continuer à innover et à évoluer avec les nouvelles tendances et les évolutions technologiques dans le domaine de la cybersécurité et de l'IoHT, en investissant dans la recherche et le développement pour rester à la pointe de l'industrie et répondre aux besoins changeants des clients.

5. Calendrier de réalisation du projet :

			Novembre	Décembre	Janvier	Février	Mars	Avril	Mai	Juin	N+1
1		Préparation et Planification , Élaboration du plan de projet détaillé	✓	✓	✓						
2		Préparation des Documents Nécessaires , collecte des informations nécessaires , des travaux connexes		✓	✓						
3		Conception et Développement , du schéma d'authentification, identification des technologies et des techniques à intégrer.			✓	✓	✓	✓			
4		Test et validation, vérification formelle et informelle					✓	✓	✓	✓	
5		Achat de matières pour le test en conditions réelles.									✓
6		Déploiement et Évaluation									✓





Deuxième axe : Aspects innovants

1. Nature des innovations :

Notre projet vise à protéger ce réseau et les données sensibles qui y sont manipulées par la mise en œuvre d'un protocole d'authentification sécurisé et léger, assurant l'intégrité et la sécurité des informations sur les patients dans un environnement de soins de santé de plus en plus interconnecté.

2. Domaines d'innovation :

- ✓ Nouveaux processus : Le schéma d'authentification proposé améliore significativement la gestion des données de santé en temps réel, permettant une surveillance continue et à distance des patients. Cela réduit le temps consacré à la collecte et à l'analyse des données, augmentant ainsi l'efficacité des opérations hospitalières et réduisant les coûts opérationnels.
- ✓ Nouvelles fonctionnalités : L'intégration de techniques cryptographiques avancées telles que l'approche Zero-Trust, les Physical Unclonable Functions (PUF) et l'Elliptic Curve Cryptography (ECC) offre un niveau de sécurité sans précédent pour les dispositifs IoHT. Cela permet de protéger les données sensibles des patients contre les cyberattaques et les violations de données.
- ✓ Nouveaux clients : Le schéma d'authentification sécurisé peut être adapté à d'autres segments de clientèle au-delà des hôpitaux, comme les cliniques privées, les maisons de retraite et les dispositifs médicaux portables utilisés par les patients à domicile. Cela ouvre de nouvelles opportunités de marché.
- ✓ Nouvelles offres : Notre schéma d'authentification est une solution innovante qui répond à un besoin urgent de sécurisation des données dans le secteur de l'IoHT. Aucun hôpital en Algérie n'utilise actuellement un tel modèle de sécurité, ce qui place mon projet à la pointe de l'innovation technologique dans le domaine de la santé.
- ✓ Nouveaux modèles Le projet propose un nouveau modèle de sécurité pour les dispositifs IoHT, qui repose sur des principes de sécurité avancés et une architecture de confiance zéro. Ce nouveau modèle transforme la façon dont les hôpitaux et les autres établissements de santé gèrent et sécurisent les données des patients, créant ainsi une nouvelle norme de sécurité et de confiance dans le secteur.





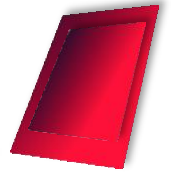
Troisième axe : Analyse stratégique du marché





Troisième axe

Analyse stratégique du marché



1. Le segment du marché

✓ **Le marché potentiel :**

En 2018, selon Mohamed El Hadj, directeur général du ministère de la Santé, le système de santé algérien se composait des éléments suivants :

- 16 Hôpital universitaire
- 297 hôpitaux publics
- 273 organisations locales de soins de santé
- 1708 dispensaires
- 6226 Centres de santé
- 575 organisations privées "Avec 206 hôpitaux"

Ainsi que :

- Maisons de repos et établissements de soins de longue durée
- Patients souhaitant recevoir des soins à domicile
- Médecins et praticiens de santé désireux de surveiller leurs patients à distance

En total, le système de santé algérien se compose de plus de 9000 établissements de santé qui pourraient bénéficier de l'intégration de notre solution de sécurité IoT.

✓ **Le marché cible (le segment) :**

se concentre principalement sur les grandes entités « les hôpitaux »:

- Hôpitaux universitaires (16)
- Hôpitaux publics (297)
- Organisations privées, notamment les hôpitaux privés (206)

Ce segment est priorisé en raison de la complexité et de la sensibilité des données de santé qu'ils gèrent, nécessitant des solutions de sécurité robustes et fiables.

✓ **Pourquoi avons-nous choisi ce marché :**

- Volume de données sensibles dans Les hôpitaux et les organisations de soins
- Besoin urgent de sécurité et des risques élevés de cyberattaques et de violations de données
- Capacité d'adoption des nouvelles technologies

✓ **Déterminer la possibilité de conclure des contrats d'achat avec certains clients importants.**

- Partenariats stratégiques : En établissant des partenariats avec des ministères de la santé et des associations médicales
- Financements et subventions
- Réputation et crédibilité





2. Mesure de l'intensité de la concurrence

- ✓ Il existe quelque entreprises locales et internationales offrant des services de cybersécurité en Algérie.
- ✓ Le gouvernement algérien a pris des mesures pour renforcer la cybersécurité nationale, notamment par la création de l'Agence Nationale de la Sécurité des Systèmes d'Information (ANSSI), qui vise à protéger les infrastructures critiques et à promouvoir une culture de sécurité de l'information.
- ✓ Malgré la présence de certains acteurs, le marché de la cybersécurité en Algérie est encore en développement, laissant de la place pour de nouvelles entreprises et solutions innovantes, particulièrement dans des niches spécifiques comme l'Internet des Objets de Santé (IoHT).
- ✓ Le secteur de la cybersécurité en Algérie présente des opportunités pour les nouveaux entrants, en particulier ceux qui proposent des solutions innovantes et adaptées aux besoins locaux, comme votre schéma d'authentification pour les dispositifs IoHT.
- ✓ Le fait de nous concentrer sur des segments spécifiques comme l'IoHT nous donne un avantage concurrentiel, car il y a probablement moins de solutions spécialisées dans ce domaine particulier.
- ✓ La concurrence dans le marché algérien de la cybersécurité est présente mais modérée, avec de nombreuses opportunités pour des solutions spécialisées et innovantes telles que celles que nous avons proposées.

3. La stratégie marketing

L'objectif de notre stratégie marketing est de sensibiliser les clients potentiels à l'importance de sécuriser les dispositifs de l'Internet des Objets de Santé (IoHT) et de promouvoir notre schéma d'authentification léger et sécurisé comme la solution idéale pour répondre à ce besoin crucial.

- ✓ **Stratégie de Prix** : Prix compétitif et abordable pour encourager l'adoption par les établissements de santé. Offres spéciales pour les premiers adopteurs et les partenariats à long terme..
- ✓ **Plans Tarifaires** : Différents plans tarifaires en fonction de la taille de l'établissement et du niveau de service requis.
- ✓ Vente directe aux hôpitaux et établissements de santé, partenariats et dans le future avec des distributeurs de matériel médical et des intégrateurs de systèmes.
- ✓ **Réseau de Distribution** : Collaboration avec des représentants régionaux pour assurer une couverture nationale.
- ✓ **Événements et Conférences** : Participation à des conférences médicales et de cybersécurité pour démontrer notre solution.
- ✓ **Webinaires et Séminaires** : Organisation de sessions de formation en ligne pour sensibiliser les professionnels de la santé à l'importance de la sécurité des données.
- ✓ **Publications et Articles** : Publication d'articles et d'études de cas dans des revues médicales et technologiques.
- ✓ **Marketing Digital** : Utilisation des réseaux sociaux, du site web et du marketing par courriel pour atteindre notre audience cible.
- ✓ **Relations Publiques** : Collaborations avec des influenceurs du secteur de la santé et des médias spécialisés pour promouvoir notre solution.





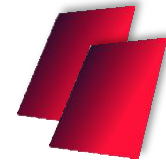
Quatrième axe : Plan de production et d'organisation





Quatrième axe :

Plan de production et d'organisation



1. Le Processus de production

Le développement d'un protocole d'authentification léger et sécurisé pour les dispositifs de l'Internet des objets de santé (IoHT) suit un processus structuré en plusieurs étapes. Ce processus garantit non seulement la qualité du produit final, mais aussi son adéquation aux besoins spécifiques des établissements de santé. Voici les différentes étapes du processus de développement :

- ✓ **Préparation des Documents Nécessaires** : Collecte d'informations sur les besoins de sécurité dans le secteur de l'IoHT. Analyse des menaces et des vulnérabilités existantes , Élaboration de la conception initiale du protocole, incluant les composants cryptographiques tels que PUF, ECC, Zero-Trust, et 3FA.
- ✓ **Conception et Développement** : Conception détaillée du schéma d'authentification. Définition des flux de données et des mécanismes de sécurité intégrés , Implémentation des techniques cryptographiques avancées (PUF, ECC, Zero-Trust, 3FA) dans le prototype.
- ✓ **Tests et Validation** : Évaluation de la robustesse du protocole face aux attaques courantes (e.g., replay, man-in-the-middle, etc.) et Optimisation des algorithmes pour réduire la complexité computationnelle
- ✓ **Déploiement Pilote** :Déploiement du protocole dans un environnement contrôlé "test réel"

2. L'Approvisionnement

- ✓ Inscription à des cours en ligne ou des certifications en cybersécurité pour renforcer nos compétences.
- ✓ Nos principaux fournisseurs seront : les consultants en Cybersécurité ; les vendeurs de matériel informatique et bureautique
- ✓ l' Achat de matériel nécessaire comme des ordinateurs de haute performance pour le développement et les tests, éventuellement des équipements de sécurité spécifiques si nécessaires

3. Les Principaux partenaires

Pour le développement et la mise en œuvre d'un nouveau schéma d'authentification léger et sécurisé pour les dispositifs de l'Internet des Objets de Santé (IoHT). Voici une liste des acteurs potentiels :

- ✓ **Ministère de la Santé** : Collaboration avec le ministère pour aligner le protocole avec les exigences réglementaires et bénéficier de subventions ou d'aides.
- ✓ **Collectivités Locales** : Partenariat avec les autorités locales pour des projets pilotes et le déploiement initial du protocole dans des hôpitaux et cliniques locaux.
- ✓ **Hôpitaux et Cliniques** : Partenariats avec des établissements de santé pour tester et déployer le protocole dans des environnements réels.
- ✓ **Universités et Instituts de Recherche** : Collaboration avec des institutions académiques pour bénéficier de l'expertise en cybersécurité et en IoT.



- ✓ **Laboratoires Spécialisés** : Partenariat avec des laboratoires de recherche pour tester et valider les aspects techniques du protocole.
- ✓ **Incubateurs de Startups** : Intégration dans des programmes d'incubation pour bénéficier de ressources, de mentorat et de financement.
- ✓ **Consultants en Sécurité Informatique** : Engager des experts pour auditer le protocole et fournir des conseils sur les meilleures pratiques en matière de cybersécurité.
- ✓ **Formateurs et Conférenciers** : Collaboration avec des formateurs pour organiser des ateliers et des sessions de formation pour les utilisateurs finaux et les administrateurs.
- ✓ Entreprises de technologies médicales
- ✓ Fournisseurs de matériel informatique

4. La main d'œuvre

Actuellement, le projet repose sur deux emplois directs : mon encadrante et moi-même, toutes deux spécialistes en cybersécurité et administratrices réseau. En plus de notre expertise, ce projet promet de créer de nombreuses opportunités d'emploi dans plusieurs domaines :

- ✓ **Cybersécurité** : Le développement et la maintenance du protocole nécessiteront des spécialistes en cybersécurité pour effectuer des audits de sécurité, analyser les vulnérabilités, et assurer la conformité aux normes de sécurité.
- ✓ **Réseaux** : Des administrateurs réseau seront indispensables pour gérer l'infrastructure, assurer une connectivité sécurisée des dispositifs IoT, et résoudre les problèmes techniques.
- ✓ **Médecine** : La collaboration avec des professionnels de la santé est essentielle pour intégrer le protocole dans les environnements cliniques et hospitaliers, ainsi que pour obtenir des retours sur son efficacité.
- ✓ **Marketing et Vente** : Des responsables marketing et commerciaux seront nécessaires pour promouvoir le protocole, développer des stratégies de vente, et établir des relations avec les clients potentiels





Cinquième axe :

Plan financier





Cinquième axe : Plan financier



1. Les Coûts et charges

✓ **Le projet prévoit les coûts et les frais suivants :**

- La location de la structure est estimée 35 000.00 DA/mois..... 420 000.00 / année
- La masse salariale du personnel 110 000.00 DA/mois.. 1 320 000.00 / année
- Le marketing et la publicité 110 0000.00 DA
- Les charges d'exploitation (eau, gaz , carburant, assurance et autre consommable) 458 000.00 DA
- Expert comptable et avocats 72 000.00 DA

✓ **Le financement du projet :**

Le projet sera financé par l'organisme dédié au financement des startups (ASF)

✓ **Le remboursement des crédits et emprunts**

s'effectuera sur la base d'un échéancier (tableau) à long terme qui sera négocié avec l'organisme concerné.

ARTICLE	MONTANT
location de la structure	420 000.00 / année
La masse salariale du personnel	1 320 000.00 / année
Le marketing et la publicité	110 0000.00 DA
Les charges d'exploitation (eau, gaz , carburant, assurance et autre consommable)	458 000.00 DA
Expert comptable et avocats	72 000.00 DA
TOTAL	3370000,00DA

2. Le Chiffre d'affaires

✓ **Le marché cible**

se concentre principalement sur les grands établissements de santé en Algérie, tels que :

- Hôpitaux publics : 297
- Hôpitaux privés : 206
- Hôpitaux universitaires : 16
- Total des hôpitaux cibles : 519

✓ **Le scénario optimiste**

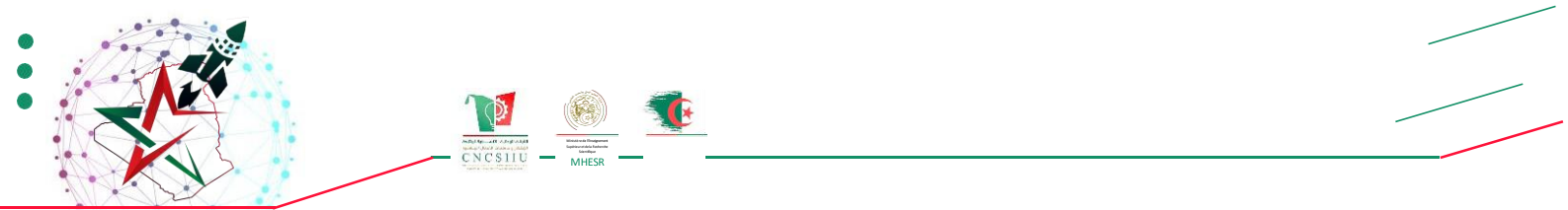
L'année N (L'année de début d'activité) :

Taux d'Adoption :

Compte tenu que nous serons les premiers à proposer une solution de sécurisation avancée pour les dispositifs IoT, nous estimons un taux d'adoption de 30%.

- Hôpitaux adoptant notre solution : 30% de 519 = 155 hôpitaux





Modèle de Facturation :

Nous proposons un modèle de facturation basé sur des frais d'abonnement annuel.

- Frais d'abonnement annuel par hôpital : 200,000.00 DA

Estimation des Revenus Annuels :

En appliquant le modèle de facturation aux hôpitaux estimés à adopter notre solution :

- Revenus annuels = 155 hôpitaux x 200,000 DZD/hôpital
- Total estimé des revenus annuels : 31,000,000.00 DA

Catégorie	Valeur
Total des hôpitaux cibles	519
Taux d'adoption (30%)	155 hôpitaux
Frais d'abonnement annuel par hôpital	200,000 DA
Revenus annuels estimés	31,000,000.00 DA

L'année N+1 (L'année suivante) :

Taux d'Adoption :

Compte tenu que nous serons les premiers à proposer une solution de sécurisation avancée pour les dispositifs IoT, nous estimons un taux d'adoption de 40%.

- Hôpitaux adoptant notre solution : 40% de 519 = 208 hôpitaux

Modèle de Facturation :

Nous proposons un modèle de facturation basé sur des frais d'abonnement annuel.

- Frais d'abonnement annuel par hôpital : 200,000.00 DA

Estimation des Revenus Annuels :

En appliquant le modèle de facturation aux hôpitaux estimés à adopter notre solution :

- Revenus annuels = 208 hôpitaux x 200,000 DA/hôpital
- Total estimé des revenus annuels : 41,600,000.00 DA

Catégorie	Valeur
Total des hôpitaux cibles	519
Taux d'adoption (40%)	208 hôpitaux
Frais d'abonnement annuel par hôpital	200,000 DZD
Revenus annuels estimés	41,600,000.00 DA

✓ **Le scénario pessimiste**

L'année N (L'année de début d'activité) :

Taux d'Adoption :

nous estimons un taux d'adoption de 10%.

- Hôpitaux adoptant notre solution : 10% de 519 = 52 hôpitaux

Modèle de Facturation :

Nous proposons un modèle de facturation basé sur des frais d'abonnement ann



uel.

- Frais d'abonnement annuel par hôpital : 200,000.00 DA

Estimation des Revenus Annuels :

En appliquant le modèle de facturation aux hôpitaux estimés à adopter notre solution :

- Revenus annuels = 52 hôpitaux x 200,000 DA/hôpital
- Total estimé des revenus annuels : 10,400,000.00 DA

Catégorie	Valeur
Total des hôpitaux cibles	519
Taux d'adoption (10%)	52 hôpitaux
Frais d'abonnement annuel par hôpital	200,000 DA
Revenus annuels estimés	10,400,000.00 DA

L'année N+1 (L'année suivante) :

Taux d'Adoption :

nous estimons un taux d'adoption de 20%.

- Hôpitaux adoptant notre solution : 20% de 519 = 104 hôpitaux

Modèle de Facturation :

Nous proposons un modèle de facturation basé sur des frais d'abonnement annuel.

- Frais d'abonnement annuel par hôpital : 200,000.00 DA

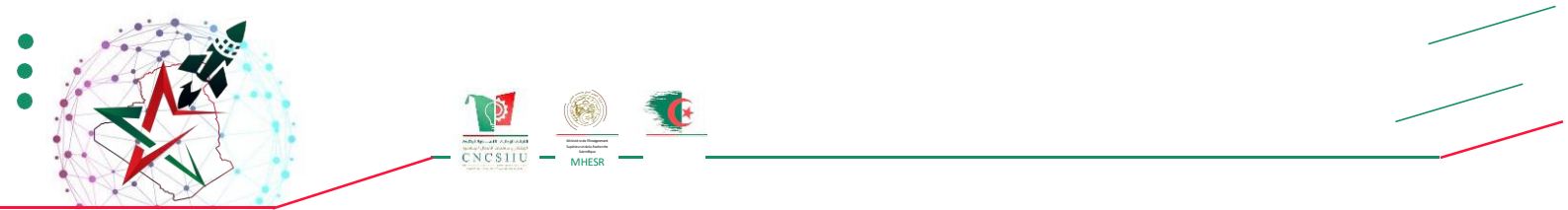
Estimation des Revenus Annuels :

En appliquant le modèle de facturation aux hôpitaux estimés à adopter notre solution :

- Revenus annuels = 104 hôpitaux x 200,000 DA/hôpital
- Total estimé des revenus annuels : 20,800,000.00 DA

Catégorie	Valeur
Total des hôpitaux cibles	519
Taux d'adoption (10%)	104 hôpitaux
Frais d'abonnement annuel par hôpital	200,000 DA
Revenus annuels estimés	20,800,000.00 DA





Bilan d’ouverture

ACTIF	
	REALISATION
En milliers DZD	2024
Immobilisation corporelle	
Le matériel bureautique	400 000.00 DA
Le matériel informatique	500 000.00 DA
Actif non-courant	900 000.00DA
Trésorerie	410 0000.00DA
Actif courant	410 0000.00DA
TOTAL ACTIF	5,000,000DA

PASSIF	
En milliers DZD	N
CAPITAUX PROPRES	0
PASSIFS COURANTS	
Empreins et dettes	5,000,000 DA
Passif non-courant	5,000,000 DA
TOTAL PASSIF	5,000,000 DA

Le compte de résultat

Composantes	Montant (DA)
Chiffre d'affaires	31,000,000.00 DA
Coûts et Charges	110 0000.00 DA
La location de la structure	420 000.00
Valeur Ajoutée (VA)	29 ,480 ,000.00DA
la charge du personnel	1 320 000.00 DA
Excédent Brut d'Exploitation (EBE)	28 ,160, 000.00DA
résultat opérationnel	28 ,160, 000.00DA
résultat ordinaire avant impôt	//
résultat net des activités ordinaires	//
Résultat net de l’exercice	28 ,160, 000.00DA





Le compte de la trésorerie

La start-up projette de générer un flux de trésorerie opérationnel significatif, estimé à 28,160,000.00 DA par an. Ce flux de trésorerie proviendra principalement des revenus d'abonnement annuels facturés aux hôpitaux pour l'utilisation de notre protocole d'authentification sécurisé adapté aux dispositifs de l'Internet des Objets de Santé (IoHT).





Sixième Axe : Prototype expérimental



Sixième axe

Prototype expérimental

1. Modèle du système

Le modèle de système de santé proposé est illustré dans la Figure, Dans ce paradigme, le flux de travail du protocole proposé est composé de trois entités principales : les capteurs ; les utilisateurs, passerelle.

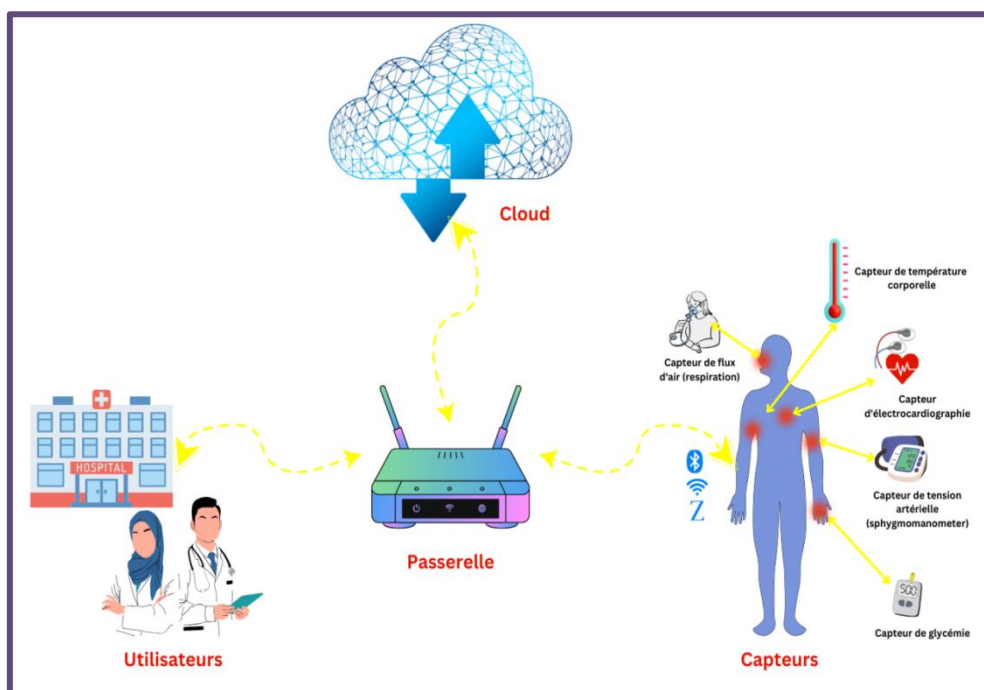


Figure 1 Le modèle de système de santé proposé

✓ les capteurs

Ces capteurs sont placés ou implantés dans le corps humain et leur rôle principal est de collecter les différentes données relatives à la santé, telles que l'ECG, la pression artérielle, la glycémie, la fréquence respiratoire et la température corporelle.

✓ les utilisateurs

Dans le modèle du système proposé, les utilisateurs sont représentés principalement en tant que médecins, qui possèdent un accès autorisé aux données médicales des patients. Ces médecins utilisent le système pour surveiller et analyser l'état des patients, prescrire des

traitements et prendre des décisions thérapeutiques éclairées sur les données fournies par les capteurs.

✓ **passerelle «gateway»**

la passerelle joue le rôle de pivot pour orchestrer la communication entre les utilisateurs et les capteurs, agit comme un intermédiaire de confiance facilitant la transparence de la communication ; elle constitue une unité principale où les informations sont authentifiées et reliées de manière sécurisée entre les différents composants du système.

Au cœur de ce cadre, on trouve le corps du patient équipé de capteurs médicaux sans fil intelligents et à faible consommation d'énergie, tels que des stimulateurs cardiaques, tension artérielle, des capteurs de glycémie, etc. Ces capteurs utilisent souvent des technologies telles que Zigbee ou Bluetooth pour enregistrer et mettre à jour les données et les transmettre ensuite. Par ailleurs, les professionnels de santé, notamment les médecins, peuvent accéder à distance à l'interface de la passerelle pour surveiller l'état des patients et récupérer les informations nécessaires, que le patient se trouve à l'hôpital ou à chez lui. Cela permet un suivi en temps réel de l'état des patients et facilite l'accès rapide aux informations critiques. Les données des patients sont stockées en toute sécurité sur un serveur cloud, ce qui garantit une gestion, une accessibilité et une confidentialité robustes des données au sein de l'écosystème de l'IOHT.

Notations	Descriptions
Ua , GWb , SNc	utilisateur, nœud gateway, nœud capteur
PW _a	Mot de passe de U _a
ID _a	identité de U _a
ID _c	identité de SN _c
PW _c	Mot de passe de SN _c
ID _g	identité de gateway
SK _{sg} , SK _{ug} , SK _{su}	Session key
T _s	Time stamp, avec s = 1, 2, 3, 4
NA , NB , NS , NB1, NB2 , ru , rs ,	nombre aléatoire
rg	XOR , opération de concaténation
⊕ ,	fonction de hachage
H(.)	chiffrement / déchiffrement
ENC/DEC	Physical unclonable function
PUF	Elliptic-curve cryptography
ECC	

Tableau 1 Définitions des notations



2. Notre proposition de schéma «LSAP-IoHT»

Pour répondre aux problèmes de sécurité posés par l'approche de Chien-Ming Chen et al, nous proposons un nouveau schéma d'authentification fiable et efficace pour les systèmes médicaux. En utilisant des techniques cryptographiques avancées et des mécanismes d'authentification robustes. Avec un schéma composé de quatre phases, le système amélioré incorpore les phases suivantes :

- phase d'initiation
- phase d'enregistrement de l'utilisateur
- phase d'enregistrement du capteur
- phase de connexion et d'authentification

✓ phase d'initiation

On considère que cette phase est appliquée avant le commencement du protocole dans un environnement sécurisé, chaque entité « gateway , capteurs , utilisateurs » est équipée de la technologie PUF , et a un Challenge-Response basé sur PUF " CRP ", le gateway a les deux CRP des capteurs et des utilisateurs " CRPs , CRPa " , tandis que les deux capteurs et utilisateurs possèdent le CRP de la gateway "CRPb » , Ce protocole utilise un système ECC léger pour les appareils intelligents.

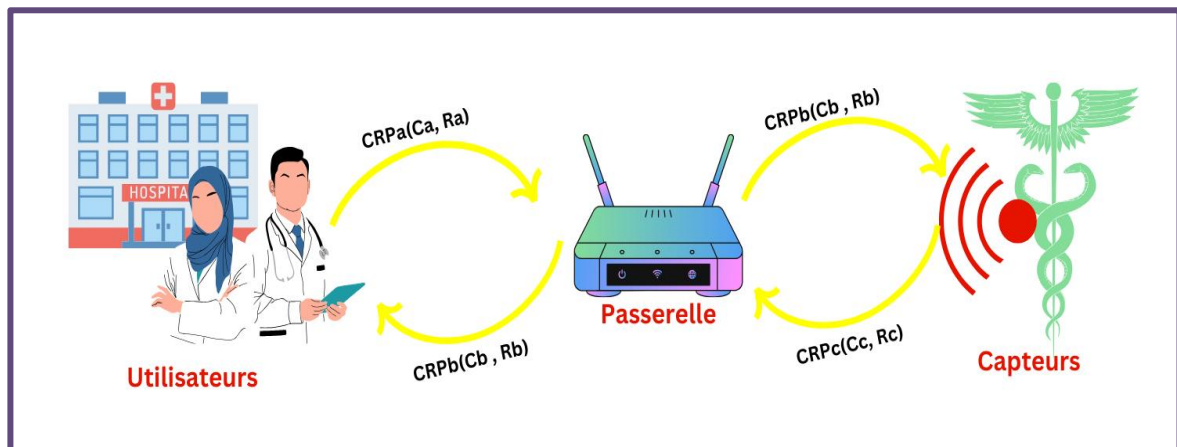


Figure 2 phase d'initiation

✓ phase d'enregistrement de l'utilisateur

Pour que l'utilisateur U_a souhaite être reconnu comme un utilisateur légitime, il doit obligatoirement être enregistré auprès du GWb. Une fois cet enregistrement effectué, tous les messages échangés seront transmis via un canal sécurisé afin de garantir la





confidentialité et l'intégrité des communications.

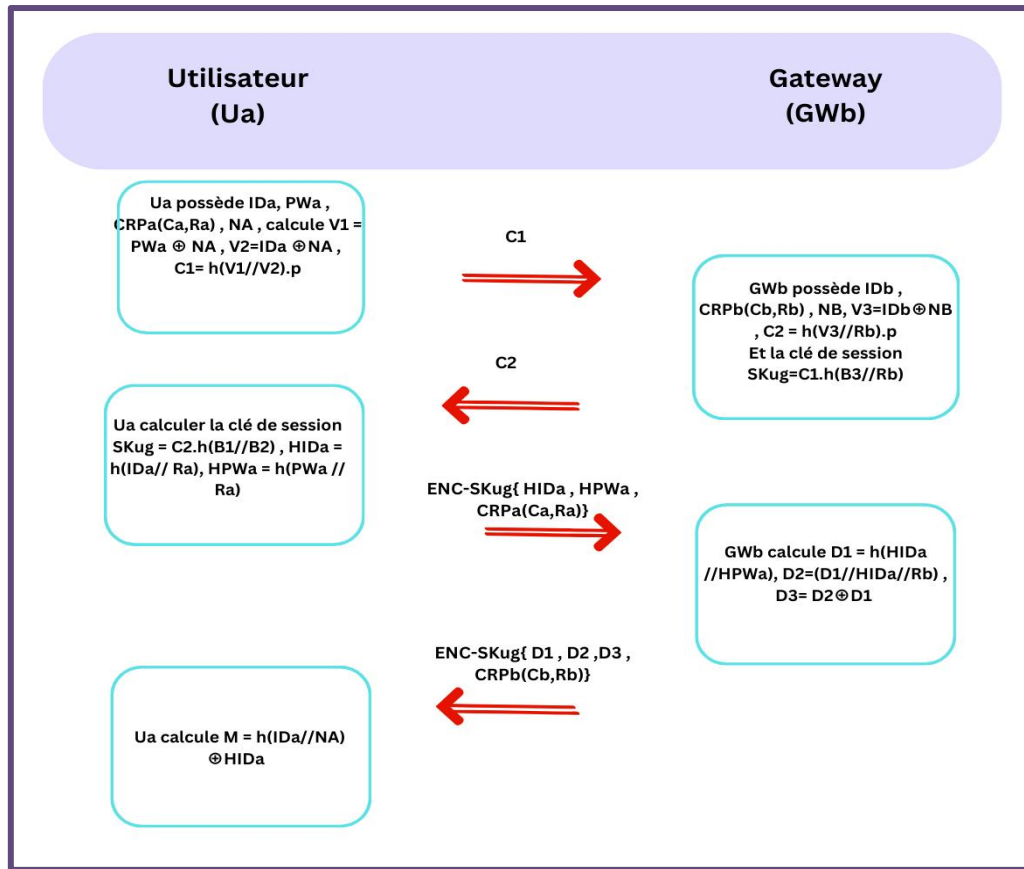


Figure 3 phase d'enregistrement de l'utilisateur

• Message 1

l'utilisateur Ua possède IDa, PWa et PUF a généré l'unique challenge-réponse CRPa (Ca, Ra) et choisit un nombre aléatoire NA, Ua calcule $V1 = PWa \oplus NA$, $V2 = IDa \oplus NA$, $C1 = h(V1/V2).p$

Ua envoie à GWb :{ C1}

• Message 2

GWb possède IDb et PUF a généré l'unique challenge-réponse CRPb (Cb, Rb) et choisit un nombre aléatoire NB, puis il calcule, $V3 = IDb \oplus NB$, $C2 = h(V3/Rb).p$ Et la clé de session $SKug = C1.h(B3/Rb)$

GWb envoie à Ua :{C2}





• Message 3

Ua peut maintenant calculer la clé de session $SK_{ug} = C2.h(B1//B2)$, Ua calcule $HIDa = h(IDa//Ra)$, $HPWa = h(PWa // Ra)$

Ua envoie à GWb: $ENC-SK_{ug}\{HIDa, HPWa, CRPa(Ca, Ra)\}$

• Message 4

GWb vérifie à l'aide de PUF l'identité de Ua, puis il calcule, $D1 = h(HIDa // HPWa)$, $D2 = (D1 // HIDa // Rb)$, $D3 = D2 \oplus D1$,

GWb envoie à Ua : $ENC-SK_{ug}\{D1, D2, D3, CRPb(Cb, Rb)\}$

• Message 5

Ua vérifie à l'aide de PUF l'identité de GWb, puis Ua calcule $M = h(IDa//NA) \oplus HIDa$

✓ phase d'enregistrement du capteur

Un capteur portable doit également être enregistré auprès du GWb avant de pouvoir se connecter au réseau. Une fois enregistré, les messages sont transmis via un canal sécurisé, assurant ainsi la sécurité des communications.

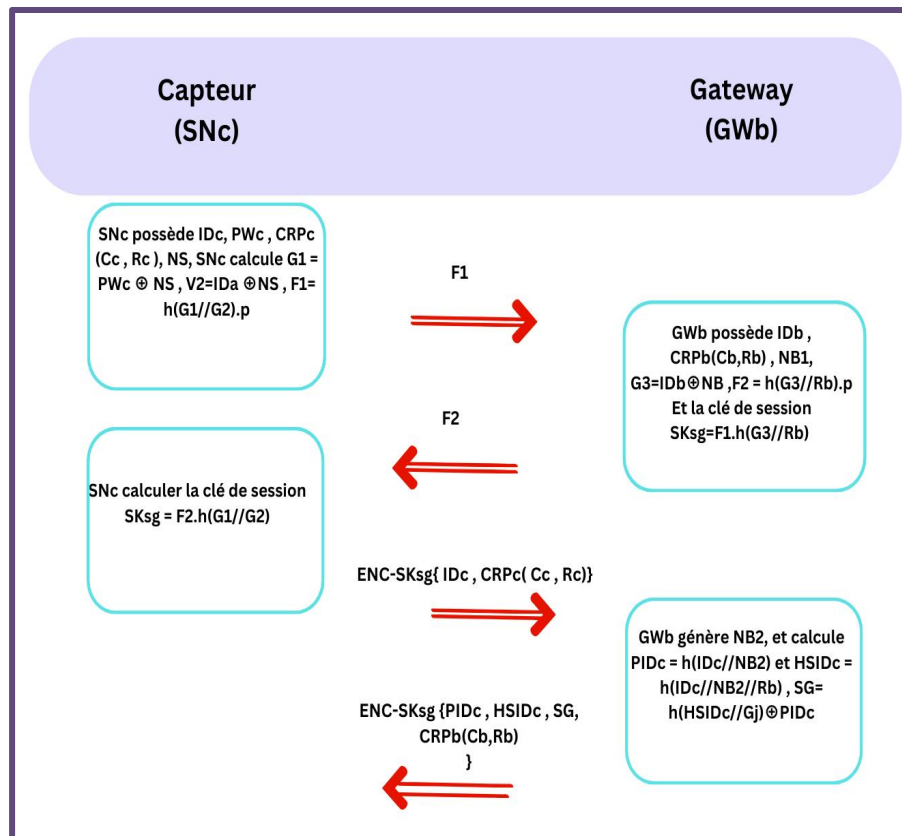


Figure 4 phase d'enregistrement du capteur





• Message 1

Le capteur SNc possède IDc, PWc et PUF a généré l'unique challenge-réponse CRPc (Cc , Rc) et choisit un nombre aléatoire Ns , SNc calcule $G1 = PWc \oplus NS$, $V2 = IDa \oplus NS$, $F1 = h(G1//G2).p$

SNc envoie à GWb :{ F1}

• Message 2

GWb possède IDb et PUF a généré l'unique challenge-réponse CRPb (Cb , Rb) et choisit un nombre aléatoire NB1, puis il calcule , $G3 = IDb \oplus NB$, $F2 = h(G3//Rb).p$
Et la clé de session $SKsg = F1.h(G3//Rb)$

GWb envoie à SNc {F2}

• Message 3

SNc peut maintenant calculer la clé de session $SKsg = F2.h(G1//G2)$

SNc envoie à GWb / ENC-SKsg{ IDc , CRPc(Cc , Rc)}

• Message 4

GWc génère un nombre aléatoire NB2 et calcule la pseudo-identité de SNc, $PIDc = h(IDc//NB2)$ et $HSIDc = h(IDc//NB2//Rb)$, $SG = h(HSIDc//Gj) \oplus PIDc$

GWb envoie à SNc : ENC-SKsg {PIDc , HSIDc , SG, CRPb(Cb,Rb)}

✓ phase de connexion et d'authentification

Si Ua demande une connexion à un capteur portable spécifique SNc, GWb doit confirmer que l'utilisateur est légitime.

• Message 1

Ua insère sa carte à puce dans un ordinateur ou un lecteur de carte à puce, et lui fournit son IDa , PWa , CRPa(Ca,Ra) , cet ordinateur calcule $M' = h(IDa// NA) \oplus HIDa$, ensuite, il détermine si M' est égal à M stocké dans la carte à puce , si c'est le cas, il génère un nombre aléatoire ra et un horodateur T1 et calcule $K1 = h(D1//Ra)$, $K2 = K1 \oplus ra$, $Z1 = h(IDa //PWa//Ra).p$, $Xug = h(T1// ra//Z1)$.

Ua envoie à GWb { K2, Xug , Z1, T1}

• Message 2

GWb vérifie la fraîcheur de T1 , Ensuite, il calcule $K1' = h(D1//Ra)$, $ra = K1' \oplus K2$, $Xug' = h(T1// ra//Z1)$, Si Xug reçu est égal à Xug' calculé, GWc calcule un nombre aléatoire rb et un horodateur T2, $K3 = ra \oplus h(HSIDc//Rb)$, $K4 = K3 \oplus PIDc$, $K5 = rb \oplus HSIDc \oplus ra$, $Xgs = h(T2//ra//rb//Z1//IDc)$.

GWb envoie à SNc {K4, K5,Xgs,Z1, T2}

• Message 3

SNb vérifie la fraîcheur de T2 , Ensuite, SNc calcule $K3' = K4 \oplus PIDc$, $ra = K3' \oplus SG \oplus PIDc$, $rb = K5 \oplus HSIDc \oplus ra$, $Xgs' = h(T2//ra//rb//Z1//IDc)$, Si Xgs reçu est égal à Xgs' calculé , SNb





alcule un nombre aléatoire rc et un horodateur $T3$, $K6 = rc \oplus h(SG//Rc//rb)$, $k7 = PIDc \oplus K6$, $Z2 = h(PWc//IDc//Rc).p$, $Xsg = h(T3//rc//rb//Z2//SG)$, Enfin, SNc calcule la clé de session $SKsu = ra.rc.Z1.h(PWc//IDc//Rc)$

SNc envoie à GWb { $K7$, Xsg , $Z2$, $T3$ }

• Message 4

GWb vérifie la fraîcheur de $T3$, Ensuite, il calcule $k6' = PIDc \oplus K7$, $rc = K6' \oplus h(SG//Rc//rb)$, $Xsg' = h(T3//rc//rb//Z2//SG)$, Si Xsg reçu est égal à Xsg' calculé, GWb calcule un horodateur $T4$, $K8 = rc \oplus h(D1//K1)$, $K9 = K8 \oplus h(HIDa//Rb)$, et il calcule $Xgu = h(T4//rc//Z2//Rb//ra)$ pour une autre authentification mutuelle.

GWb envoie à Ua { $K9$, Xgu , $Z2$, $T4$ }

• Message 5

Ua vérifie la fraîcheur de $T4$, Ensuite, il calcule $K8' = K9 \oplus h(HIDa//Rb)$, $rc = K8' \oplus h(D1//B1)$, et il calcule $Xgu = h(T4//rc//Z2//Rb//ra)$, Si Xgu reçu est égal à Xgu' calculé, Ua calcule la clé de session $SKsu = ra.rc.Z2.h(PWa//IDa//Ra)$

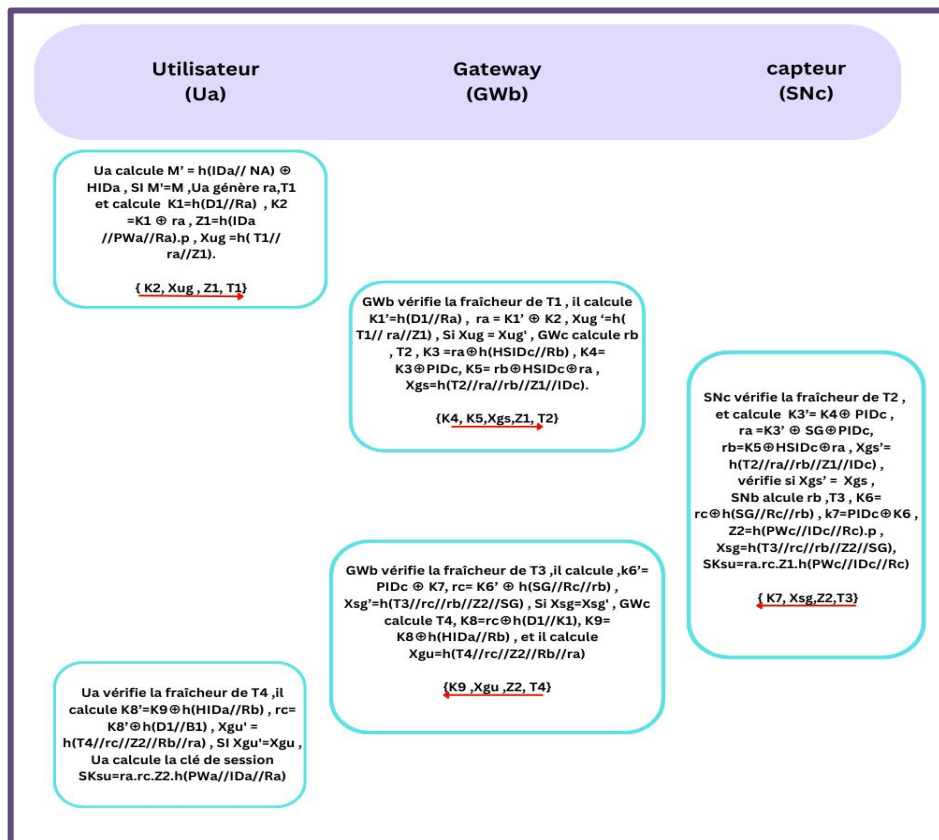


Figure 5 phase d'enregistrement du capteur





3. Analyse de sécurité

Cette analyse formelle vise à examiner la robustesse et l'efficacité de notre protocole de sécurité dans le contexte du IoHT. Nous allons évaluer les mécanismes de cryptographie et d'authentification utilisés, leur intégration harmonieuse dans l'architecture globale du système, et leur capacité à répondre aux menaces potentielles. En fournissant une évaluation détaillée et rigoureuse, nous espérons démontrer que notre protocole peut offrir une sécurité fiable et adaptable dans un environnement de santé hautement connecté et nous prouvons également que notre approche est résistante à différents types d'attaques. Enfin, nous avons utilisé scyther pour montrer que le protocole que nous avons proposé est sécurisé.

✓ Analyse informelle

Dans cette analyse, nous prouvons la capacité de résistance aux attaques connues, et nous définissons quelques techniques cryptographiques utilisées.

- **Attaque par Rejeu**

Dans notre protocole proposé, les messages transmis comprennent des timestamps et des nombres aléatoires, tels que T1, T2, NA et NB. Les timestamps et les nombres aléatoires sont deux moyens efficaces de prévenir les attaques par rejeu. En intégrant ces mécanismes, notre protocole garantit la résistance aux attaques par rejeu, préservant ainsi la sécurité et l'intégrité des communications.

- **Attaque par usurpation d'identité**

Pour chaque entité du système - nœud gateway, nœud capteur et utilisateur - nous avons utilisé une double vérification d'authentification pour chaque message transmis. En outre, nous avons adopté une authentification à trois facteurs. Chaque entité est équipée d'une identité, d'un mot de passe et d'une paire Challenge-Réponse (CRP) unique du PUF. Cette approche de sécurité à plusieurs niveaux garantit que même si un attaquant tente de pénétrer dans le système, il ne réussit pas à passer la double vérification d'authentification.

- **Attaque d'initiés privilégiés**

Le protocole que nous avons proposé est sécurisé contre les attaques d'initiés privilégiés grâce à la mise en œuvre de PUF (Physically Unclonable Functions). Chaque entité du système est authentifiée à l'aide d'une paire Challenge-Réponse (CRP) PUF unique, qui ne peut être ni dupliquée ni prédite. Cela garantit que même les initiés privilégiés, qui pourraient avoir accès à d'autres détails d'authentification, ne peuvent pas reproduire les réponses PUF uniques d'autres entités. et même si l'attaquant pouvait obtenir certaines données, il ne pourrait pas trouver les clés, certaines des données qui entrent dans la génération des clés n'ayant même pas été envoyées. Par conséquent, le protocole atténue efficacement le risque de menaces d'initiés, en maintenant l'intégrité et la sécurité du système.

- **Attaque physique**

La nature simple des appareils IOHT permet aux adversaires d'y accéder facilement. Dans une attaque physique, l'attaquant peut accéder physiquement à l'appareil IoT pour extraire





les clés secrètes et, par conséquent, cloner l'appareil , Le protocole que nous avons proposé est considéré comme étant sécurisé contre ce type d'attaque en raison du fait que les microcontrôleurs et les PUF des appareils sont intégrés sur la même puce et communiquent de manière sécurisée. Par conséquent, même si un attaquant a un accès physique à l'appareil IoT, il ne peut en extraire aucune des clés secrètes.

- **Attaque de l'homme du milieu**

notre protocole proposé est considéré être résistant à ce type d'attaque du fait que l'attaquant MITM a besoin de connaître des informations spécifiques pour construire des données valides afin de commencer l'attaque. Connaître toutes ces informations n'est pas possible pour un adversaire actif qui se place sur la ligne de communication entre les trois parties qui communiquent, dans la phase d'enregistrement de l'utilisateur et dans l'enregistrement du capteur, nous avons envoyé les données cryptées à l'aide d'une clé symétrique, et pour la phase de connexion, nous avons utilisé deux vérifications d'authentification.

- ✓ **Analyse formelle**

Dans cette section, nous entreprenons une analyse approfondie du protocole proposé, mettant en œuvre une vérification formelle à l'aide de l'outil SCYTHYER. Cette démarche vise à évaluer la robustesse et la fiabilité du protocole dans divers scénarios et à identifier d'éventuelles vulnérabilités.

L'utilisation de l'outil SCYTHYER nous permet de modéliser le protocole dans un environnement simulé, où nous pouvons explorer différents paramètres et configurations pour évaluer sa performance et sa sécurité. Cette approche méthodique nous offre des insights précieux sur la solidité du protocole, nous permettant ainsi de prendre des mesures correctives si nécessaire et de garantir un niveau de sécurité optimal pour notre système.

- **Présentation de l'outil scyther**

Scyther représente un outil de vérification avancé spécialement conçu pour les protocoles de sécurité, opérant dans l'hypothèse que toutes les fonctions cryptographiques sont parfaites. Il se distingue par son interface utilisateur graphique intuitive, facilitant ainsi la vérification et la compréhension des protocoles. Chaque fois qu'une attaque est détectée en lien avec une revendication spécifique, Scyther génère des graphes d'attaque correspondants, fournissant ainsi une visualisation claire des vulnérabilités potentielles. De plus, Scyther peut examiner toutes les revendications envisageables concernant un protocole donné. Cet outil est également précieux pour identifier les problèmes résultant de la conception du protocole. En outre, Scyther est capable de générer tous les modèles de traces possibles, ce qui permet une analyse exhaustive des scénarios possibles. La vérification peut être réalisée avec un nombre limité ou illimité de sessions, offrant ainsi une flexibilité optimale dans l'évaluation de la sécurité. Le langage utilisé pour écrire des protocoles dans Scyther est le SPDL (Security Protocol Description Language), garantissant une syntaxe claire et une représentation précise des protocoles[62].

La figure ci-dessus illustre un exemple du langage SPDL, représentant une section de la phase de connexion et d'authentification de notre protocole proposé. Dans cet extrait, les





trois rôle principales du système sont déclarées : le "gateway", le "capteur" et l'"utilisateur". Les messages transmis entre ces entités sont également spécifiés, décrivant ainsi le flux d'informations lors de la phase de login et de la connexion.

```
protocol protocoleIOHT(S , G , U)
{
  role U
  {
    const ra: Nonce;
    var rb , rc: Nonce;
    fresh T1, T2 , T3 , T4 : Timestamp;

    send_1(U,G, K2, Xug, Z1, T1 );
    recv_4(G,U, K9 , Xgu , Z2 , T4 );
    macro SKsu = Multiplication(ra , rc , Z2 ,h(PWa , IDa , Ra) );
  }

  role G
  {
    var ra , rc: Nonce;
    const rb: Nonce;
    fresh T1, T2 , T3 , T4 : Timestamp;

    recv_1(U,G, K2, Xug, Z1, T1 );
    send_2(G,S, K4,K5, Xgs, Z1 , T2 );
    recv_3(S,G, K7 , Xsg , Z2 , T3 );
    send_4(G,U, K9 , Xgu , Z2 , T4 );
  }

  role S
  {
    var ra , rb: Nonce;
    const rc: Nonce;
    fresh T1, T2 , T3 , T4 : Timestamp;

    recv_2(G,S, K4,K5, Xgs, Z1 , T2 );
    send_3(S,G, K7 , Xsg , Z2 , T3 );
    macro SKus = Multiplication(ra , rc , Z1 ,h(PWc , IDc , Rc));
  }
}
```

Figure 6 phase de connexion et d'authentification en SPDL



• **Analyse formelle du protocole proposé**

Après avoir soumis notre protocole à une analyse formelle approfondie à l'aide de l'outil Scyther qui il est utilisé de nombreux chercheurs évaluer divers systèmes de sécurité dans des travaux connexes précédents.

Claim	Status	Comments
protocoleIOHT, U	Ok	No attacks within bounds.
protocoleIOHT,U1 Secret ra	Ok	No attacks within bounds.
protocoleIOHT,U2 Secret rc	Ok	No attacks within bounds.
protocoleIOHT,U3 Nisynch	Ok	No attacks within bounds.
protocoleIOHT,U4 SKR Multiplication(ra,rc,ECC(h(IDc,PWc,PUF(Cc)),P)...	Ok	No attacks within bounds.
protocoleIOHT,U5 Niagree	Ok	No attacks within bounds.
protocoleIOHT,U6 Alive	Ok	No attacks within bounds.
G	Ok	No attacks within bounds.
protocoleIOHT,G1 Secret ra	Ok	No attacks within bounds.
protocoleIOHT,G2 Secret rc	Ok	No attacks within bounds.
protocoleIOHT,G3 Nisynch	Ok	No attacks within bounds.
protocoleIOHT,G4 Niagree	Ok	No attacks within bounds.
protocoleIOHT,G5 Alive	Ok	No attacks within bounds.
S	Ok	No attacks within bounds.
protocoleIOHT,S1 Secret ra	Ok	No attacks within bounds.
protocoleIOHT,S2 Secret rc	Ok	No attacks within bounds.
protocoleIOHT,S3 Nisynch	Ok	No attacks within bounds.
protocoleIOHT,S4 SKR Multiplication(ra,rc,ECC(h(IDa,PWa,PUF(Ca)),P)...	Ok	No attacks within bounds.
protocoleIOHT,S5 Niagree	Ok	No attacks within bounds.
protocoleIOHT,S6 Alive	Ok	No attacks within bounds.

Figure 7 Résultat de la vérification formelle

nous sommes ravis de confirmer que notre système répond aux normes de sécurité les plus strictes. Les résultats de l'analyse ont démontré de manière concluante que notre protocole est robuste et résilient face à diverses attaques potentielles. Grâce à l'utilisation de Scyther, nous avons pu modéliser et simuler différentes situations et interactions, vérifiant ainsi chaque aspect du protocole et identifiant toute faiblesse éventuelle.

En résumé, l'analyse formelle effectuée via l'outil Scyther confirme la sécurité et la fiabilité de notre protocole, renforçant ainsi notre confiance dans sa capacité à protéger les données et à garantir l'intégrité de la communications.

LSAP-IOHT Business Model Canvas

11

Les partenaires clés	Activités clés	Proposition de valeur	Relations avec les clients	Segments de clients
- Ministère de la Santé - Hôpitaux et Cliniques - Universités et Instituts de Recherche - Laboratoires Spécialisés - Incubateurs de Startups - Consultants en Sécurité Informatique - Formateurs et Conférenciers - Collectivités Locales - Entreprises de technologies médicales et informatique	- Développement du protocoles de sécurité - Tests de sécurité - Feedback et amélioration continue - Personnalisation : Adapter le protocole aux systèmes existants des établissements de santé - Recherche et développement: pour rester à la pointe des innovations en cybersécurité - Maintenance : Effectuer des mises à jour régulières pour maintenir la sécurité et la performance du protocole - Marketing et acquisition de clients - Développement de Nouveaux Protocoles et Systèmes: Développer des protocoles adaptés à différents domaines - Solutions complètes de cybersécurité : Concevoir des solutions intégrées comprenant la détection, la prévention et la réponse aux incidents de sécurité.	- Sécurisation des données sensibles des patients en temps réel - un haut niveau de sécurité et de fiabilité - surveillance continue et à distance des patients - facilitant la gestion des maladies chroniques - Réduction de la fréquence des visites médicales grâce à une surveillance proactive - Amélioration de la précision des diagnostics et de la personnalisation des traitements - Réduction des coûts de santé grâce à l'optimisation des ressources - Conception d'un protocole léger qui minimise l'impact sur les ressources des dispositifs IoT - Réduction de l'exposition aux risques liés aux cyberattaques - Innovation technologique : Répondre à des besoins entièrement nouveaux , en proposant un schéma d'authentification innovant et adapté aux dispositifs de l'Internet des Objets de Santé (IoHT) qui intègre des techniques cryptographiques avancées	- Support technique 24/7: Assistance continue pour résoudre les problèmes techniques. - Programmes de fidélisation et Réductions : Offrir des réductions pour les abonnements à long terme. - Formations et ateliers pour le personnel de santé - Suivi Régulier et Évaluation de la Satisfaction : Effectuer des suivis réguliers avec les clients pour s'assurer que le protocole répond à leurs besoins et pour identifier toute opportunité d'amélioration. - Feedback Client : Recueillir activement les retours d'expérience des utilisateurs - Bulletins d'Information : Envoyer régulièrement des newsletters pour tenir les clients informés des mises à jour du produit, des nouvelles fonctionnalités, et des meilleures pratiques. - Ventes directes aux établissements de santé - Participation à des conférences et salons sur la santé et la technologie - Publicité et marketing digital (site web, réseaux sociaux) - Recommandations par les professionnels de santé - Publications et Articles - Collaborations avec des influenceurs du secteur de la santé et des médias spécialisés	- Hôpitaux publics et privés : Comprend les grands hôpitaux universitaires, les hôpitaux généraux publics et les établissements de santé privés et Fournir des solutions de sécurité pour la gestion des données patient. - Cliniques et centres de santé - Maisons de repos et établissements de soins de longue durée : Surveillance continue des résidents. - Médecins et professionnels de santé indépendants : Surveillance à distance et sécurisée de leurs patients. - Patients nécessitant une surveillance continue à domicile ,Patients souffrant de maladies chroniques.
Structure des coûts		Flux de revenus		
- Coûts de développement et de maintenance du protocole - Location de la structure - Masse salariale - Marketing et publicité - Charges d'exploitation - Frais de formation et support technique - Expert comptable et avocats		- Abonnement annuel par hôpital ou établissement de santé - Ventes de licences pour l'utilisation du protocole - Services additionnels (formations, support premium , consultation) - Partenariats et collaborations avec des entreprises de technologies médicales		